

Unified CM Security Architecture

Technical Foundations for Deployment

Matt Jordy (mjordy@cisco.com)
Technical Marketing Engineer, CTG

Scott Kiewert (sckiewer@cisco.com)
Technical Marketing Engineer, CTG

cisco Live !

Webex App

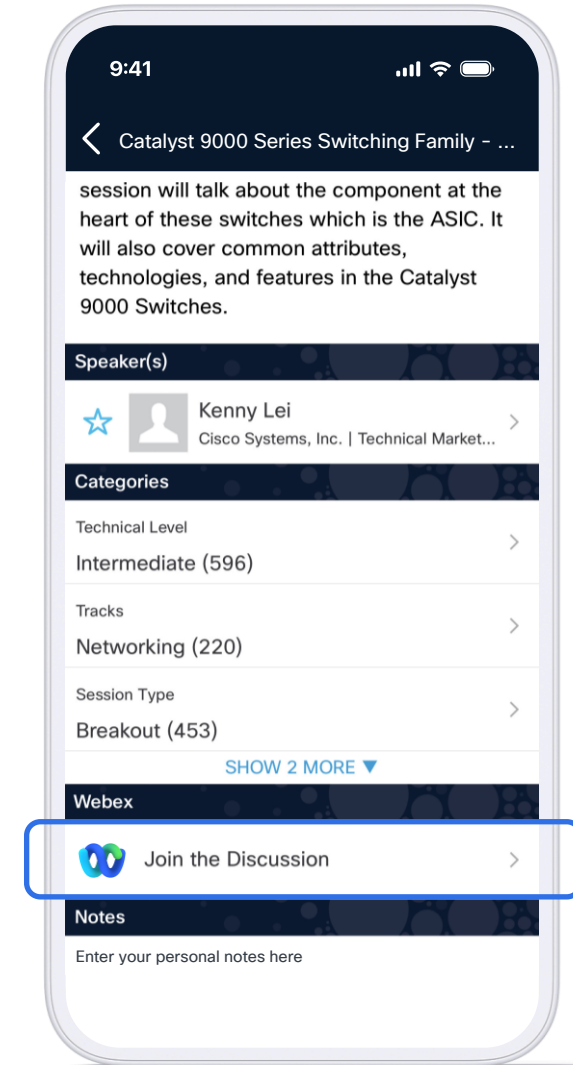
Questions?

Use Webex App to chat with the speaker after the session

How

- 1 Find this session in the Cisco Events App
- 2 Click “Join the Discussion”
- 3 Install the Webex App or go directly to the Webex space
- 4 Enter messages/questions in the Webex space

Webex spaces will be moderated by the speaker until February 27, 2026.



Agenda

- 01 Architecture Overview**
- 02 Client and Device Trust with PKI**
- 03 Certificate Management & Encryption**
- 04 API Protection and OAuth 2.0**
- 05 Simplified Device Onboarding & Provisioning**
- 06 Conclusions and References**

Rome was not built in a day...

CSR 11.x:

- LSC management
- Next-gen encryption
- Single SAML agreement
- Mixed mode auto-reg

CSR 12.5:

- TLS cipher suite control
- ECDSA endpoint certificates
- SIP OAuth for Jabber
- Secure phone onboarding
- Expwy-E automatic certificates
- Automatic phone cert enrollment

CSR 15:

- TLS 1.3
- OAuth with refresh for Wx App
- OAuth framework enhancements

CSR 10.x:

- SAML SSO
- Cluster-wide certs
- MRA

CSR 12.0-12.1:

- OAuth with refresh
- Jabber MRA improvements
- ITLRecovery trust anchor
- TLS 1.2

CSR 14:

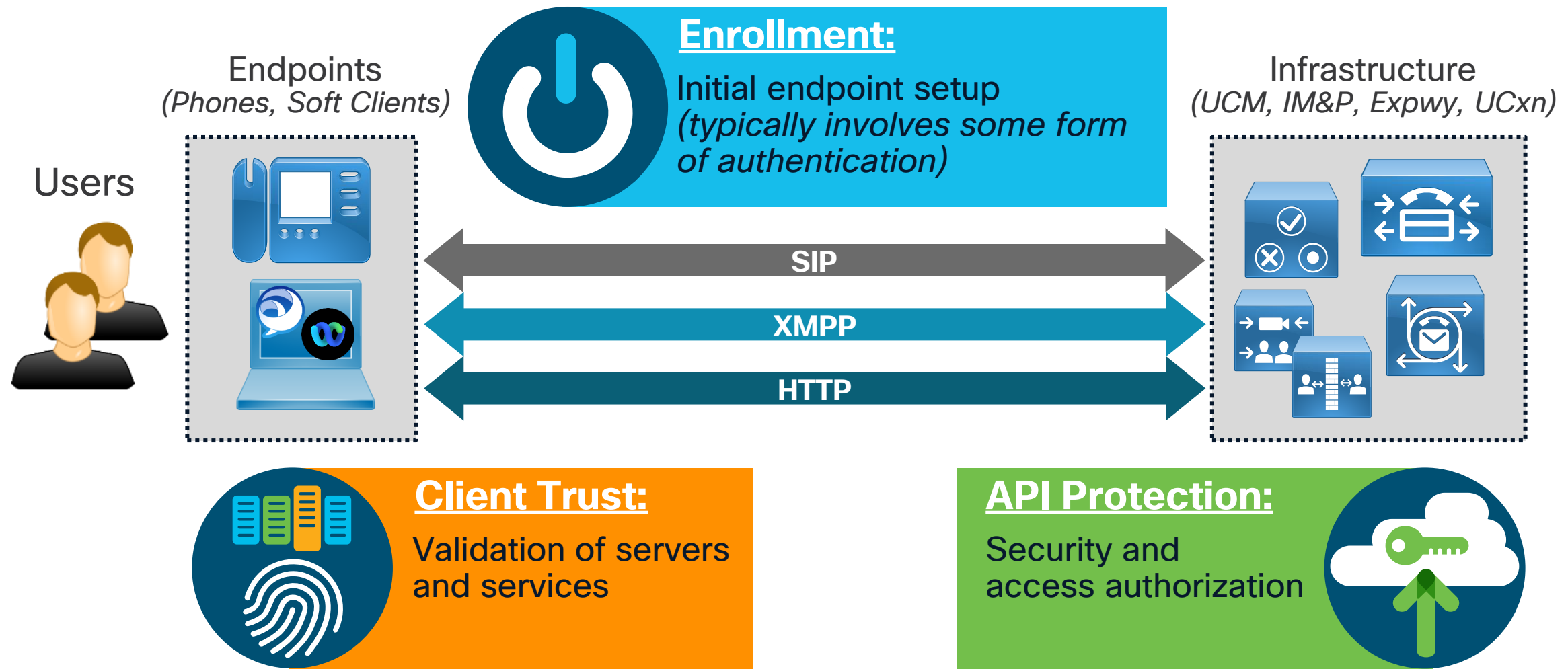
- Always-secure phones with OAuth
- Server cert reduction
- Centralized cert mgmt



Architecture Overview

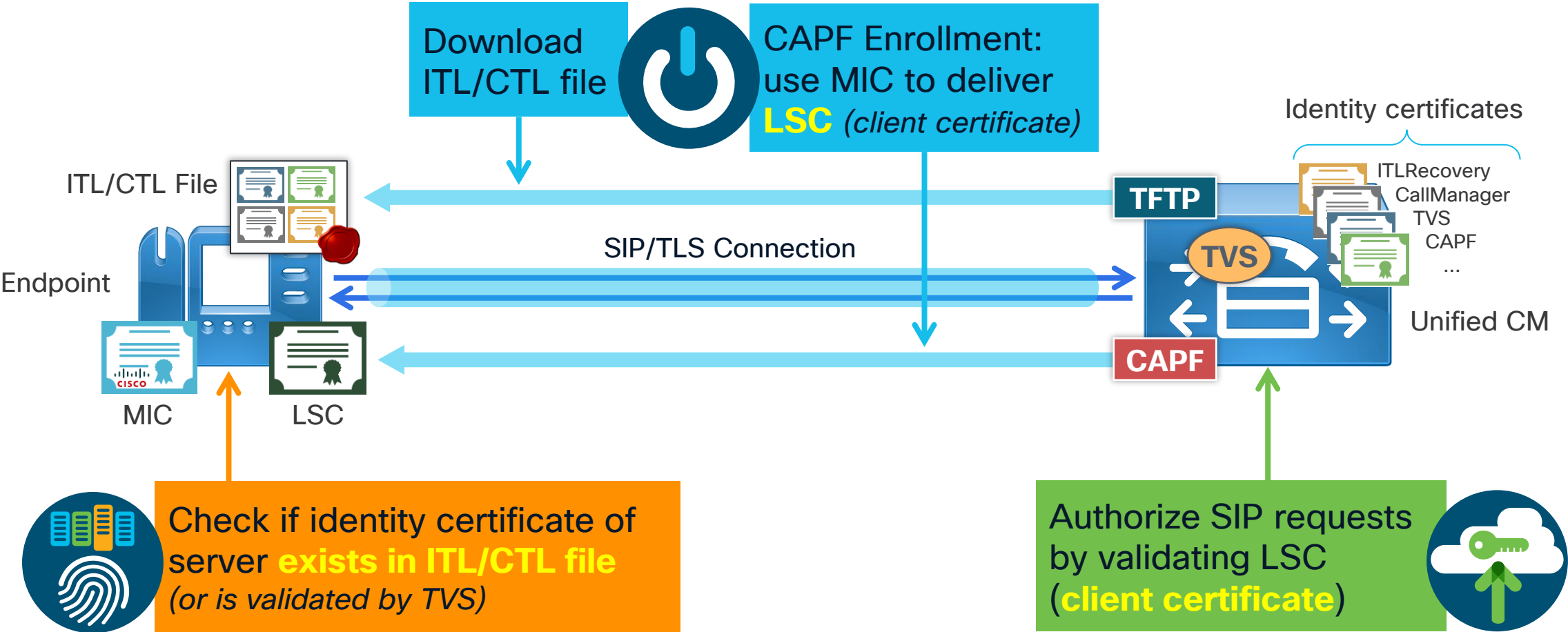
Architecture Overview

Key Areas for UC Security



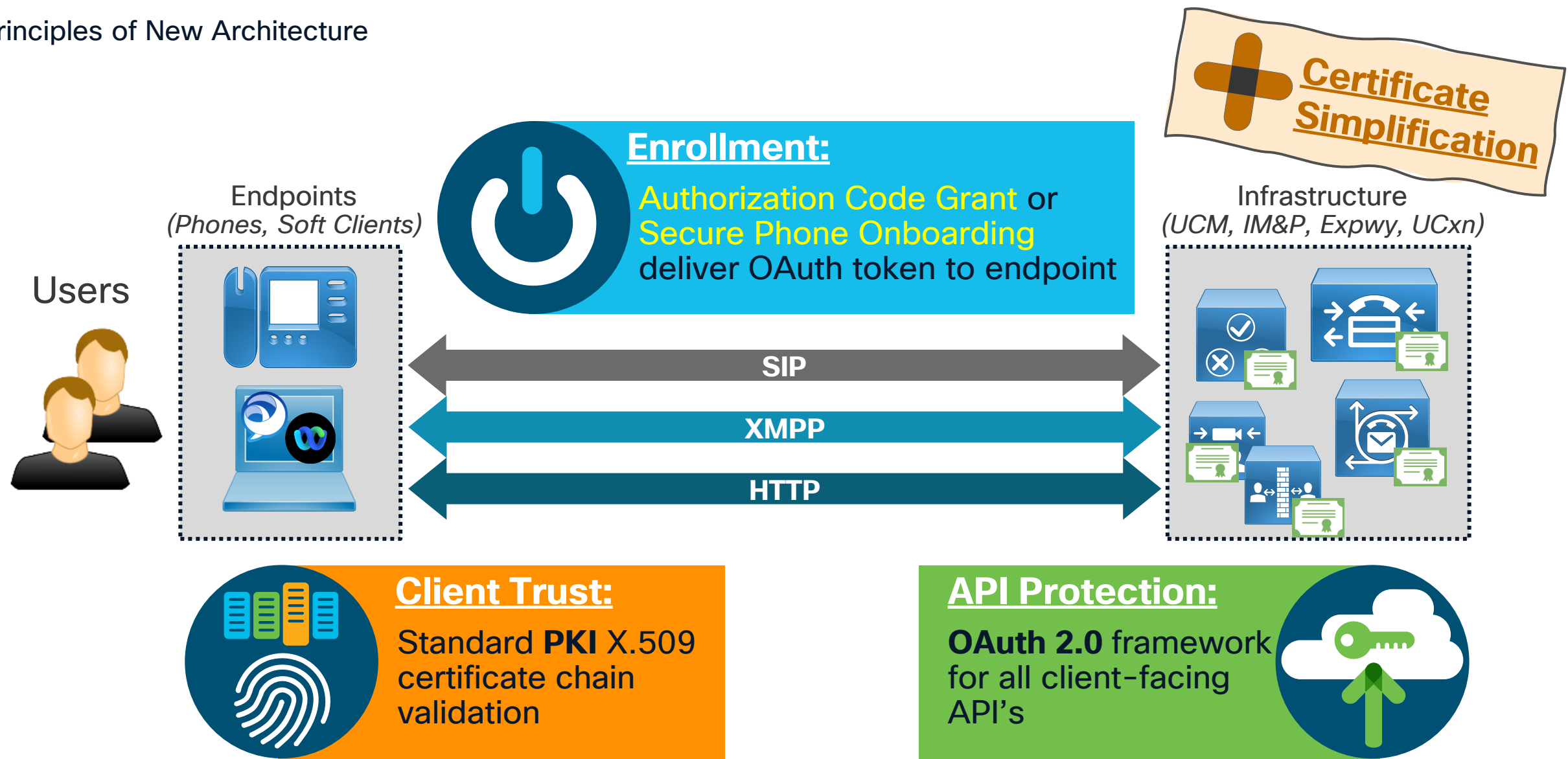
Architecture Overview

Traditional UC Security Model (CAPF)



Architecture Overview

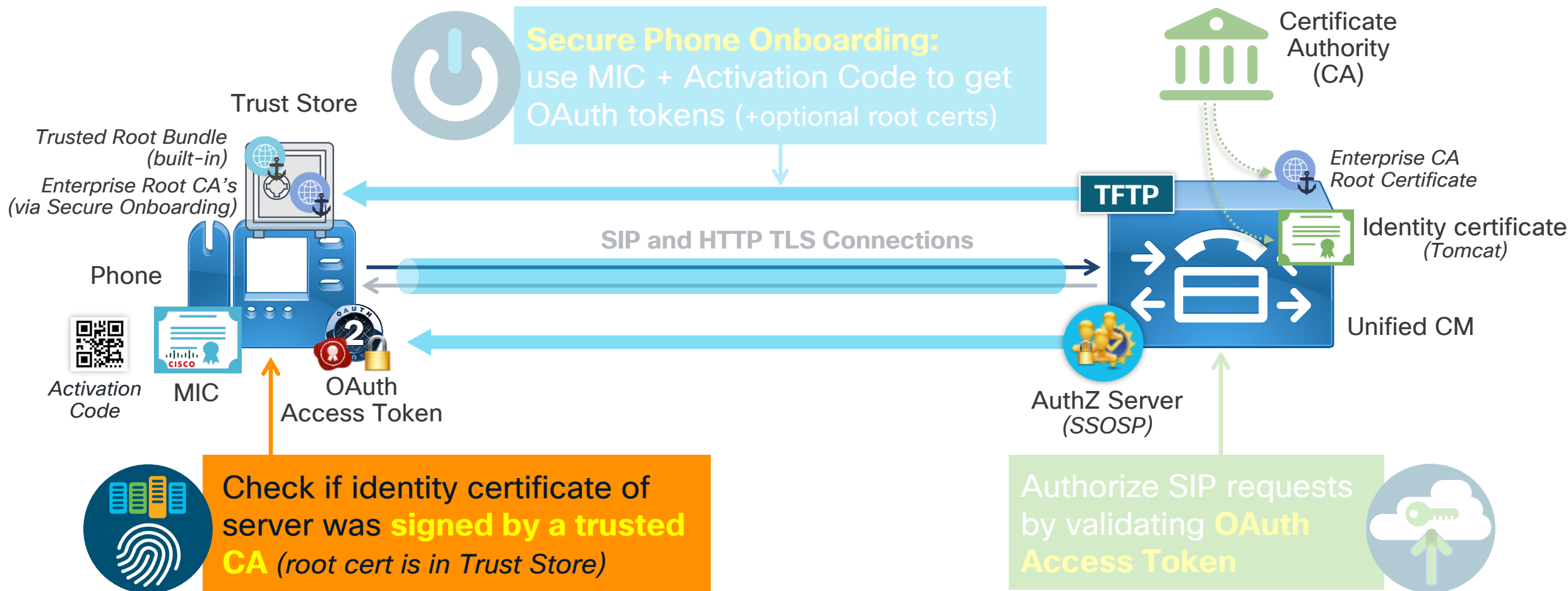
Principles of New Architecture



Client and Device Trust (PKI)

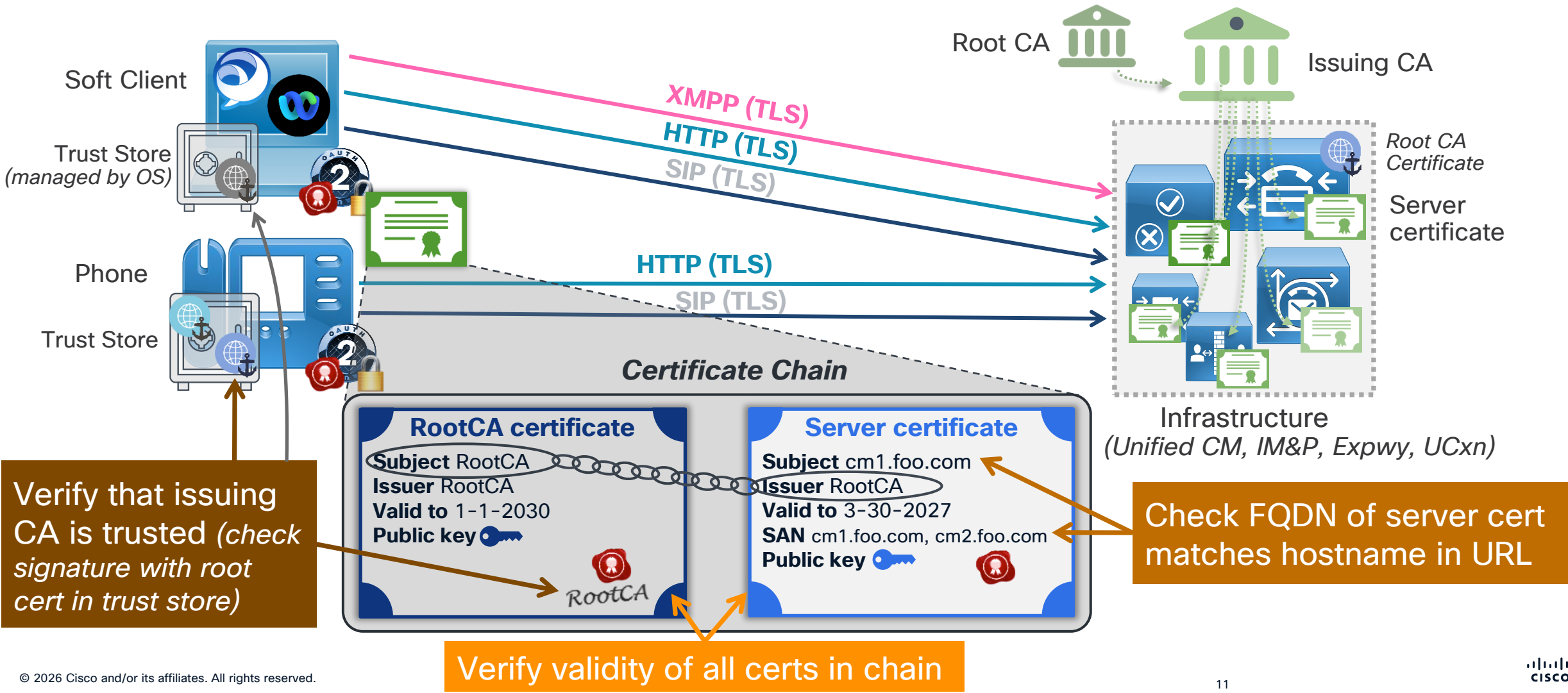
Always-secure Phones with OAuth

Client Trust: PKI



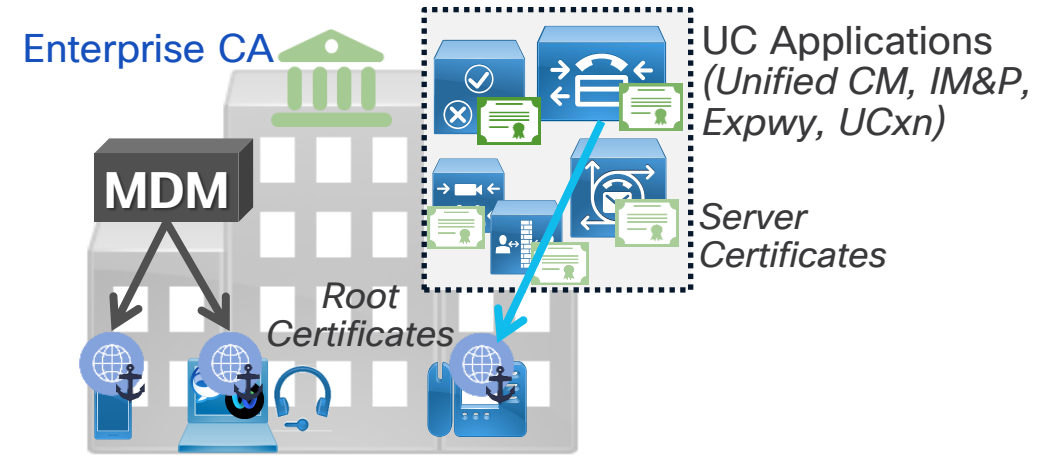
Client Trust

PKI (Certificate Chain Validation)



Client Trust

CA Choice Considerations



Commercial (Public) CA

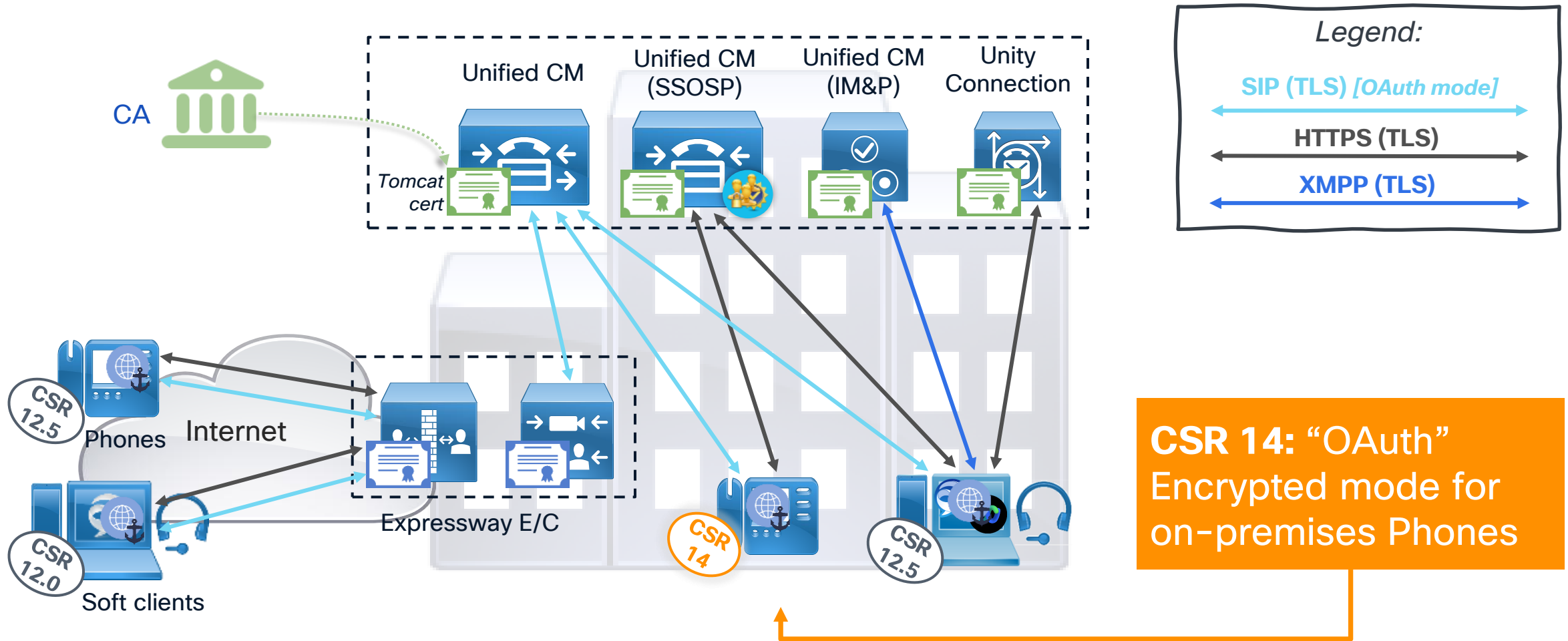
- Generally trusted by default by all devices:
 - **PC's, mobile devices:** check with OS vendor
 - **Cisco phones:** “Cisco Trusted Union Root Bundle”, available at www.cisco.com/security/pki/
- Ongoing certificate cost (per server per year)

Enterprise (Private) CA

- Requires mechanism to distribute root certificate to all Enterprise devices:
 - **PC's, mobile devices:** MDM software, Microsoft AD GPO's, ...
 - **Cisco phones:** Unified CM (Secure Onboarding)
- No certificate cost

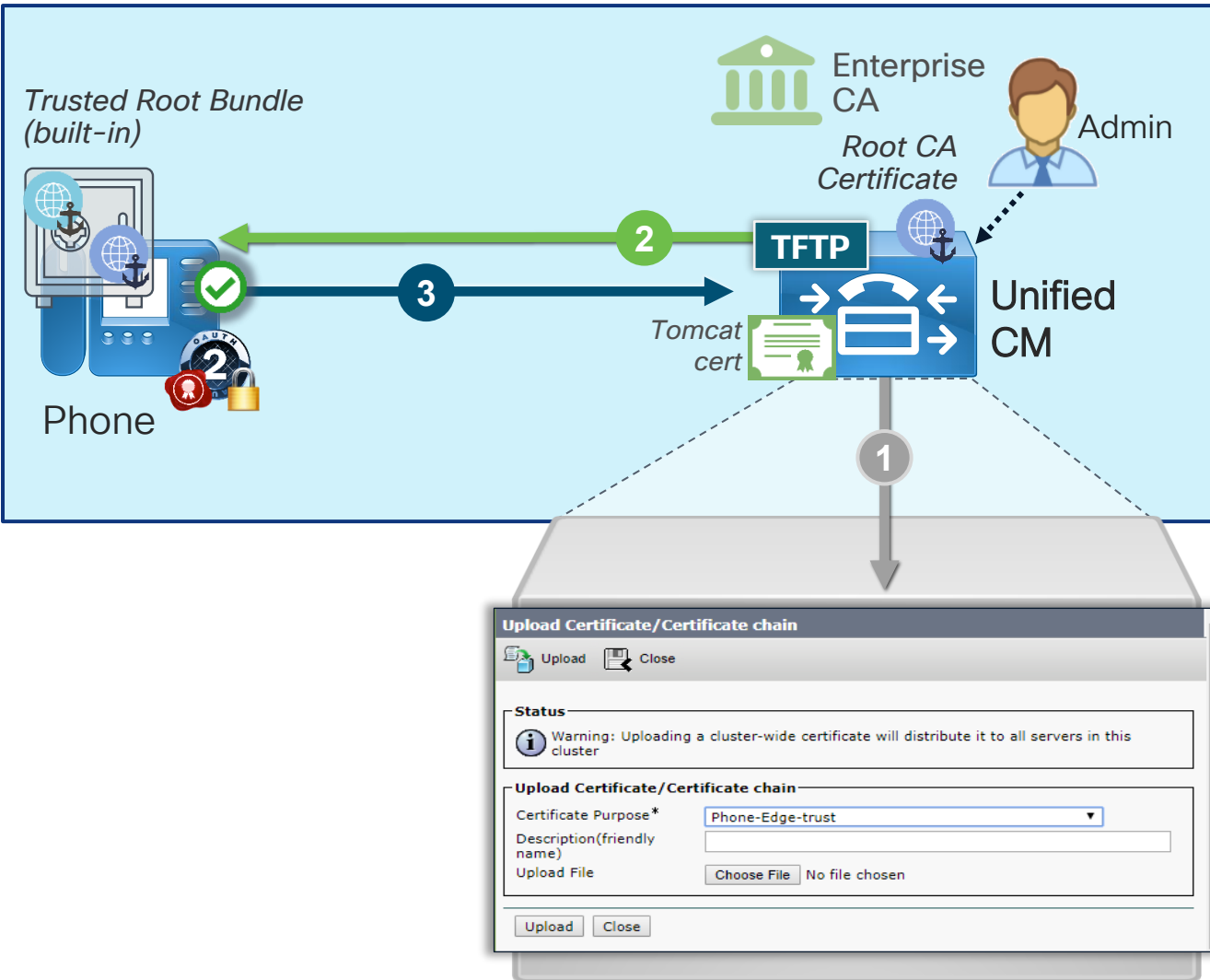
Client Trust

Certificate Chain Validation Support



Client Trust

Certificate Chain Validation with an Enterprise (Private) CA



How to use an Enterprise CA:

- 1 Admin uploads root certificates of Enterprise CAs to Phone-Edge-trust on Unified CM and resets the phones
- 2 If there are certs in Phone-Edge-trust, phone downloads a file with these trust anchors from TFTP and updates its Trust Store (built-in root bundle no longer trusted!)
- 3 In "OAuth" Encrypted mode, phone validates Tomcat certificate chain using the root certs in its Trust Store (applies to SIP and HTTPS/SSOSP connections)

Note: not needed when Tomcat and Expwy certs are signed by a Public CA included in the "Cisco Trusted Union Root Bundle" at www.cisco.com/security/pki/

Certificate Management & Encryption

Certificate Management Simplification

Server Certificate Count Reduction

- ✓ Multi-server (SAN) self-signed certificates
- ✓ Tomcat certificate reuse
- ✓ Remove unnecessary certificates

Simplified Server Certificate Management

- ✓ Reduced overhead on certificate renewal
- ✓ Automate certificate management
- ✓ Server certificate monitoring
- ✓ Long-lived certificates
- ✓ Centralized certificate management

Endpoint Certificate Simplification

- ✓ Automatic endpoint certificate enrollment with private CA
- ✓ Endpoint certificate (LSC) monitoring
- ✓ ITL mismatch report

Simplification with SIP OAuth

- ✓ Simplify endpoint security for these devices:
 - 7800 / 8800 / 9800 series desk phones
 - Cisco Jabber
 - Webex App (on-prem calling)
- ✓ No LSC for encrypted signaling/media = no CAPF enrollment.
- ✓ Mixed-mode not enabled, no CTL file.

Server Certificate Count Reduction

Server Certificate Count Reduction

- ✓ Multi-server (SAN) self-signed certificates
- ✓ Tomcat certificate reuse
- ✓ Remove unnecessary certificates

- **No need to manage a certificate at every node**

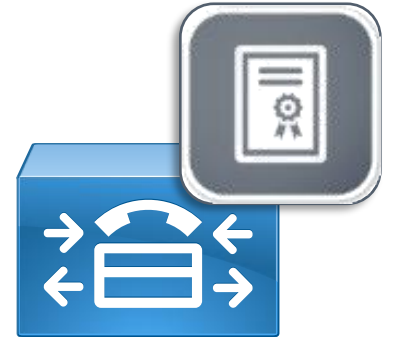
The multi-server (SAN) option for self-signed certificates means no CA-signed certificate required to take advantage of the reduced overhead of managing a single service certificate per cluster. This includes TVS certificate.

- **Fewer service certificates to manage**

Reuse the multi-server (SAN) tomcat certificate for securing CallManager service connections. In this case the tomcat certificate replaces the CallManager certificate leaving one less certificate to manage.

- **Remove unnecessary certificates**

- » Publisher-only CAPF certificate: CAPF certificates removed from subscribers.



Server Certificate Count Reduction

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions
Tomcat	11 1
Tomcat ECDSA	11
CallManager	11 1
CallManager ECDSA	11
TVS	11
CAPF	11
ITL Recovery	1
IPSec	11
TOTAL	78 58

Server Certificate Count Reduction

- **Multi-server (SAN) self-signed certificates** allows nodes in clusters to use the same self-signed certificates.

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions	Unified CM Version 14 and later
Tomcat	11 1	1
Tomcat ECDSA	11	1
CallManager	11 1	1
CallManager ECDSA	11	1
TVS	11	1
CAPF	11	
ITL Recovery	1	
IPSec	11	
TOTAL	78 58	

Server Certificate Count Reduction

- **Multi-server (SAN) self-signed certificates** allows nodes in clusters to use the same self-signed certificates.
- **CAPF certificate only exists on the Publisher node** reducing the number of certificates to manage.

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions	Unified CM Version 14 and later
Tomcat	11 1	1
Tomcat ECDSA	11	1
CallManager	11 1	1
CallManager ECDSA	11	1
TVS	11	1
CAPF	11	1
ITL Recovery	1	1
IPSec	11	
TOTAL	78 58	

Server Certificate Count Reduction

- **Multi-server (SAN) self-signed certificates** allows nodes in clusters to use the same self-signed certificates.
- **CAPF certificate only exists on the Publisher node** reducing the number of certificates to manage.
- **Tomcat certificate can be reused as the CallManager certificate** further reducing the number of certificates to manage.

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions	Unified CM Version 14 and later
Tomcat	11 1	1
Tomcat ECDSA	11	1
CallManager	11 1	0
CallManager ECDSA	11	0
TVS	11	1
CAPF	11	1
ITL Recovery	1	1
IPSec	11	
TOTAL	78 58	

Server Certificate Count Reduction

- **Multi-server (SAN) self-signed certificates** allows nodes in clusters to use the same self-signed certificates.
- **CAPF certificate only exists on the Publisher node** reducing the number of certificates to manage.
- **Tomcat certificate can be reused as the CallManager certificate** further reducing the number of certificates to manage.

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions	Unified CM Version 14 and later
Tomcat	11 1	1
Tomcat ECDSA	11	1
CallManager	11 1	0
CallManager ECDSA	11	0
TVS	11	1
CAPF	11	1
ITL Recovery	1	1
IPSec	11	11
TOTAL	78 58	16

Server Certificate Count Reduction

FUTURE

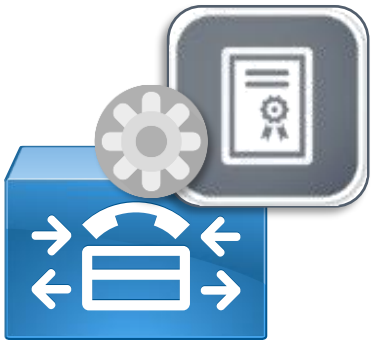
- **Multi-server (SAN) self-signed certificates** allows nodes in clusters to use the same self-signed certificates.
- **CAPF certificate only exists on the Publisher node** reducing the number of certificates to manage.
- **Tomcat certificate can be reused as the CallManager certificate** further reducing the number of certificates to manage.
- ***Future: IPSec certificate to be eliminated** when IPSec not in use.

* Plan of record. **SUBJECT TO CHANGE**

EXAMPLE: Unified CM 11-node cluster (Pub, TFTP x2, Sub pairs x4)

Certificate	Unified CM Pre-14 Versions	Unified CM Version ?*
Tomcat	11 1	1
Tomcat ECDSA	11	1
CallManager	11 1	0
CallManager ECDSA	11	0
TVS	11	1
CAPF	11	1
ITL Recovery	1	1
IPSec	11	0*
TOTAL	78 58	5

Simplified Server Certificate Management



Simplified Server Certificate Management

- ✓ Reduced overhead on certificate renewal
- ✓ Automate certificate management
- ✓ Server certificate monitoring
- ✓ Long-lived certificates
- ✓ Centralized certificate management

- **Fewer manual service restarts required for certificate renewals**
 - » CAPF and TVS services are restarted automatically in the background when these certificates are renewed.
- **Endpoint reset control post certificate renewals**

Enterprise parameter* determines automatic v. manual restart on renewal of CAPF, TVS, and CallMangaer certificates.
- **Reduce certificate management overhead**

Use APIs to automate certificate renewal.
- **Monitor server certificate validity dates**

Don't get surprised by expired server certificates. Receive advanced notification by email before they expire.
- **Renew core trust certificates less frequently**

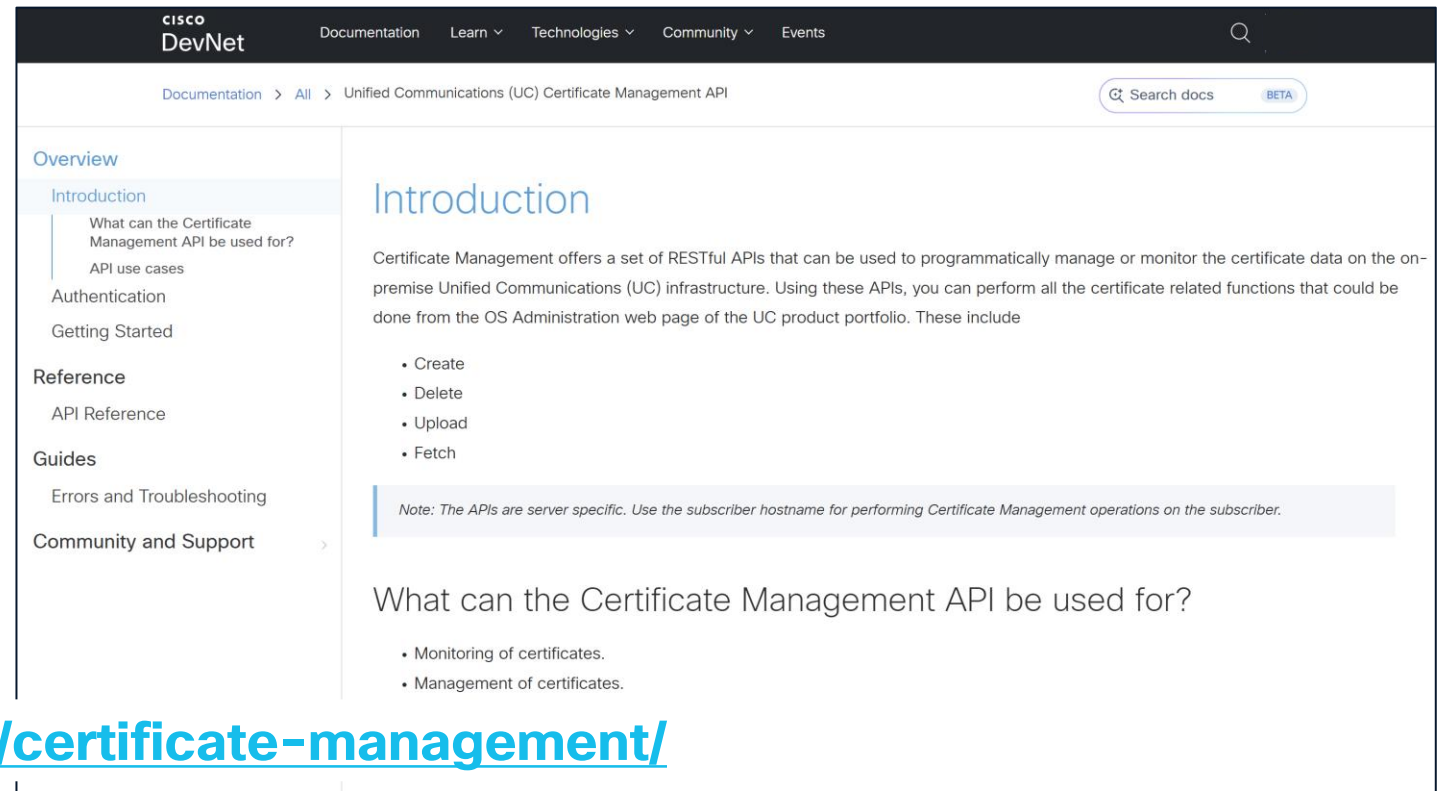
Cerificates with long validity periods mean fewer renewals and easier upgrades: ITL Recovery (20 years).
- **Cloud Connected UC (CCUC)**

* 'Phone Interaction on Certificate Update'

Server Certificate Management APIs

- Certificate management REST APIs: Enable administrators to programmatically manage collaboration application certificates (Unified CM, IM&P, Unity Connection, Emergency Responder)
- API Endpoints: Certificate signing request (CSR), identity, and trust certificate operations – get/view, generate, delete, upload, reuse.
- Review the documentation for certificate management API endpoints

<https://developer.cisco.com/docs/certificate-management/>

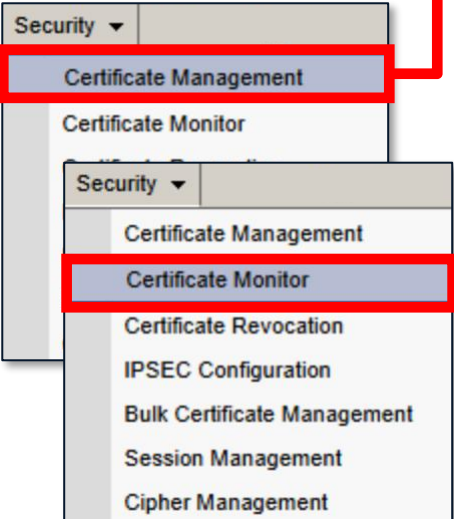


Server Certificate Expiration Monitoring and Notification

Monitor server certificates expiration (Certificate Management)

Certificate ^	Common Name/Common Name_SerialNumber	Usage	Type	Key Type	Distribution	Issued By	Expiration	Description
CallManager	cucm1.dcloud.cisco.com_73239c806215a003d0f9ef69b3058791	Identity Self-signed	RSA		cucm1.dcloud.cisco.com	cucm1.dcloud.cisco.com	10/12/2030	Self-signed certificate gene
CallManager-ECDSA	cucm1-EC.dcloud.cisco.com_4f8528f0de974f4190439b1e7dd276ef	Identity Self-signed	EC		cucm1.dcloud.cisco.com	cucm1-EC.dcloud.cisco.com	10/13/2030	Self-signed certificate gene
CAPF	CAPF-a41cf770	Identity Self-signed	RSA		cucm1.dcloud.cisco.com	CAPF-a41cf770	10/13/2030	Self-signed certificate gene
ipsec	cucm1.dcloud.cisco.com_660000000456eb312eed67fddc000000000004	Identity CA-signed	RSA		cucm1.dcloud.cisco.com	dcloud-AD1-CA-1	10/03/2037	Certificate Signed by DCLO
ITLRecovery	ITLRECOVERY_cucm1.dcloud.cisco.com_4cb9e7529fd1ef1ac2dbff0286021dd5	Identity Self-signed	RSA		cucm1.dcloud.cisco.com	ITLRECOVERY_cucm1.dcloud.cisco.com	06/01/2039	Self-signed certificate gene
tomcat	cucm1.dcloud.cisco.com_660000000394a9c6d9423ddd960000000000003	Identity CA-signed	RSA		cucm1.dcloud.cisco.com	dcloud-AD1-CA-1	10/03/2037	Certificate Signed by DCLO
tomcat-ECDSA	cucm1-EC.dcloud.cisco.com_7845bff8385036a94fc98e847483ebb3	Identity Self-signed	EC		cucm1.dcloud.cisco.com	cucm1-EC.dcloud.cisco.com	08/29/2029	Self-signed certificate gene
TVS	cucm1.dcloud.cisco.com_43c87652b20e3a66bdfbf55d60545118	Identity Self-signed	RSA		cucm1.dcloud.cisco.com	cucm1.dcloud.cisco.com	10/13/2030	Self-signed certificate gene

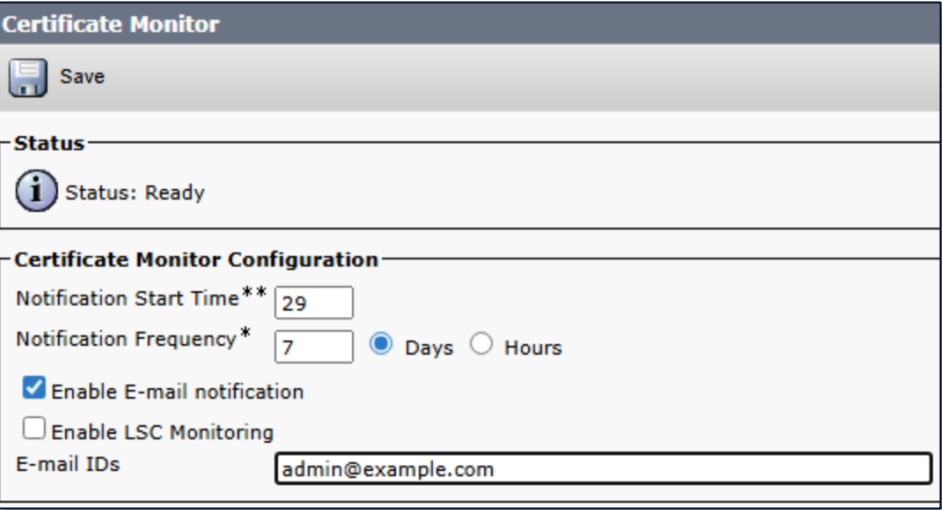
(OS Admin)



Security ▾

- Certificate Management
- Certificate Monitor
- Certificate Revocation
- IPSEC Configuration
- Bulk Certificate Management
- Session Management
- Cipher Management

Receive email notification prior to server certificate expiration (Certificate Monitor)



Certificate Monitor

Save

Status

Status: Ready

Certificate Monitor Configuration

Notification Start Time** 29

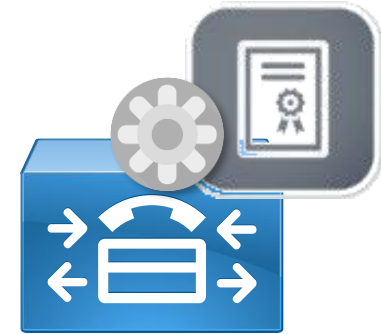
Notification Frequency* 7 ☒ Days ☐ Hours

☒ Enable E-mail notification

☐ Enable LSC Monitoring

E-mail IDs admin@example.com

Long-lived Server Certificates and Upgrades



- While convenient, using certificate with long validity periods is NOT a security best practice. Long-lived certificates pose a security risk due to increased exposure time (the longer a certificate exists the higher the risk for compromise).
- In cases where the [certificate is not public and is not exposed externally](#), a long lived certificate **might** still be used – for example, the **Unified CM ITL Recovery** certificate.
- The 20-year ITL Recovery certificate provides a trust anchor for phones across cluster service certificate renewals and system upgrades ensuring that phones maintain trust.
- The [certificate is not exposed beyond the scope of Unified CM and its registered devices](#) nor is it freely served on a port call (no answer)

Centralized Certificate Management: Cloud Connected UC

Webex Cloud Connected UC (CCUC) Certificate Management enables a single place for administrators to **view and manage certificates** across multiple clusters and multiple UC applications

- Ability to distribute certificates across the UC application trust stores
- Quick dashboard to view expired or about to expire certificates and take actions directly from centralized UI
- Insights for certificate consolidation and out of compliance

The screenshot shows the Webex Control Hub interface for CUCM-Core - cucm-a-pub. com. The sidebar on the left contains navigation options: Workspaces, Devices, Apps, Account, Security & Privacy, Organization Settings, and a SERVICES section with Updates & Migrations, Messaging, Meeting, Calling, PSTN & Routing, Customer Assist, Vidcast, Events, and Connected UC (highlighted with a red box). The main content area shows a dashboard for Identity Certificate, Trust Store, and Jobs. It includes summary cards for Identity Certificates (21 total: 16 Valid, 1 Expires Soon, 5 Expired), Trust Certificates (44 total: 35 Valid, 1 Expires Soon, 9 Expired), and Recent Jobs (Current Month: 0 Total, 0 Pending, 0 Complete). Below these is a table of 25 certificates with columns: Certificate, Server Name, Common Name, Type, Status, and Expiration. The table lists various certificates like tomcat-ECDSA, cup-ECDSA, cup, cup-xmpp-s2s, and TVS, along with their server names and expiration dates.

**** Cloud feature – requires connectivity to Webex ****

Endpoint Certificate Simplification

- **Automatically install private CA-signed LSCs**
With Online CAPF mode endpoint locally significant certificates are automatically signed using your private CA.
- **Monitor endpoint LSC validity dates**
Don't get surprised by expired endpoint certificates. Receive advanced notification by email prior to expiration.
- **Discover endpoints with broken trust**
Get your devices back online faster. The ILT mismatch report identifies devices that are unable to register due to loss of trust (generally as a result of certificate renewal).

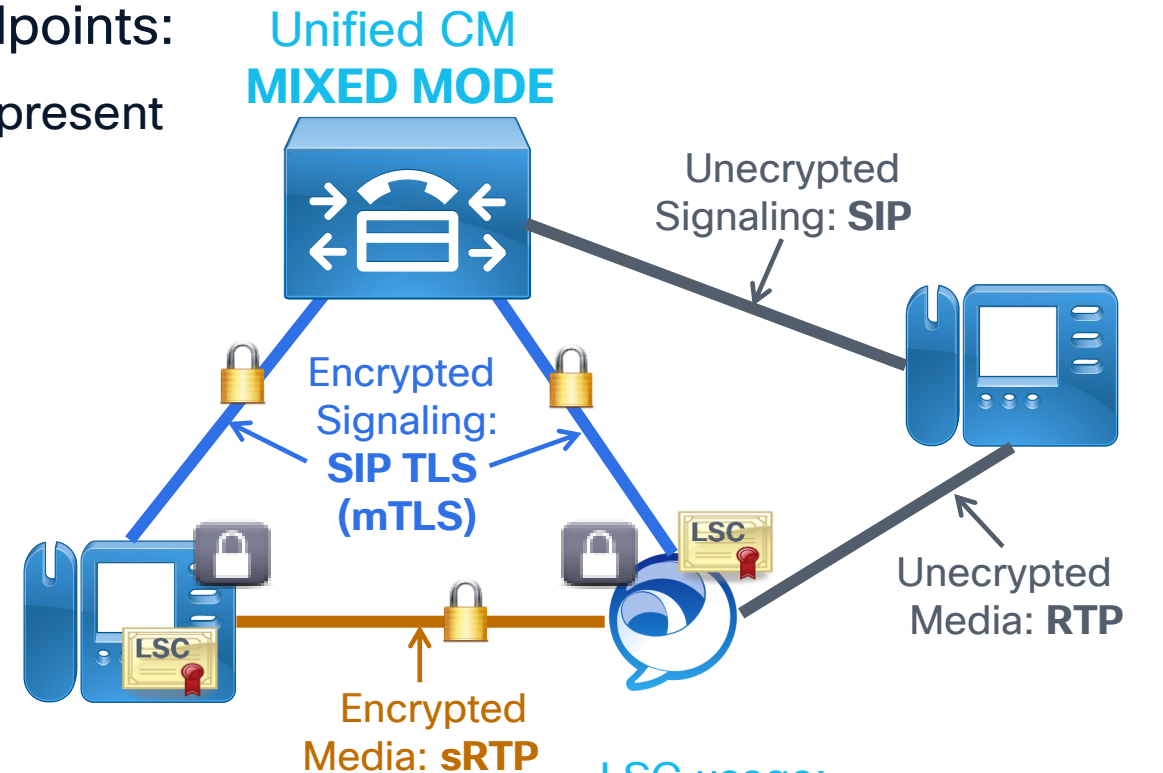
Endpoint Certificate Simplification

- ✓ Automatic endpoint certificate enrollment with private CA
- ✓ Endpoint certificate (LSC) monitoring
- ✓ ITL mismatch report



Unified CM and Endpoints: Encrypted Media & Signaling

- Encrypted signaling between Unified CM and endpoints:
 - » SIP TLS: Encrypted SIP requires endpoint/client to present valid certificate to connect (mTLS)
 - » CAPF generated locally significant certificate (LSC) recommended.
- Encrypted media between endpoints:
 - » Requires secure signaling (SIP TLS)
 - » Secure RTP (sRTP): Secure media encryption via SIP client derived encryption key.
- When enabled for encrypted media and signaling
 - » Endpoints in encrypted calls will display a lock icon.
 - » Interoperability with non-secure endpoints. Calls to / from non-secure endpoints fall back to unencrypted media (default)*



LSC usage:

- TLS
- CAPF enrollment, 802.1x auth, phone VPN

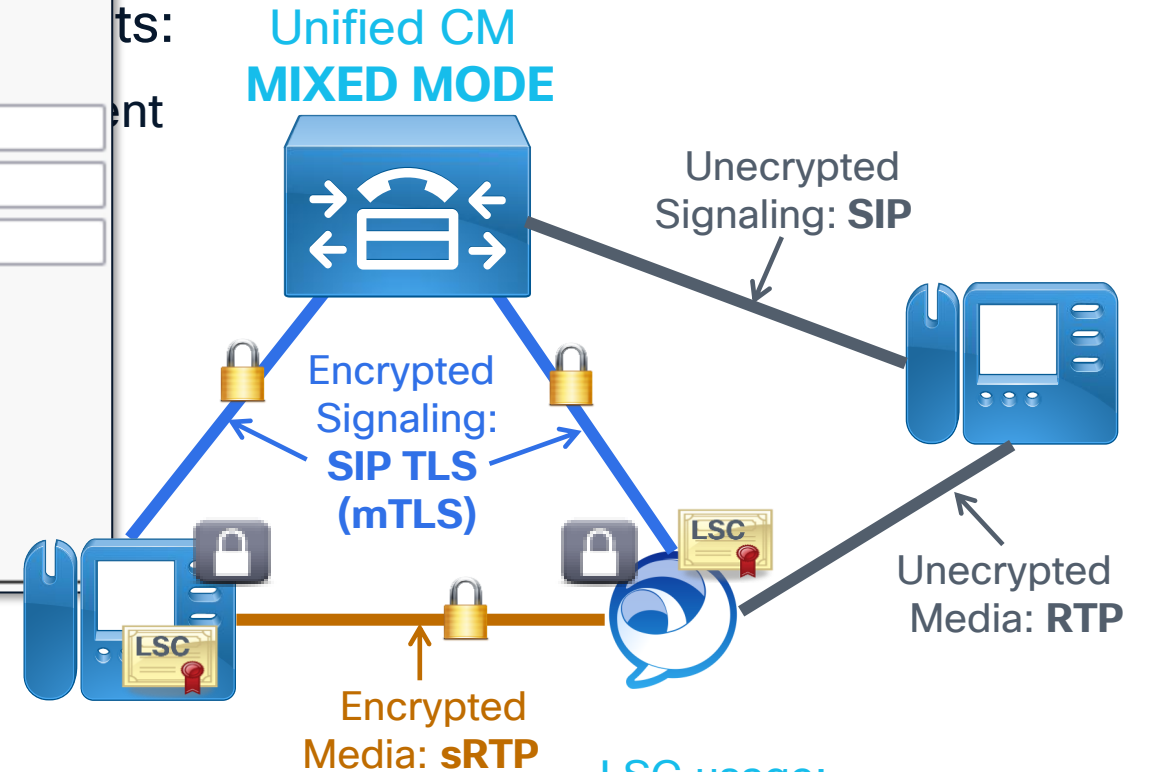
* 'Block Unencrypted Calls' service Parameter is 'False' by default

Unified CM and Endpoints: Encrypted Media & Signaling

- En...ts:
» ent
- En...ent
- » Secure RTP (sRTP): Secure media encryption via SIP client derived encryption key.

Phone Security Profile Information

Product Type:	Cisco Device
Device Protocol:	SIP
Name*	Cisco Device - SIP Secure Profile
Description	Cisco Device - SIP Secure Encrypted Profile
Nonce Validity Time*	600
Device Security Mode	Encrypted
Transport Type*	TLS
☐ Enable Digest Authentication	
☐ TFTP Encrypted Config	
☐ Enable OAuth Authentication	



LSC usage:

- TLS
 - CAPF enrollment, 802.1x auth, phone VPN
- When enabled for encrypted media and signaling
 - » Endpoints in encrypted calls will display a lock icon.
 - » Interoperability with non-secure endpoints. Calls to / from non-secure endpoints fall back to unencrypted media (default)*

* 'Block Unencrypted Calls' service Parameter is 'False' by default

Unified CM and Endpoints: Encrypted Media & Signaling

- Encrypted signaling between Unified CM and endpoints:

- » SIP TLS: Encrypted SIP requires endpoint/client to present valid certificate to connect
- » CAPF generated local certificates are recommended.

- Encrypted media between

- » Requires secure signaling
- » Secure RTP (sRTP): Secure media via SIP client derived encryption key.

- When enabled for encrypted media and signaling

- » Endpoints in encrypted calls will display a lock icon.
- » Interoperability with non-secure endpoints. Calls to / from non-secure endpoints fall back to unencrypted media (default)*

Unified CM
MIXED MODE

Phone Security Profile Information

Product Type: Cisco Unified Client Services Framework

Device Protocol: SIP

Name * UCF - Standard SIP Secure Profile

Description Unified Client Services Framework - SIP Secure Encrypted Profile

Device Security Mode Encrypted

Transport Type * TLS

☐ TFTP Encrypted Config

☐ Enable OAuth Authentication

Unencrypted
Signaling: **SIP**



Unencrypted
Media: **RTP**

Encrypted
Media: **sRTP**

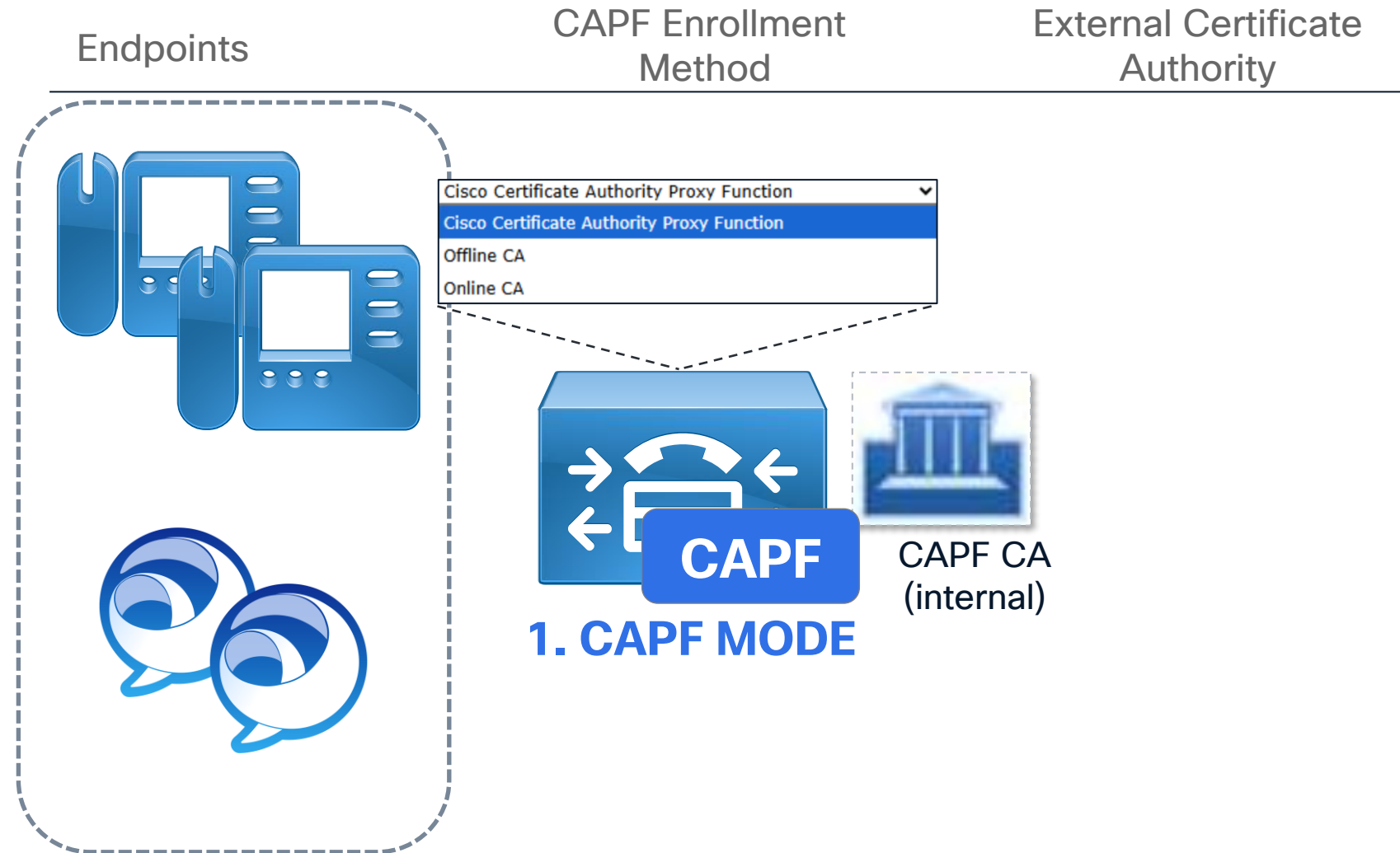
LSC usage:

- **TLS**
- CAPF enrollment, 802.1x auth, phone VPN

* 'Block Unencrypted Calls' service Parameter is 'False' by default

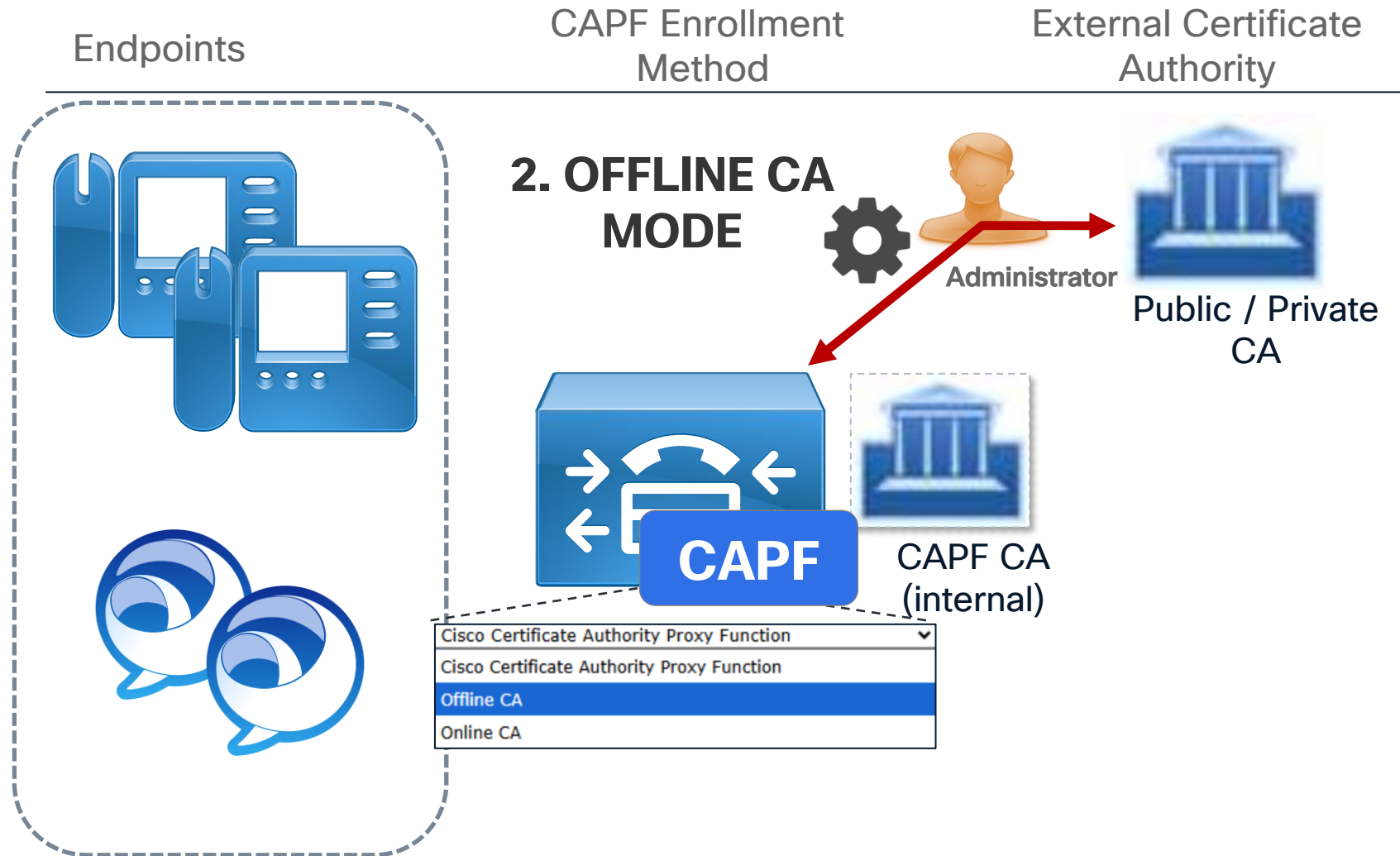
Endpoint LSCs – CAPF Enrollment Methods

- Encrypted Media Prerequisite: Certificate Authority Proxy Function (CAPF) enrollment required to install device-specific certificates (LSCs) on collaboration endpoints.
(Relying on MIC not recommended)
- Multiple CAPF enrollment methods are available to accommodate an each organization's requirements.
- Online CA Mode for automatic enterprise CA endpoint certificate enrollment with CAPF.



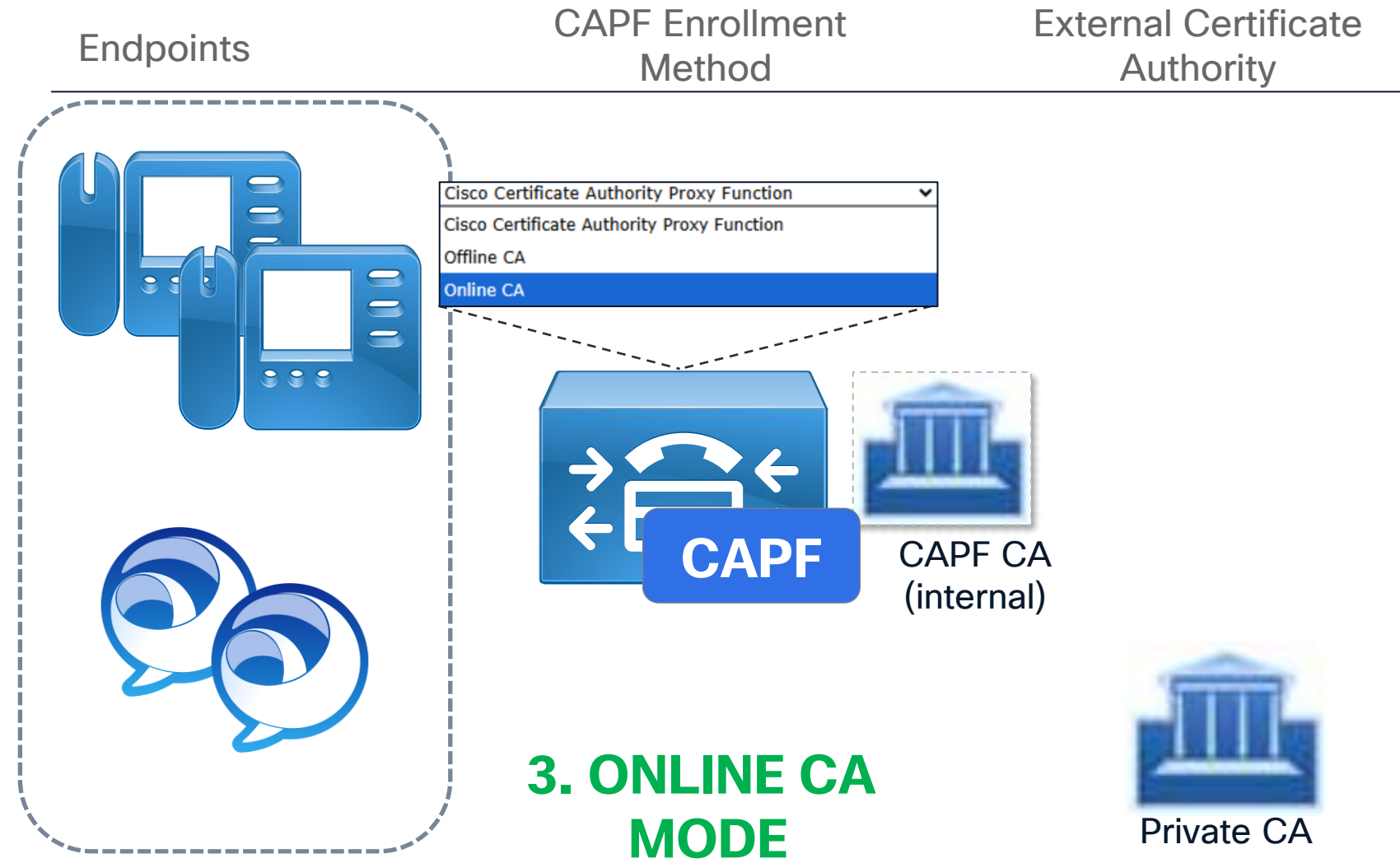
Endpoint LSCs – CAPF Enrollment Methods

- Encrypted Media Prerequisite: Certificate Authority Proxy Function (CAPF) enrollment required to install device-specific certificates (LSCs) on collaboration endpoints.
(Relying on MIC not recommended)
- Multiple CAPF enrollment methods are available to accommodate each organization's requirements.
- Online CA Mode for automatic enterprise CA endpoint certificate enrollment with CAPF.



Endpoint LSCs – CAPF Enrollment Methods

- Encrypted Media Prerequisite: Certificate Authority Proxy Function (CAPF) enrollment required to install device-specific certificates (LSCs) on collaboration endpoints.
(Relying on MIC not recommended)
- Multiple CAPF enrollment methods are available to accommodate an each organization's requirements.
- Online CA Mode for automatic enterprise CA endpoint certificate enrollment with CAPF.

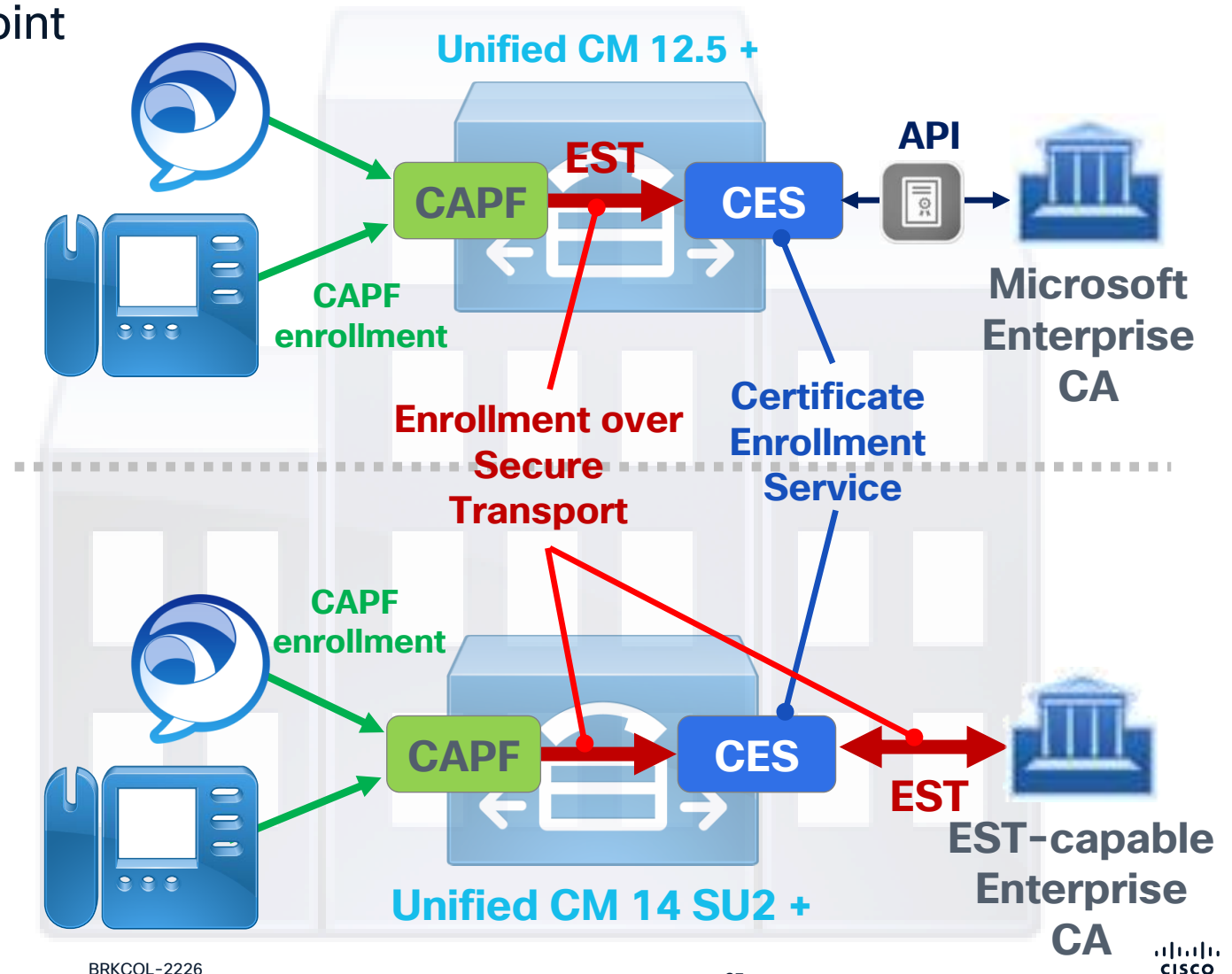


Online CA Mode: Automatic Enterprise CA Enrollment

Online CA Mode enables automatic endpoint certificate enrollment with an Enterprise CA. Available starting with 12.5.

Microsoft CA: Certificate Enrollment Service (CES) on Unified CM publisher communicates with Microsoft CA for certificate operations via **Microsoft API**.

EST-capable CA: CES on Unified CM publisher communicates with Enterprise CA for certificate operations using standards-based **Enrollment over Secure Transport**. Supported starting with 14 SU2.



Online CA Mode: Automatic Enterprise CA Enrollment

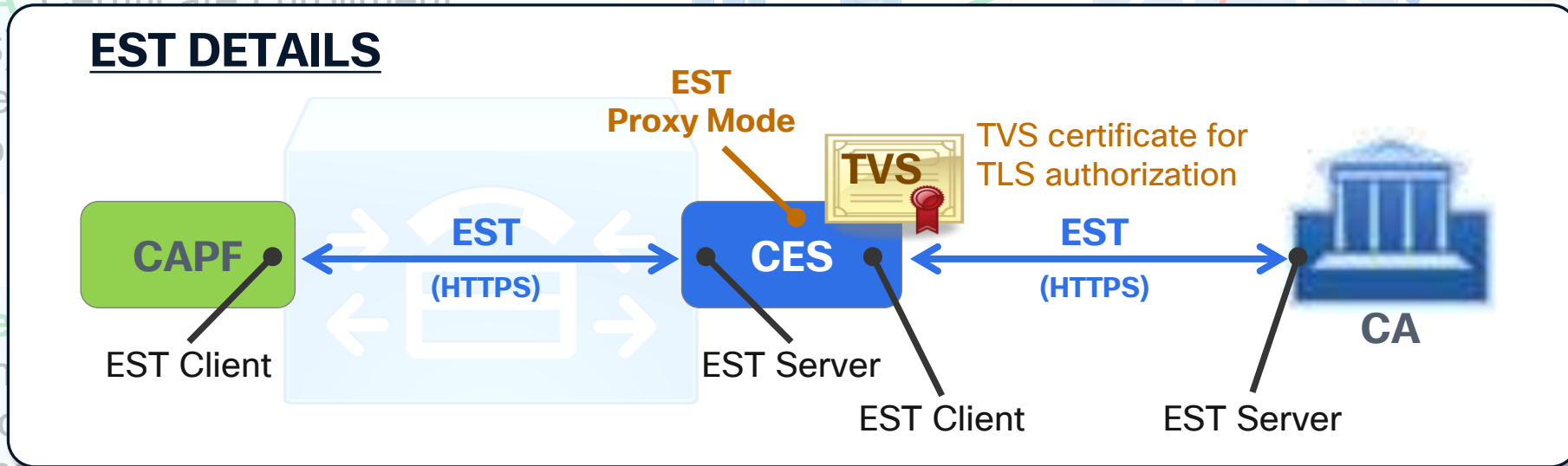
Online CA Mode enables automatic endpoint certificate enrollment with an Enterprise CA. Available starting with 12.5.

Microsoft CA: Certificate Enrollment Service (CES)

communicate certificate operations

EST-capable publisher connects to Enterprise CA for certificate enrollment

standards-based **Enrollment over Secure Transport**. Supported starting with 14 SU2.



Endpoint LSC Expiration Monitoring and Notification

Monitor endpoint LSC certificate expiration (Unified CM Administration)

☐	Device Name(Line) ▲	Description	Extension	Owner User ID	LSC Status	LSC Expires	LSC Issued By	LSC Issuer Expires By	CAPF Auth String	Device Protocol	Status	Last Registered	Unified CM	IPv4 Address	C
☐	8845 SEP5006AB806CF8	8845 Desk phone (kmelby)	6026	kmelby	Upgrade Success	11/21/2026	CAPF-a41cf	05/07/2029		SIP	RegisteredNow		cucm1.dcloud.cisco.com	10.65.177.216	
☐	9871 SEP845A3EC2D262	9871 Desk phone (cholland)	6018	cholland	Upgrade Success	11/21/2026	CAPF-a41cf	05/07/2029		SIP	RegisteredNow		cucm1.dcloud.cisco.com	10.65.177.215	
☐	9871 SEP845A3EC24D23	9871 Desk phone (wwhitman)	1083	wwhitman	Upgrade Success	11/21/2026	CAPF-a41cf	05/07/2029		SIP	RegisteredNow		cucm1.dcloud.cisco.com	10.65.177.217	

Receive email notification prior to LSC expiration (OS Administration)

Security ▾

Certificate Management

Certificate Monitor

Certificate Revocation

IPSEC Configuration

Bulk Certificate Management

Session Management

Cipher Management

Certificate Monitor

Save

Status

Status: Ready

Certificate Monitor Configuration

Notification Start Time**

29

Notification Frequency*

7

Days

Hours

☒ Enable E-mail notification

☒ Enable LSC Monitoring

E-mail IDs

admin@example.com

Phone Initial Trust List (ITL) Mismatch and Reporting

- ITL mismatch: When the ITL file on a phone becomes outdated and does not match the current ITL file on the Unified CM server.
- For example, an ITL mismatch could happen when the Unified CM admin renews core certificates (TVS, ITL Recovery) while a phone is offline.
- If the ITL is mismatched, the phone may register, but it will not operate correctly due to lost trust (e.g., phone cannot verify signature of downloaded files (CTL, config file, etc.) – no config updates)

Easily identify phones that have mismatched ITL: Phone search where **'ITL File Status' = 'Mismatch'**

Phone (1 - 3 of 3)

Find Phone where

ITL File Status

Mismatch

Find

Clear Filter

+

-

Select item or enter search text

		Device Name(Line) ^	Description	Device Pool	ITL Hash	ITLhash Status	Last ITLHash Reported	Device Protocol	Status
☐	 8845	SEP	8845 (kmelby)	dCloud DP	703f921ac8d7049cb962601ed5e78523fca0af67	Mismatched	Jan 26, 2026 3:10:29 PM	SIP	Registered
☐	 9871	SEP	9871 (wwhitman)	dCloud DP	703f921ac8d7049cb962601ed5e78523fca0af67	Mismatched	Jan 26, 2026 3:13:30 PM	SIP	Registered
☐	 9871	SEP	9871 (cholland)	dCloud DP	703f921ac8d7049cb962601ed5e78523fca0af67	Mismatched	Jan 26, 2026 3:11:28 PM	SIP	Registered

This search returns a list of devices that have outdated ITL files.

Devices are registered, but services will not operate normally

Public CA Certificate Validity Period

COMING
SOON

WHAT: Reduced Public CA issued/signed certificate lifetime

WHY: To reduce risk of compromised certificates the CA/Browser Forum voted to amend TLS requirements to shorten the length of certificate validity. As a result, all Public CAs will begin reducing the maximum certificate lifetime/validity length of issued certificates.

WHEN:

- Beginning March 15, 2026 **maximum validity length** for an issued certificate will be reduced to **200 days**.
- On March 15, 2027 **maximum validity length** for issued certificates will be further reduced to **100 days**.
- 2 years later on March 15, 2029 **maximum validity length** for issued certificates will be reduced to **47 days**.

IMPACT: Any public CA signed certificates in a Unified CM deployment **must be updated more frequently.**

**** No impact to private CA signed/issued (or self-signed) certificates.****

WHAT CAN YOU DO TO REDUCE IMPACT:

1. Consider using certificates that have longer validity lengths – **use private CA signed Unified CM certificates or revert to multi-SAN self-signed certificates.**
2. If public CA signed certificates are required – leverage **server certificate management APIs** to help automate certificate renewal operations. And use **certificate monitoring to enable email notification** prior to expiration.

Public CA Client Auth EKU Sunsetting

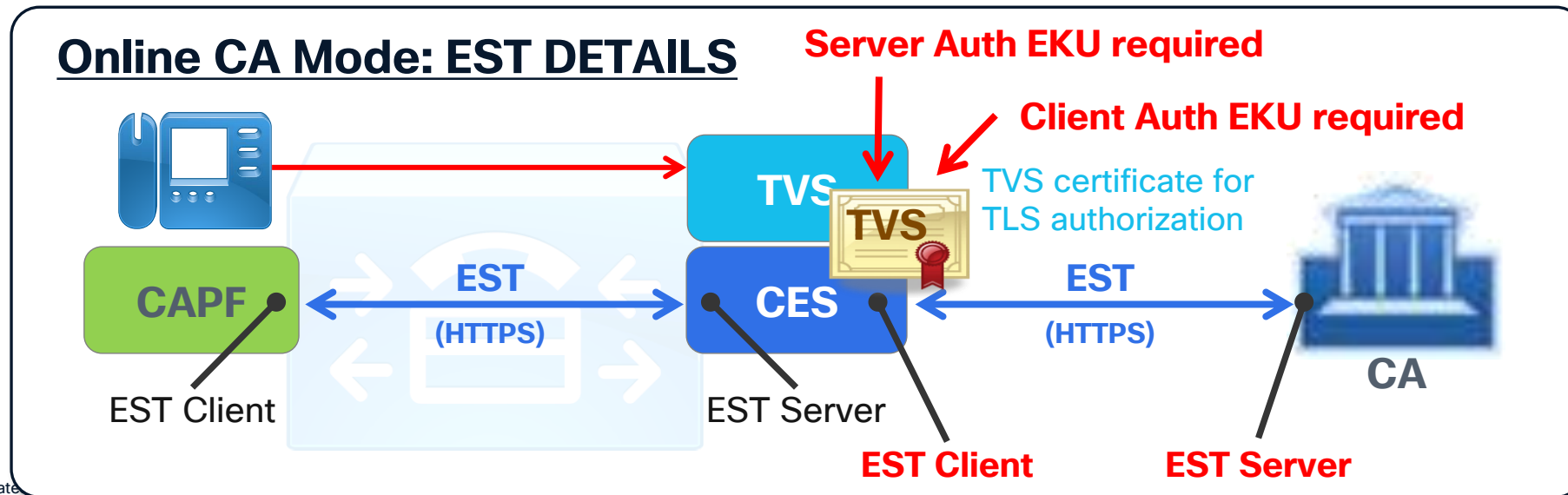
COMING
SOON

WHAT: Removal of Client Authentication EKU (purpose) from Public CA issued/signed certificates

WHY: To improve security posture based on principle of least privilege the Chrome Root Policy (v1.6)* was modified to disallow mixed-use TLS root certificates and allow only **Server Auth EKU** on public TLS certificates. As a result, all Public CAs root and intermediate certificates must be dedicated to TLS Server Auth purpose or they will no longer be trusted. Further Public CAs will stop issuing dual-purpose certificates.

WHEN:

Date of enforcement June 15, 2026 (phased cut off of certs issued with **Client Auth EKU** as this deadline approaches).



Public CA Client Auth ECU Sunsetting

COMING
SOON

WHAT: Removal of Client Authentication ECU (purpose) from Public CA issued/signed certificates

WHY: To improve security posture based on principle of least privilege the Chrome Root Policy (v1.6)* was modified to disallow mixed-use TLS root certificates and allow only **Server Auth ECU** on public TLS certificates. As a result, all Public CAs root and intermediate certificates must be dedicated to TLS Server Auth purpose or they will no longer be trusted. Further Public CAs will stop issuing dual-purpose certificates.

WHEN:

Date of enforcement June 15, 2026 (phased cut off of certs issued with **Client Auth ECU** as this deadline approaches).

IMPACT: Any public CA signed certificates in a Unified CM deployment must be updated to remove the Client Auth ECU. Further, dual service certificates will be required (1 for the client interface and 1 for the server interface).

**** No impact to private CA signed/issued (or self-signed) certificates.****

Public CA Client Auth EKU Sunsetting – Mitigation

COMING
SOON

WORKAROUND / MITIGATION:

1. If using public CA issued certificates, consider replacing with certificates containing dual EKUs. This means **private CA issued** certificates or revert to **self-signed** certificates.

Pro: Maintain dual EKU / Con: Trust – private CA/self-signed cert

OR

2. Switch to certificates issued by public root CA **that continues to issue certificate with combined EKU** (from an alternative root) – e.g., DigiCert, IdenTrust.

Pro: Maintain dual EKU / Con: Trust – alternative root not included in Chrome browser truststore (by default)

OR

2. Renew current public CA issued certificates to extend validity ← **Do this by March 15 for maximum validity period!**

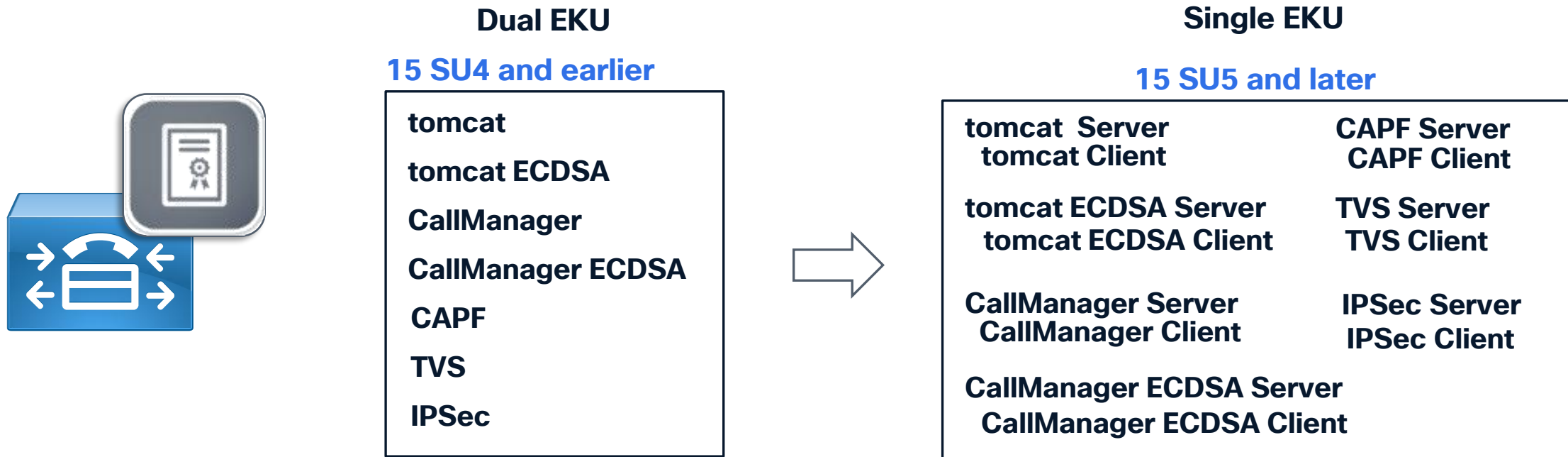
**** AND this is only to prepare for upgrade to Unified CM version 15 SU5 in the future ****

Public CA Client Auth ECU Sunsetting – 15 SU5

COMING
SOON

PLANNED ENCHANCEMENTS FOR UNIFIED CM 15 SU5*:

1. Implement dual certificate model (server and client cert per service)



2. Implement service parameter to disable Client Auth ECU check.

Note: This will require similar parameter/setting on the other side of the TLS connection

* Current target 2H CY2026. Plan of record. SUBJECT TO CHANGE.

Cipher Management



Cipher management capabilities on Unified CM enable administrator to control the encryption ciphers used by the system when making secure connections.

- **Not required / Not recommended:** By default, Unified CM has a set of recommended encryption ciphers that support secure integrations with most other products (Cisco and 3rd-party).
- **Why change?:** An administrator might change the ciphers available on the system to:
 - » Add a cipher to the system to address cipher mismatches during TLS handshake (less restrictive)*
 - » Remove a cipher to prevent it from being negotiated (more restrictive).
- **Be aware of the implications:** Modifying system ciphers may cause cipher mismatches at TLS handshake leading to connection failures.

Cipher management options:

- » Basic cipher management: Enterprise Parameters (Unified CM Administration)
- » Advanced cipher management: Cipher management (OS Administration)

* Certain weaker ciphers are not allowed, even if configured (e.g., PSK-3DES-EDE-CBC-SHA, ECDH-RSA-NUL-SHA)

Basic Cipher Control - Enterprise Parameters

If managing system ciphers, a good first step is to use the enterprise parameter basic controls

- TLS Ciphers
- sRTP Ciphers
- HTTPS Ciphers

Security Parameters		
Cluster Security Mode *	0	
Cluster SIPOAuth Mode *	Enabled	
LBM Security Mode *	Insecure	Insecure
CAPF Phone Port *	3804	3804
CAPF Operation Expires in (days) *	10	10
Endpoint Advanced Encryption Algorithms Support *	Disable	Disable
TFTP File Signature Algorithm *	SHA-1	SHA-1
Enable Caching *	True	True
Authentication Method for API Browser Access *	Basic	Basic
TLS Ciphers *	All Ciphers RSA Preferred	All Ciphers RSA Preferred
TLS 1.3 Certificate Preference Order *	TLS 1.2 Ciphers Preference Order	TLS 1.2 Ciphers Preference Order
SRTP Ciphers *	All Supported Ciphers	All Supported Ciphers
TLS Signature Algorithm for SIP Proxy and XMPP *	RSA Preferred	RSA Preferred
HTTPS Ciphers *	RSA Ciphers Only	RSA Ciphers Only

These settings provide convenient recommended cipher groupings for various levels of security (e.g., Medium, Strongest)

Default = least restrictive

All Ciphers RSA Preferred
Strongest- AES-256 SHA-384 only: RSA Preferred
Strongest- AES-256 SHA-384 only: ECDSA Preferred
Medium- AES-256 AES-128 only: RSA Preferred
Medium- AES-256 AES-128 only: ECDSA Preferred
All Ciphers RSA Preferred
All Ciphers ECDSA Preferred

All Supported Ciphers
Strongest- AEAD AES-256 GCM cipher only
Medium- AEAD AES-256 GCM, AEAD AES-128 GCM ciphers only
All Supported Ciphers

RSA Ciphers Only
RSA Ciphers Only
All Supported EC and RSA Ciphers

Full Cipher Control – Cipher Management



Proceed with
Caution

If basic controls are not sufficient, specify a set of preferred ciphers under Cipher Management configuration.

- Cipher configuration applies to all TLS interfaces and/or individual interfaces:
 - » All TLS
 - » HTTPS TLS
 - » SIP TLS
- ‘HTTPS TLS’ and ‘SIP TLS’ cipher configuration overrides cipher configuration for ‘All TLS’
- Configuration under Cipher Management overrides the basic cipher control Enterprise Parameters.

- Ciphers are entered in OpenSSL cipher string format: *<Cipher-Suite-Name>:<Cipher-Suite-Name>*
e.g., **ECDHE-RSA-AES256-GCM-SHA384:ECDHE-RSA-AES128-GCM-SHA256**

Cisco Unified Operating System Administration
For Cisco Unified Communications Solutions

Show Settings Security Software Upgrades Services Help

Cipher Management

- Certificate Management
- Certificate Monitor
- Certificate Revocation
- IPSEC Configuration
- Bulk Certificate Management
- Session Management
- Cipher Management

(OS Admin)

All TLS Type TLS Cipher Suites

Cipher String

HTTPS TLS Type TLS Cipher Suites

Cipher String

SIP TLS Type TLS Cipher Suites

Cipher String ECDHE-RSA-AES256-GCM-SHA384:ECDHE-RSA-AES128-GCM-SHA256

Cipher Expansion String ECDHE-RSA-AES256-GCM-SHA384:ECDHE-RSA-AES128-GCM-SHA256

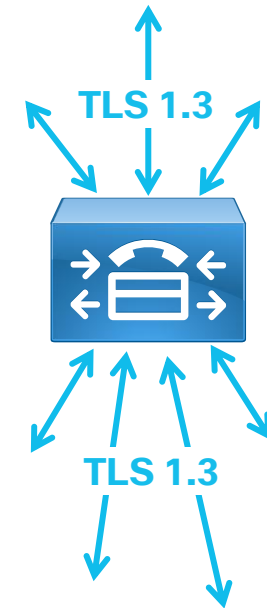
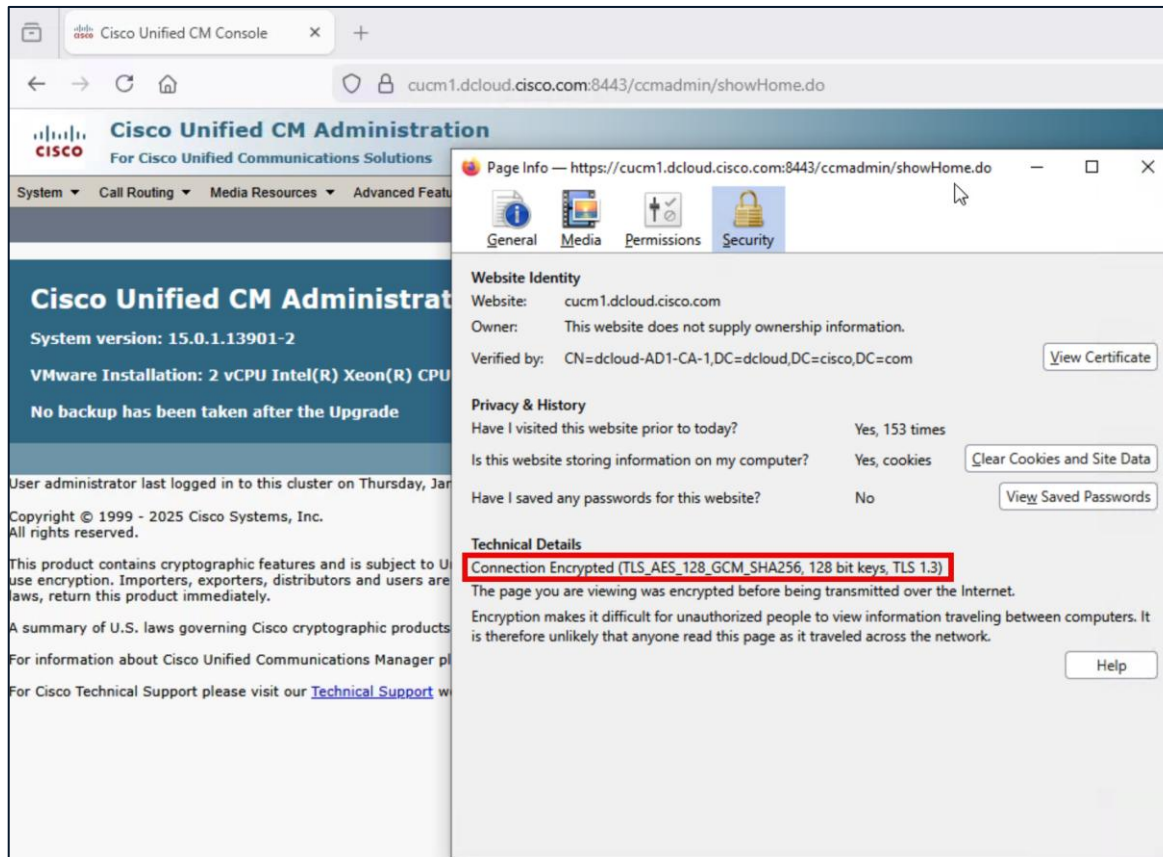
Any Cipher Expansion String listed here override the ciphers from All above.
If Cipher String for any interface is left blank, then the Cipher String in "All" is applied.

Transport Layer Security (TLS) 1.3



Unified CM 15 SU2 introduced support for TLS 1.3

- TLS 1.3 is the latest version of the TLS protocol (RFC 8446) standard and provides significant improvements over previous versions:

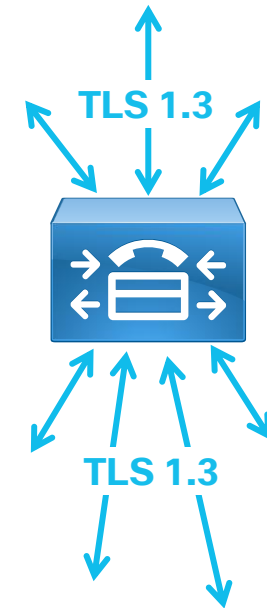


Transport Layer Security (TLS) 1.3



Unified CM 15 SU2 introduced support for TLS 1.3

- TLS 1.3 is the latest version of the TLS protocol (RFC 8446) standard and provides significant improvements over previous versions:
 - » Faster: Reduced TLS connection setup time due to faster handshake mechanism
 - » More secure: Removes support for older / less secure encryption algorithms and instead relies on modern authenticated* algorithms (e.g., AES-GCM, ChaCha20-Poly1305).
- TLS 1.3 available by default but use is dependent on server/client capabilities at connection.
- Careful if setting TLS minimum version (e.g., `set tls min-version 1.3`) ... TLS 1.3 is more secure, but may not be universally supported/compatible across your deployment

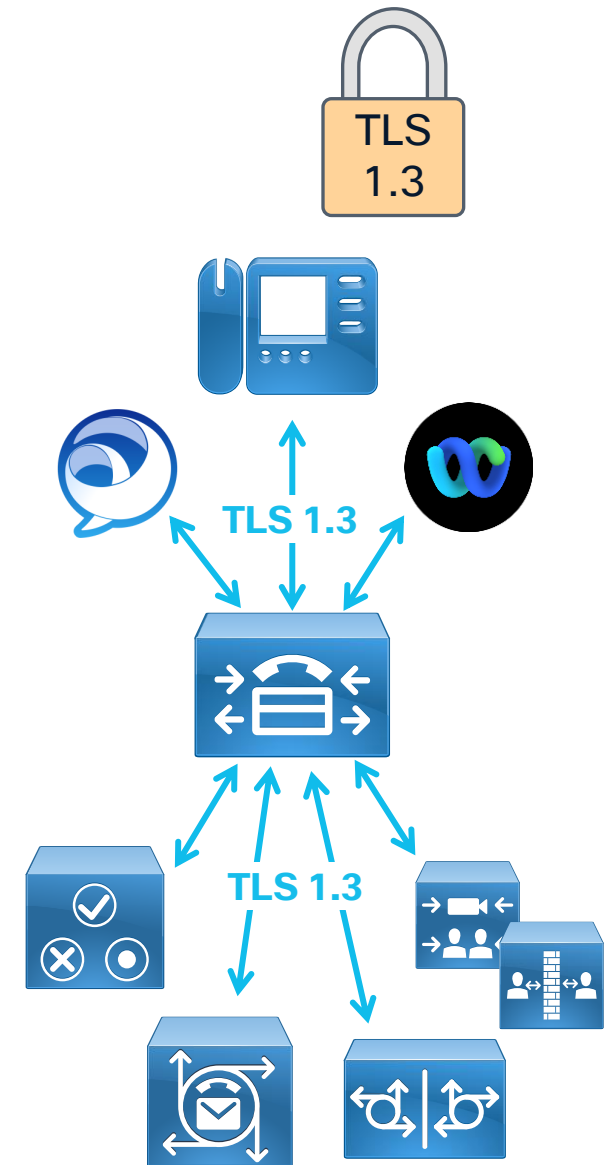


Transport Layer Security (TLS) 1.3

Unified CM 15 SU2 introduced support for TLS 1.3

- TLS 1.3 is the latest version of the TLS protocol (RFC 8446) standard and provides significant improvements over previous versions:
 - » Faster: Reduced TLS connection setup time due to faster handshake mechanism
 - » More secure: Removes support for older / less secure encryption algorithms and instead relies on modern authenticated* algorithms (e.g., AES-GCM, ChaCha20-Poly1305).
- TLS 1.3 available by default but use is dependent on server/client capabilities at connection.
- Careful if setting TLS minimum version (e.g., `set tls min-version 1.3`) ... TLS 1.3 is more secure, but may not be universally supported/compatible across your deployment
- Refer to the TLS 1.3 Compatibility Matrix for details on supported products:

https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/uc_system/unified/communications/system/Compatibility/TLS/TLS1-3-Compatibility-Matrix.html



* Authenitcated Encryption with Associated Data (AEAD)

TLS 1.3 Deployment Considerations



TLS 1.3 prefers ECDSA over RSA. This preference is based on the client’s advertised signature algorithms and ensures smoother compatibility for TLS connections.

- With TLS 1.2 server selects cert based on key algorithm in the negotiated cipher suite
- With TLS 1.3 server instead selects cert based on client advertised supported signature algorithms list

New enterprise parameter ‘**TLS 1.3 Certificate Preference Order**’ provides backward compatibility inbound TLS 1.3 connections to ensure expected certificate(s) are used:

<u>TLS 1.3 Certificate Preference Order</u> *	TLS 1.2 Ciphers Preference Order ▼ TLS 1.2 Ciphers Preference Order TLS 1.3 Signature Algorithm Preference Order
---	---

RSA cert

TLS 1.2 Ciphers Preference Order (Default): Certificate selection for inbound TLS 1.3 connections based on ‘TLS Ciphers’ parameter (default = ‘All Ciphers RSA Preferred’).

<u>TLS Ciphers</u> *	All Ciphers RSA Preferred ▼
----------------------	-----------------------------

ECDSA cert

TLS 1.3 Signature Algorithm Preference Order: Certificate selection for inbound TLS 1.3 connections based on client’s signature algorithm advertisement (ECDSA over RSA).

TLS 1.3 Deployment Considerations



TLS 1.3 prefers ECDSA over RSA. This preference is based on the client’s advertised signature algorithms and ensures smoother compatibility for TLS connections.

- With TLS 1.2 server selects cert based on key algorithm in the negotiated cipher suite
- With TLS 1.3 server instead selects cert based on client advertised supported signature algorithms list

New enterprise parameter ‘**TLS 1.3 Certificate Preference Order**’ provides backward compatibility inbound TLS 1.3 connections to ensure expected certificate(s) are used:

TLS 1.3 Certificate Preference Order *	TLS 1.2 Ciphers Preference Order ▼
	TLS 1.2 Ciphers Preference Order
	TLS 1.3 Signature Algorithm Preference Order

RSA cert

TLS 1.2 Ciphers Preference Order (Default): Certificate selection for inbound TLS 1.3 connections based on ‘TLS Ciphers’ parameter (default = ‘All Ciphers RSA Preferred’).

TLS Ciphers *	All Ciphers RSA Preferred ▼
----------------------	-----------------------------

TLS 1.3 Signature Algorithm Preference Order: Certificate selection for inbound TLS 1.3 connections based on client’s signature algorithm advertisement (ECDSA over RSA).

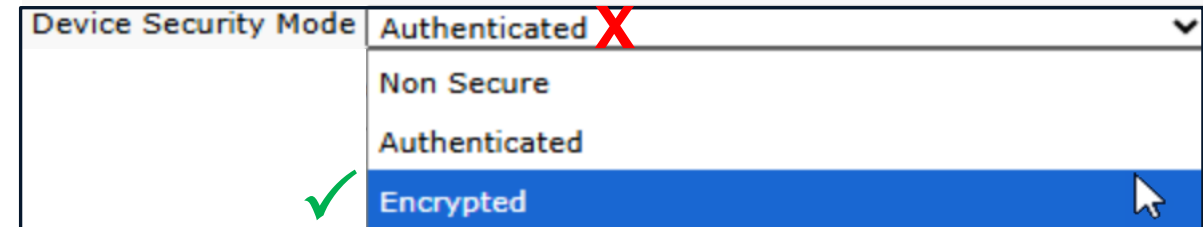


TLS 1.3 Deployment Caveats



TLS 1.3 Restrictions and Caveats:

- TLS 1.3 protocol is not supported in Common Criteria.
 - » Solution: Use TLS 1.2 instead
- ‘Authenticated’ Device Security Mode on SIP Trunk and/or Phone Security Profiles is not supported with TLS 1.3 (falls back to lower TLS version).
 - » Solution: Switch profile security mode to ‘Encrypted’ (or alternatively, do not set minimum TLS version on the cluster to 1.3).
- Endpoint support: Older phone models (including 7800 and 8800 series) do NOT support TLS 1.3
 - » Solution: User supported endpoints.
 - ✓ Phone OS devices (9800 series, 8875) – Minimum version Phone OS 3.2.
 - ✓ Software clients (minimum versions: Jabber 15, Webex App 44.5)
 - ✓ Room OS devices (Desk / Room / Board series) – Minimum versions 11.9.



Simplification with SIP OAuth



Server Certificate Count Reduction

- ✓ Multi-server (SAN) self-signed certificates
- ✓ Tomcat certificate reuse
- ✓ Remove unnecessary certificates

Simplified Server Certificate Management

- ✓ Reduced overhead on certificate renewal
- ✓ Automate certificate management
- ✓ Server certificate monitoring
- ✓ Long-lived certificates
- ✓ Centralized certificate management

Endpoint Certificate Simplification

- ✓ Automatic endpoint certificate enrollment with private CA
- ✓ Endpoint certificate (LSC) monitoring
- ✓ ITL mismatch report

Simplification with SIP OAuth

- ✓ Simplify endpoint security for these devices:
 - 7800 / 8800 / 9800 series desk phones
 - Cisco Jabber
 - Webex App (on-prem calling)
- ✓ No LSC for encrypted signaling/media = no CAPF enrollment.
- ✓ Mixed-mode not enabled, no CTL file.

Endpoint and API Authorization with OAuth

What is OAuth 2.0?

Open Authorization Standard

OAuth 2.0 is an industry-standard authorization framework that enables secure delegated access without sharing credentials

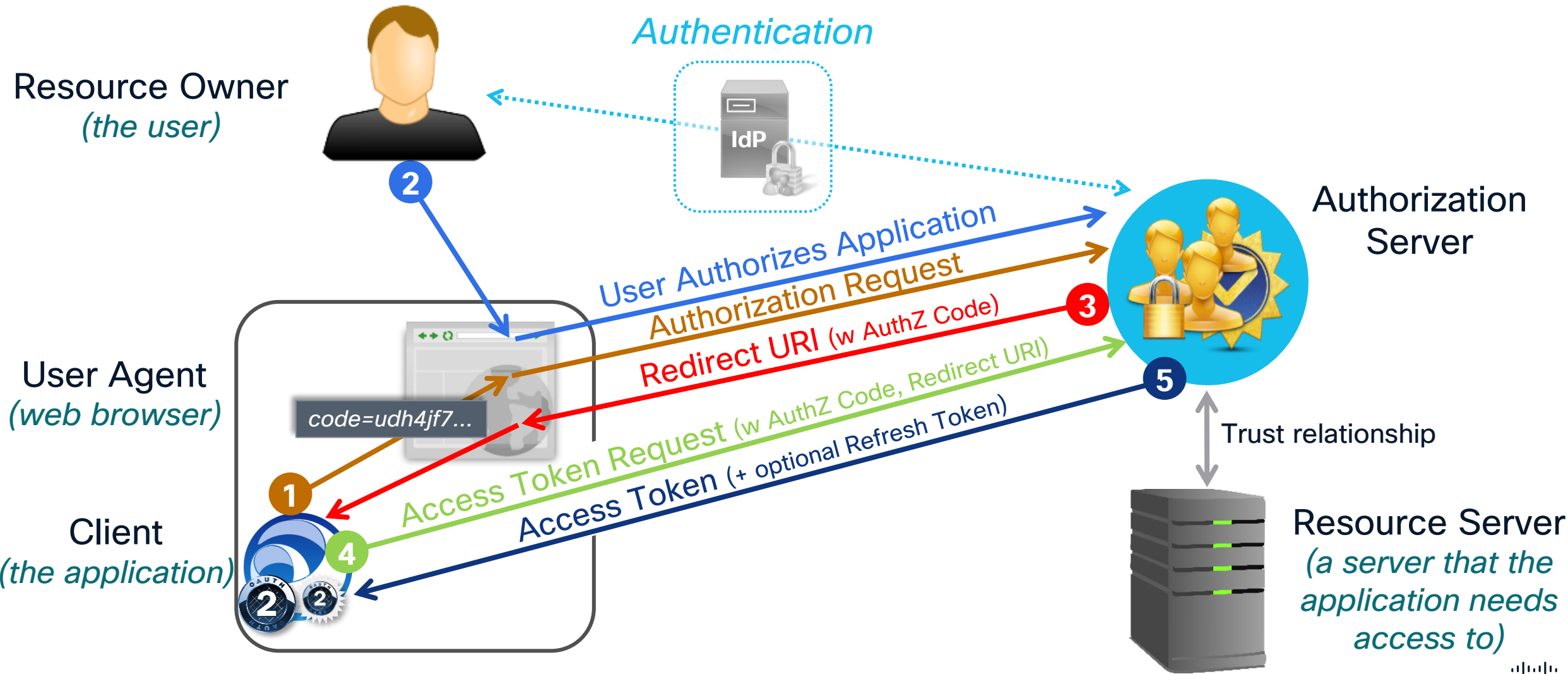
- Industry standard authorization protocol (RFC 6749)
- Uses tokens instead of passwords for authorization
- Provides secure, limited access to protected resources
- Widely adopted across web services and APIs
- Separates authentication from authorization

Key Security Benefits:

- **No password sharing:** Credentials never exposed to third parties
- **Limited scope:** Tokens grant specific, limited permissions
- **Token expiration:** Access automatically expires after set period
- **Revocable access:** Tokens can be revoked without password changes
- **Centralized control:** Single point for access management and auditing

OAuth Primer

Authorization Code Flow

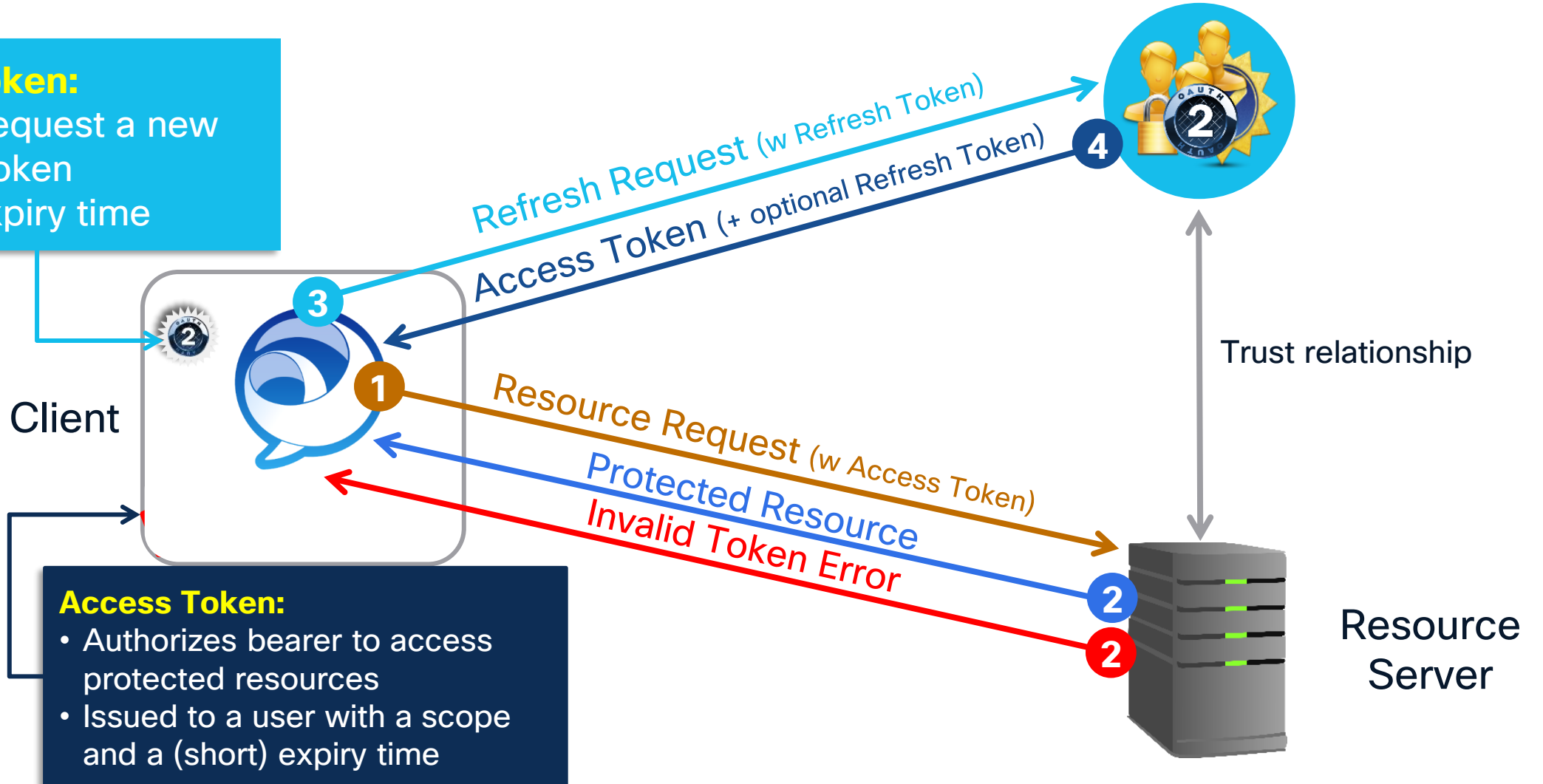


OAuth Primer

Access and Refresh Tokens

Refresh Token:

- Used to request a new Access Token
- Longer expiry time

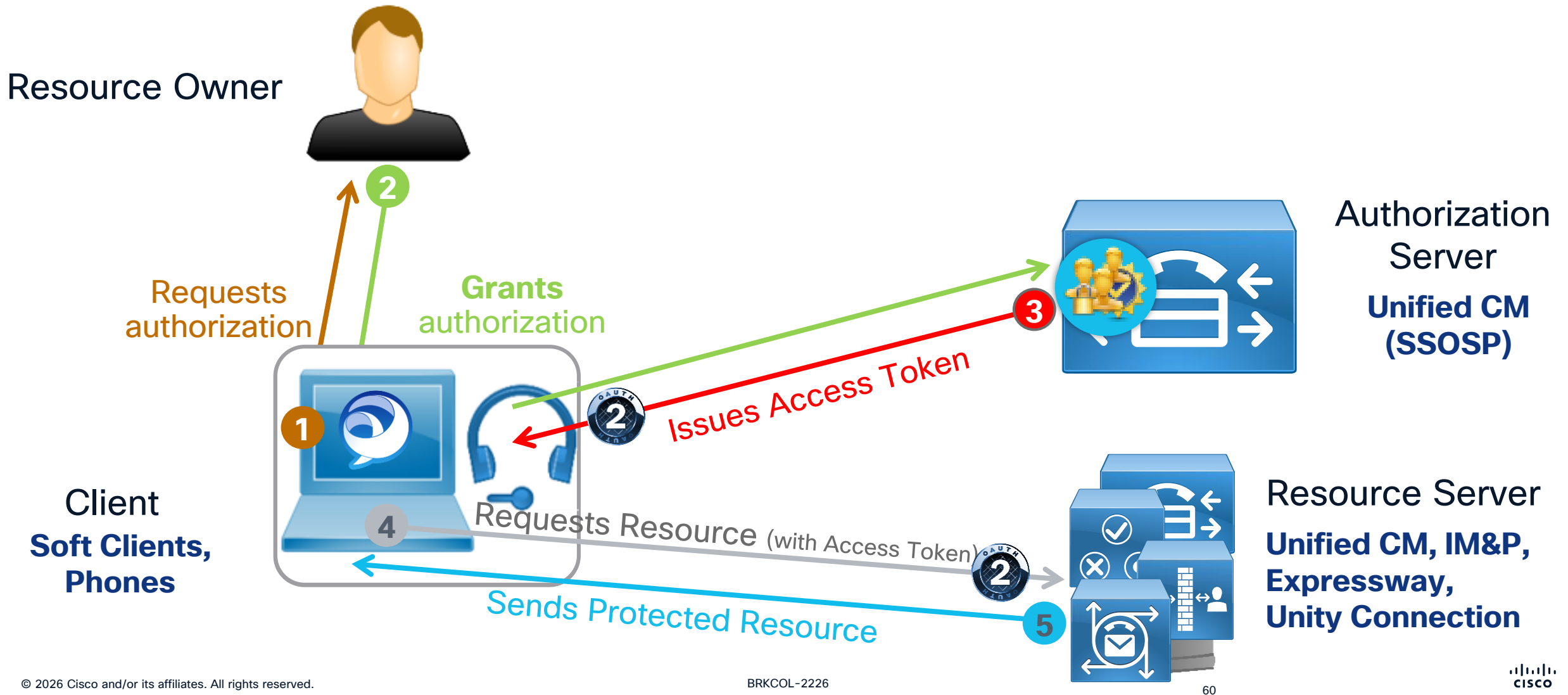


Access Token:

- Authorizes bearer to access protected resources
- Issued to a user with a scope and a (short) expiry time

OAuth Primer

OAuth Roles in Cisco UC

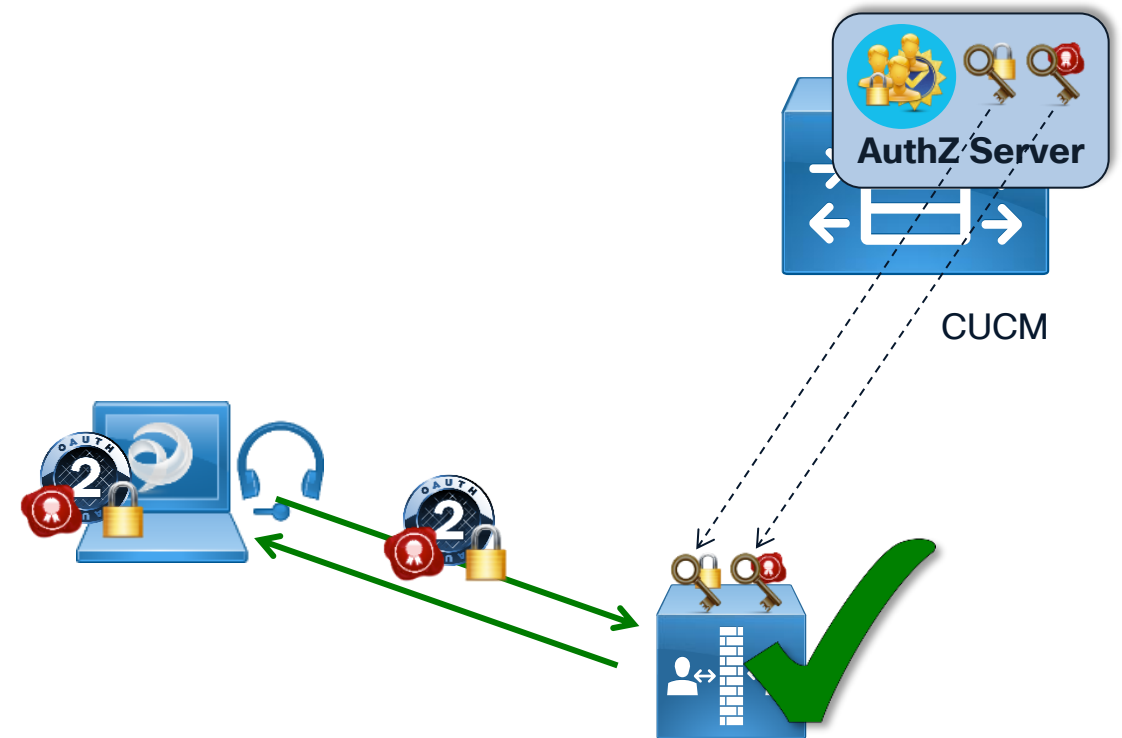


OAuth Primer

Token Format: Self-contained Access Tokens

- **Self-contained access tokens** are signed and encrypted by the AuthZ server and contain the relevant scopes
- They can be validated and examined by Resource Servers (e.g., Expressway, Unity Connection) with the appropriate keys
 - Clients cannot read the content of the tokens and treat them as “blobs”
- Format adopted by Cisco UC: JSON Web Token (JWT) (RFC 7519,7515,7516)
- *(Note: token format is not part of the OAuth 2.0 standard)*

Validating Self-contained Access Tokens



API Protection

Before CSR 12

	HTTP (CUCM)	SIP	XMPP	HTTP (Unity Cxn)
On-premises Phones	Certificate-based*	Certificate-based*	(N/A)	(N/A)
On-premises Clients (Local or LDAP AuthN)	Digest	Certificate-based*	SOAP binding with digest auth, derive VTG token used as SASL bind	Digest
MRA Phones	Basic auth, Expwy-E caches credentials, generates x-auth cookie sent back to client	Digest auth at Expwy-E based on cached CUCM credentials	(N/A)	(N/A)
MRA Clients (Local or LDAP AuthN)	Basic auth, Expwy-E caches credentials, generates x-auth cookie sent back to client	Digest auth at Expwy-E based on cached CUCM credentials	SOAP binding with digest auth (after edge traversal using x-auth cookie), derive VTG token for SASL bind	Digest auth after edge traversal using x-auth cookie
On-premises Clients (SAML SSO)	OAuth token	Certificate-based*	SOAP binding with OAuth token, derive VTG token used as SASL bind	OAuth token (different token from CUCM)
MRA Clients (SAML SSO)	OAuth token	Opaque token generated on Expwy-C as result of OAuth flow	SOAP binding with OAuth token, derive VTG token used as SASL bind	OAuth token (different token from CUCM)

API Protection

CSR 12.5

	HTTP (CUCM)	SIP	XMPP	HTTP (Unity Cxn)
On-premises Phones	Certificate-based*	Certificate-based*	(N/A)	(N/A)
On-premises Clients (Local or LDAP AuthN)	OAuth token	OAuth token	OAuth token	OAuth token
MRA Phones	OAuth token	OAuth token	(N/A)	(N/A)
MRA Clients (Local or LDAP AuthN)	OAuth token	OAuth token	OAuth token	OAuth token
On-premises Clients (SAML SSO)	OAuth token	OAuth token	OAuth token	OAuth token
MRA Clients (SAML SSO)	OAuth token	OAuth token	OAuth token	OAuth token

API Protection

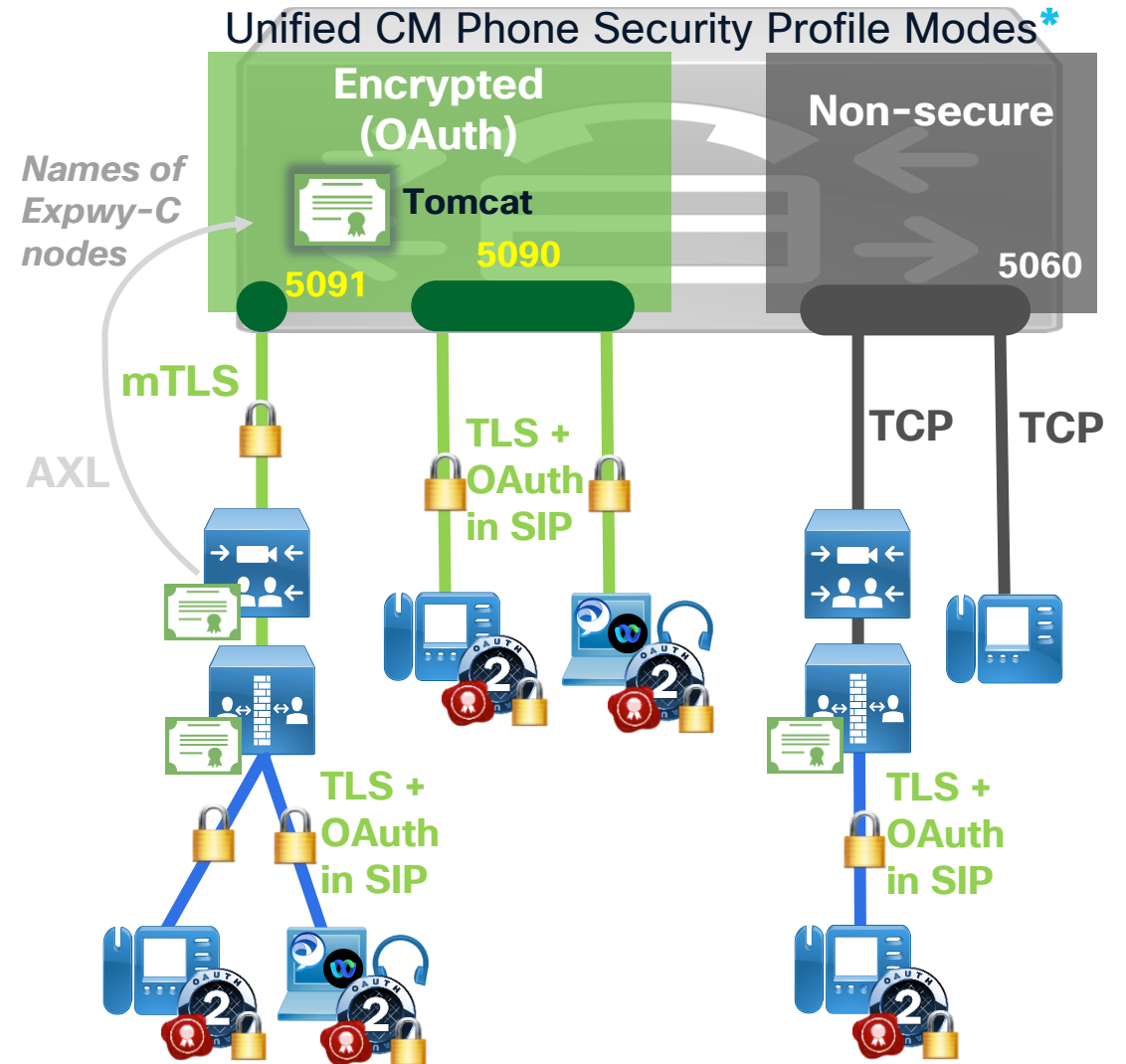
CSR 14

	HTTP (CUCM)	SIP	XMPP	HTTP (Unity Cxn)
On-premises Phones	OAuth token	OAuth token	(N/A)	(N/A)
On-premises Clients (Local or LDAP AuthN)	OAuth token	OAuth token	OAuth token	OAuth token
MRA Phones	OAuth token	OAuth token	(N/A)	(N/A)
MRA Clients (Local or LDAP AuthN)	OAuth token	OAuth token	OAuth token	OAuth token
On-premises Clients (SAML SSO)	OAuth token	OAuth token	OAuth token	OAuth token
MRA Clients (SAML SSO)	OAuth token	OAuth token	OAuth token	OAuth token

OAuth for Phones

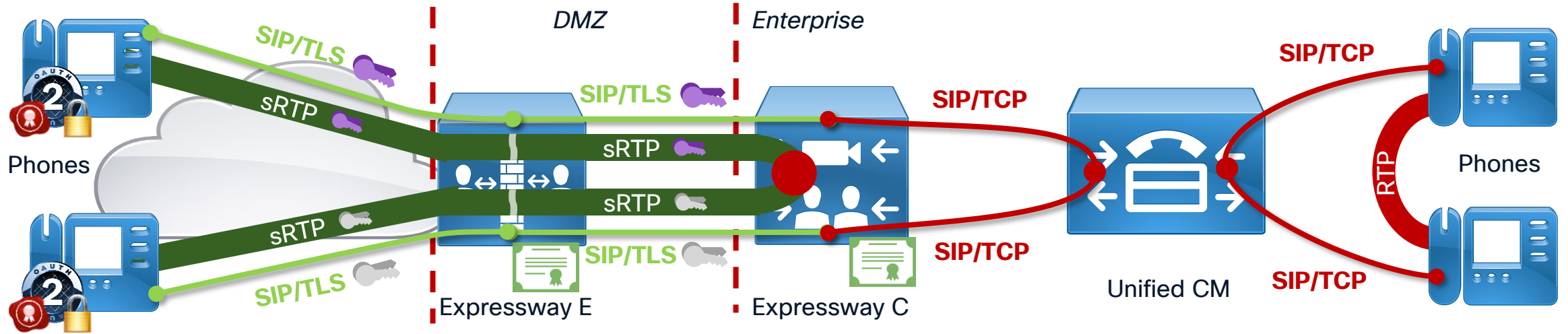
CSR 14

- Phones support OAuth for SIP and HTTPS with Unified CM
 - Signaling and media encryption without mixed-mode or client certificates
 - **HTTPS with OAuth for config download**
- Phones onboarded with activation code in CSR 12.5 can be upgraded to this mode without reactivation
- Phones in non-secure mode can also be upgraded to this mode using Zero-Touch Onboarding



OAuth for Phones

SIP and Media Security – Before CSR 14



Phones over MRA:

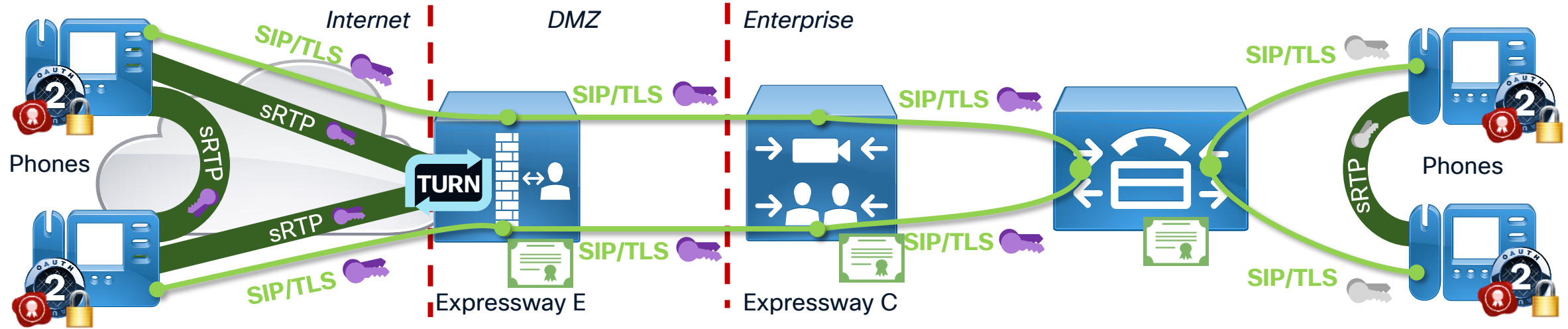
- SIP signaling is authenticated (TLS + OAuth token) and encrypted
 - Expwy-C enforces encryption (B2BUA)
- Media is encrypted (Phone ↔ Expwy-C)
 - No ICE media path optimization possible

Phones on-premises:

- SIP signaling and media are not authenticated or encrypted by default
 - Encryption requires Unified CM mixed mode
- Signaling authentication is certificate-based (mTLS), requires CAPF enrollment

OAuth for Phones

SIP and Media Security – CSR 14



Phones over MRA:

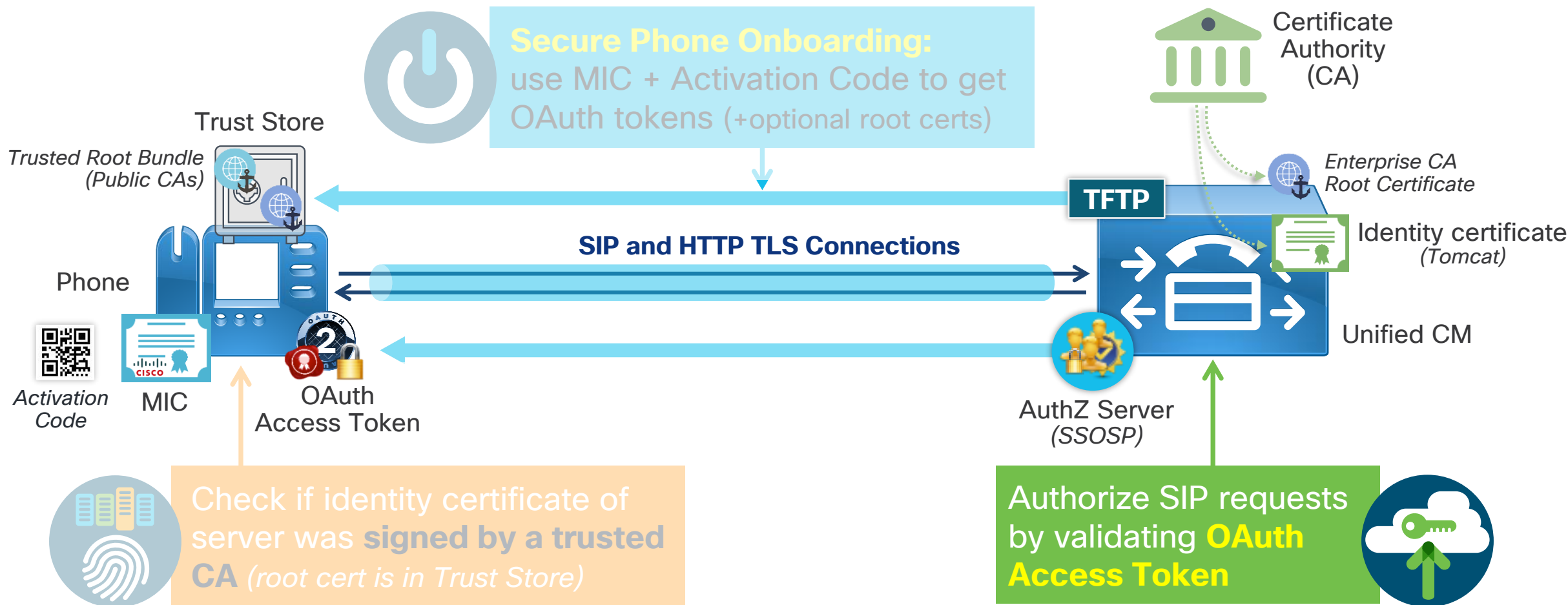
- SIP signaling is authenticated (TLS + OAuth token) and encrypted
 - Expwy-C uses mTLS with Unified CM
- Media is encrypted end-to-end
 - ICE media path optimization is possible

Phones on-premises:

- SIP signaling is authenticated (TLS + OAuth token) and encrypted
- Media is encrypted (no need for CAPF enrollment or mixed-mode)

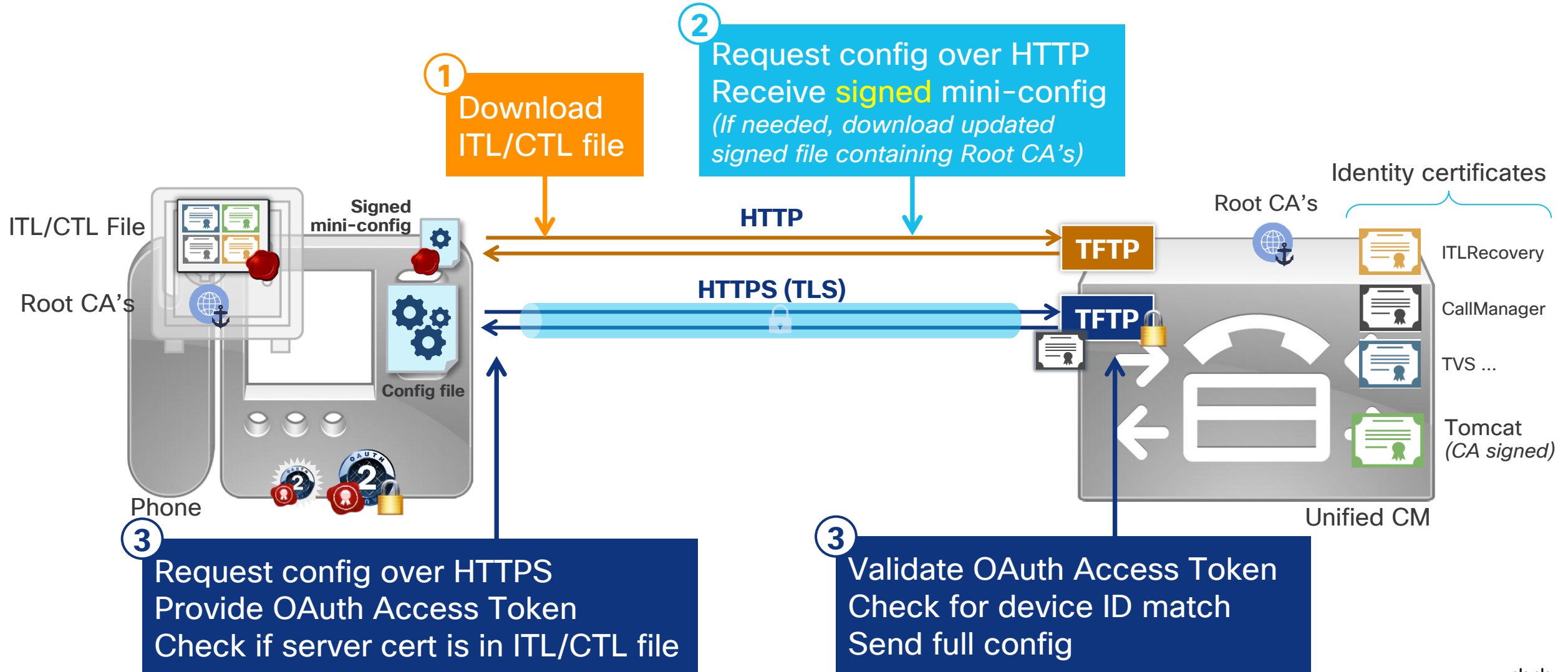
Always-secure Phones with OAuth

API Protection: OAuth



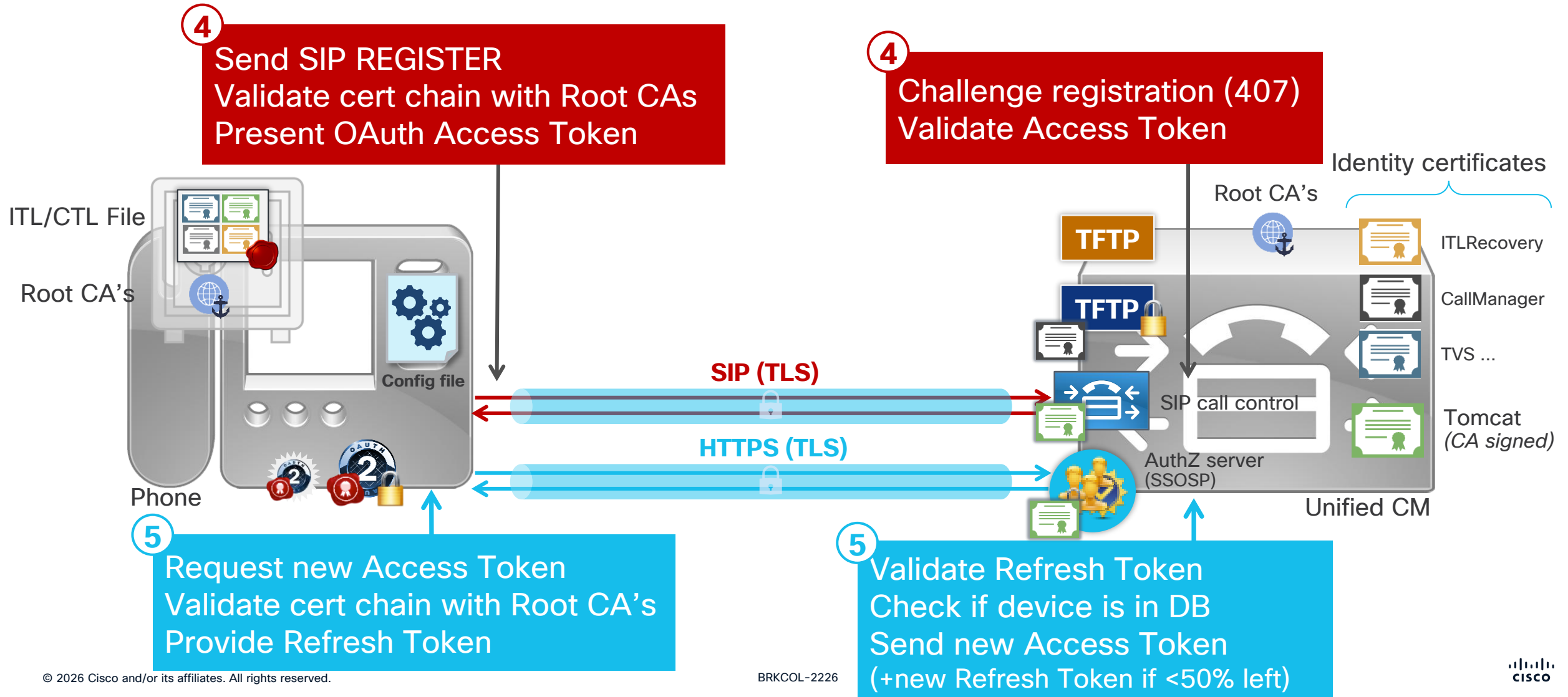
OAuth for Phones

Configuration Download - CSR 14



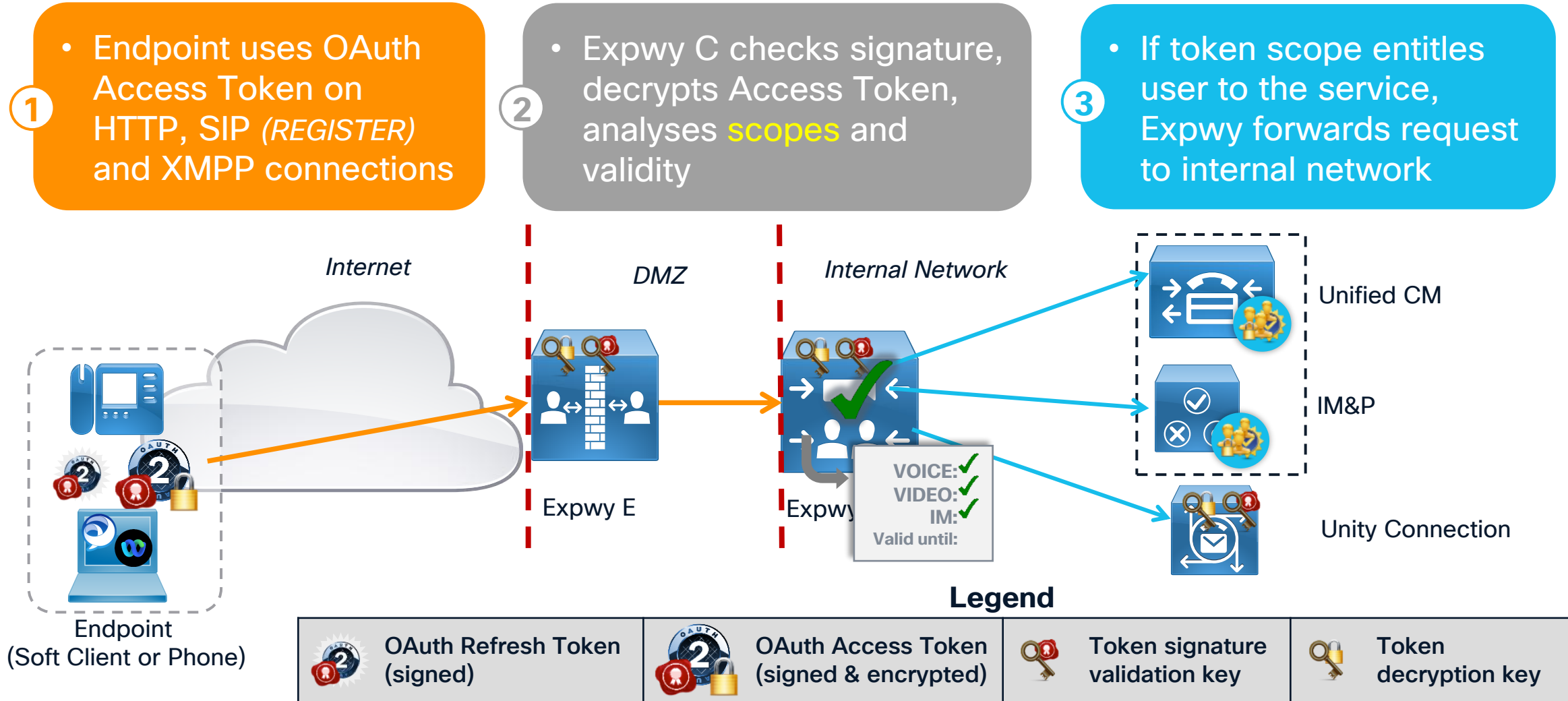
OAuth for Phones

SIP and AuthZ Server (SSOSP) – CSR 14



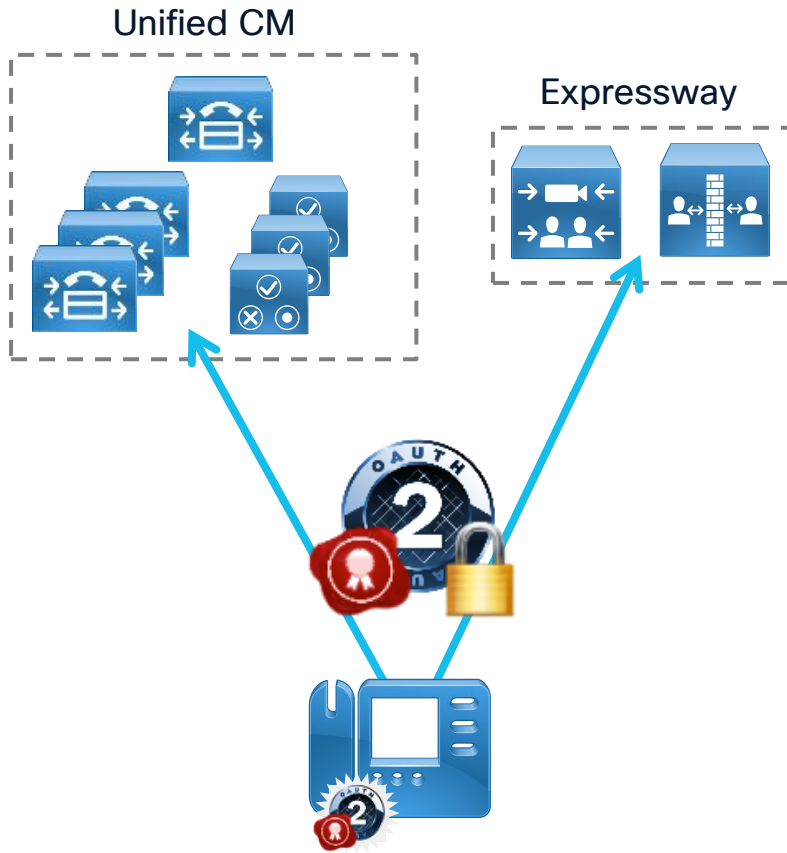
OAuth for Phones

Accessing Services over MRA



OAuth for Phones

Configuration Process



1. Enable OAuth with Refresh Login flow on Unified CM*
2. Enable and configure SIP OAuth on Unified CM
3. Configure Expressway (if MRA is needed)
4. Assign “OAuth” Encrypted Phone Security Profile to Endpoints

*Remember to enable OAuth with Refresh on all UC applications for the optimal user experience.

OAuth for Phones

Configuration: Enable OAuth with Refresh Login Flow

Unified CM Admin > System > Enterprise Parameters :

SSO and OAuth Configuration		
OAuth Access Token Expiry Timer (minutes) *	60	60
Client OAuth Refresh Token Expiry Timer (days) *	60	60
Physical Phone OAuth Refresh Token Expiry Timer (days) *	60	60
Redirect URIs for Third Party SSO Client		
SSO Login Behavior for iOS *	Use embedded browser (WebView)	Use embedded browser (WebView)
OAuth with Refresh Login Flow *	Enabled	Disabled
Use SSO for RTMT *	True	True
OAuth Access Token for Devices *	Implicit: Already registered devices	Implicit: Already registered devices
Auto Renew Refresh Token *	Enabled	Enabled

- **Enable** OAuth with Refresh Login Flow (disabled by default)
- If needed, **adjust** token expiry timers

OAuth for Phones

Configuration: Enable SIP OAuth on Unified CM

- Enable feature from Unified CM publisher CLI (requires smart license enabled for export-controlled functionality):

```
utils sip-oauth enable
```

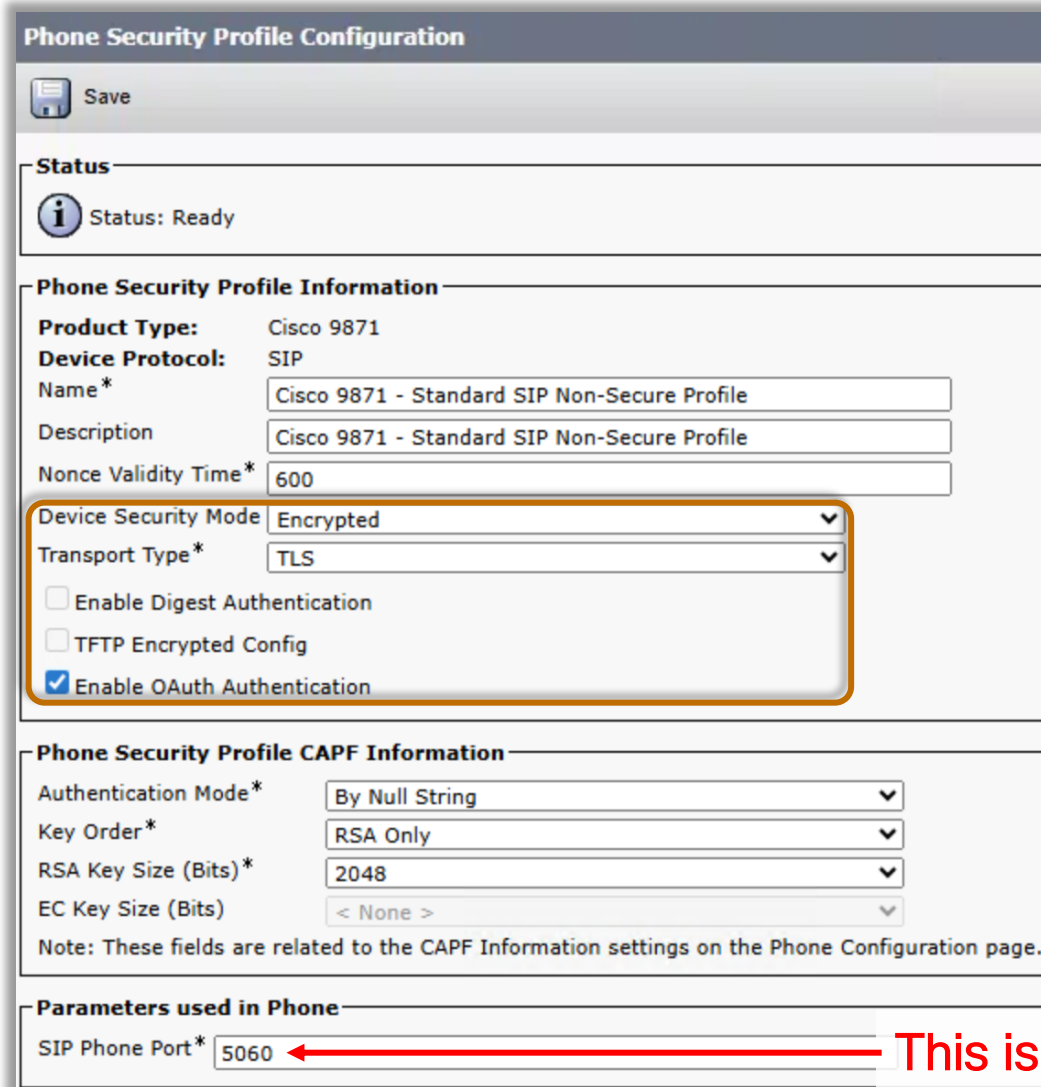
- Restart Callmanager service on all relevant subscriber nodes
- Verify cluster configuration at:

Unified CM Admin > System > Enterprise Parameters:

Security Parameters	
Cluster Security Mode *	1
Cluster SIPOAuth Mode *	Enabled
LBM Security Mode *	Secure ▼
CAPF Phone Port *	3804
CAPF Operation Expires in (days) *	10
Endpoint Advanced Encryption Algorithms Support *	Disable ▼

OAuth for Phones

Configuration: SIP OAuth Phone Security Profile



Phone Security Profile Configuration

 Save

Status

 Status: Ready

Phone Security Profile Information

Product Type: Cisco 9871
Device Protocol: SIP

Name * Cisco 9871 - Standard SIP Non-Secure Profile
Description Cisco 9871 - Standard SIP Non-Secure Profile
Nonce Validity Time * 600

Device Security Mode Encrypted
Transport Type * TLS

☐ Enable Digest Authentication
☐ TFTP Encrypted Config
☒ Enable OAuth Authentication

Phone Security Profile CAPF Information

Authentication Mode * By Null String
Key Order * RSA Only
RSA Key Size (Bits) * 2048
EC Key Size (Bits) < None >

Note: These fields are related to the CAPF Information settings on the Phone Configuration page.

Parameters used in Phone

SIP Phone Port * 5060 ← This is ignored!

Unified CM Admin > System > Security > Phone Security Profile:

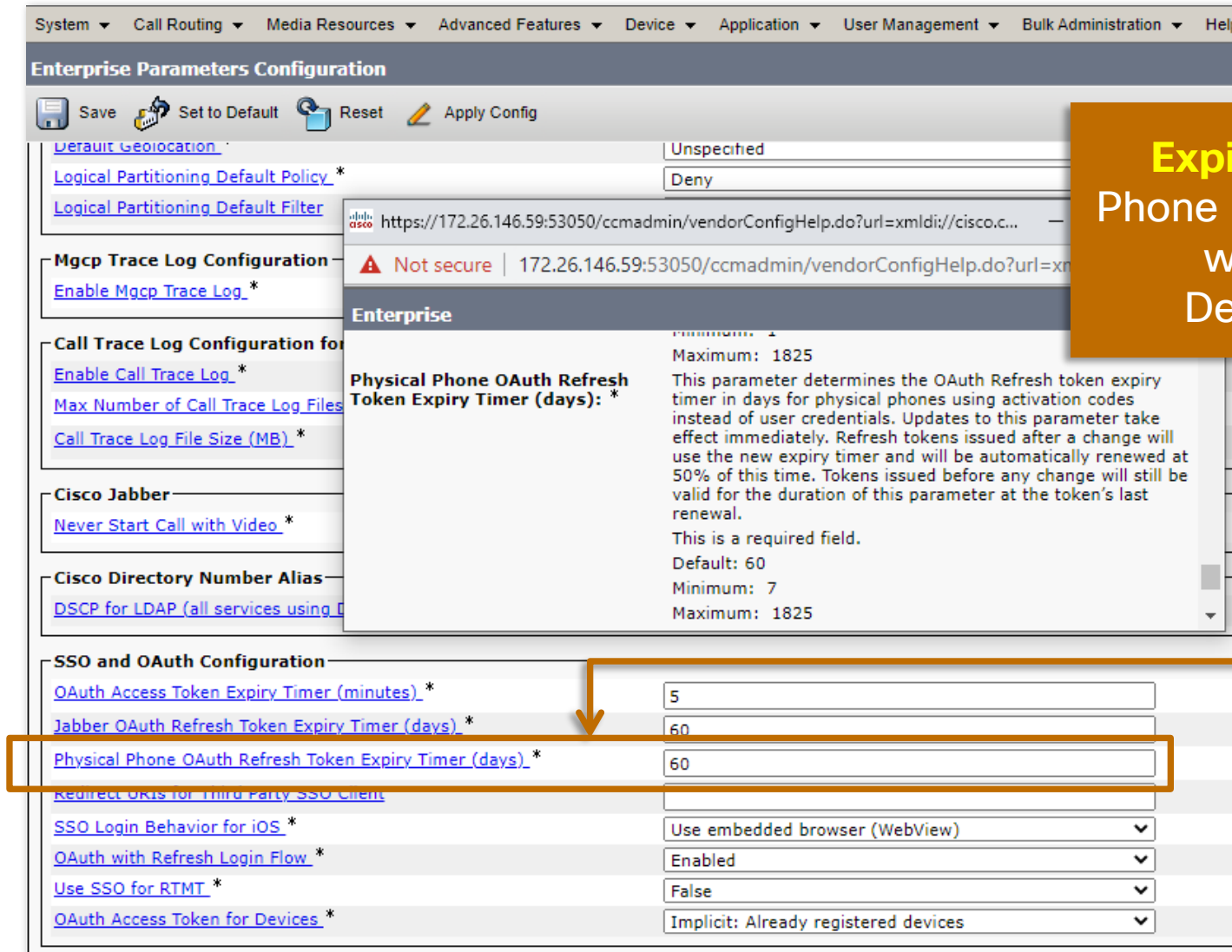
- Create or modify Phone Security Profiles for all relevant endpoint types
- Set Device Security Mode to “Encrypted”
- Select checkbox to “Enable OAuth Authentication”
- Reset/restart devices

OAuth for Phones

Configuration: Refresh Token Expiry Time

Unified CM Admin > System >
Enterprise Parameters

Expiry Timer for Phone Refresh Token:
Phone refresh tokens automatically renewed
when reaching 50% of expiry timer
Default value: 60 days (configurable)



System ▾ Call Routing ▾ Media Resources ▾ Advanced Features ▾ Device ▾ Application ▾ User Management ▾ Bulk Administration ▾ Help

Enterprise Parameters Configuration

Save Set to Default Reset Apply Config

Default Geolocation: Unspecified

Logical Partitioning Default Policy: Deny

Logical Partitioning Default Filter: [https://172.26.146.59:53050/ccmadmin/vendorConfigHelp.do?url=xmldi://cisco.c...](#)

Mgcp Trace Log Configuration

Enable Mgcp Trace Log: *

Call Trace Log Configuration for

Enable Call Trace Log: *

Max Number of Call Trace Log Files: *

Call Trace Log File Size (MB): *

Cisco Jabber

Never Start Call with Video: *

Cisco Directory Number Alias

DSCP for LDAP (all services using D): *

SSO and OAuth Configuration

OAuth Access Token Expiry Timer (minutes): *

Jabber OAuth Refresh Token Expiry Timer (days): *

Physical Phone OAuth Refresh Token Expiry Timer (days): *

Redirect URIs for Third Party SSO Client: *

SSO Login Behavior for iOS: *

OAuth with Refresh Login Flow: *

Use SSO for RTMT: *

OAuth Access Token for Devices: *

Maximum: 1825

This parameter determines the OAuth Refresh token expiry timer in days for physical phones using activation codes instead of user credentials. Updates to this parameter take effect immediately. Refresh tokens issued after a change will use the new expiry timer and will be automatically renewed at 50% of this time. Tokens issued before any change will still be valid for the duration of this parameter at the token's last renewal.

This is a required field.

Default: 60

Minimum: 7

Maximum: 1825

If a phone remains unplugged for more than 30 days (default value), it may need to be re-onboarded

OAuth for Phones

Configuration: Disabling Zero-Touch Onboarding

Unified CM Admin > System > Enterprise Parameters :

System ▾ Call Routing ▾ Media Resources ▾ Advanced Features ▾ Device ▾ Application ▾ User Management ▾ Bulk Administration ▾ Help ▾

Enterprise Parameters Configuration

 Save  Set to Default  Reset  Apply Config

Default Geolocation	Unspecified ▾
Logical Partitioning Default Policy *	Deny ▾
Logical Partitioning Default Filter	< None > ▾

Mgcp Trace Log Configuration

Enable Mgcp Trace Log *	Disabled
---	----------

Call Trace Log Configuration for Enterprise

Enable Call Trace Log *	Enabled
Max Number of Call Trace Log Files *	2000
Call Trace Log File Size (MB) *	2

Cisco Jabber

Never Start Call with Video *	False
---	-------

Cisco Directory Number Alias

DSCP for LDAP (all services using Di	default DSCP (000000)
--	-----------------------

SSO and OAuth Configuration

OAuth Access Token Expiry Timer (minutes) *	5	60
Jabber OAuth Refresh Token Expiry Timer (days) *	60	60
Physical Phone OAuth Refresh Token Expiry Timer (days) *	7	60
Redirect URIs for Third Party SSO Client		
SSO Login Behavior for iOS *	Use embedded browser (WebView) ▾	Use embedded browser (WebView)
OAuth with Refresh Login Flow *	Enabled ▾	Disabled
Use SSO for RTMT *	False ▾	True
OAuth Access Token for Devices *	Implicit: Already registered devices ▾	Implicit: Already registered devices

Implicit: Zero-touch onboarding allowed
Explicit: Activation-code onboarding only

Always-secure Phones with OAuth

Benefits of New Architecture



Compliant

Internal and external security and privacy requirements



Secure

Easy to manage, always-on security built with modern standards



Flexible

Seamless mobility between on-premises and MRA for phones and soft clients



Optimized

Better quality and scale for remote workers with media optimization



Enrollment for Soft Clients

Refresher: Soft Client Authentication Options



3

SAML SSO:

- CUCM/IM&P, Unity Connection and Expressway set up SAML agreements with IdP
- All end-user authentication is delegated to the IdP
- Soft clients rely on platform browser to interact with IdP

2

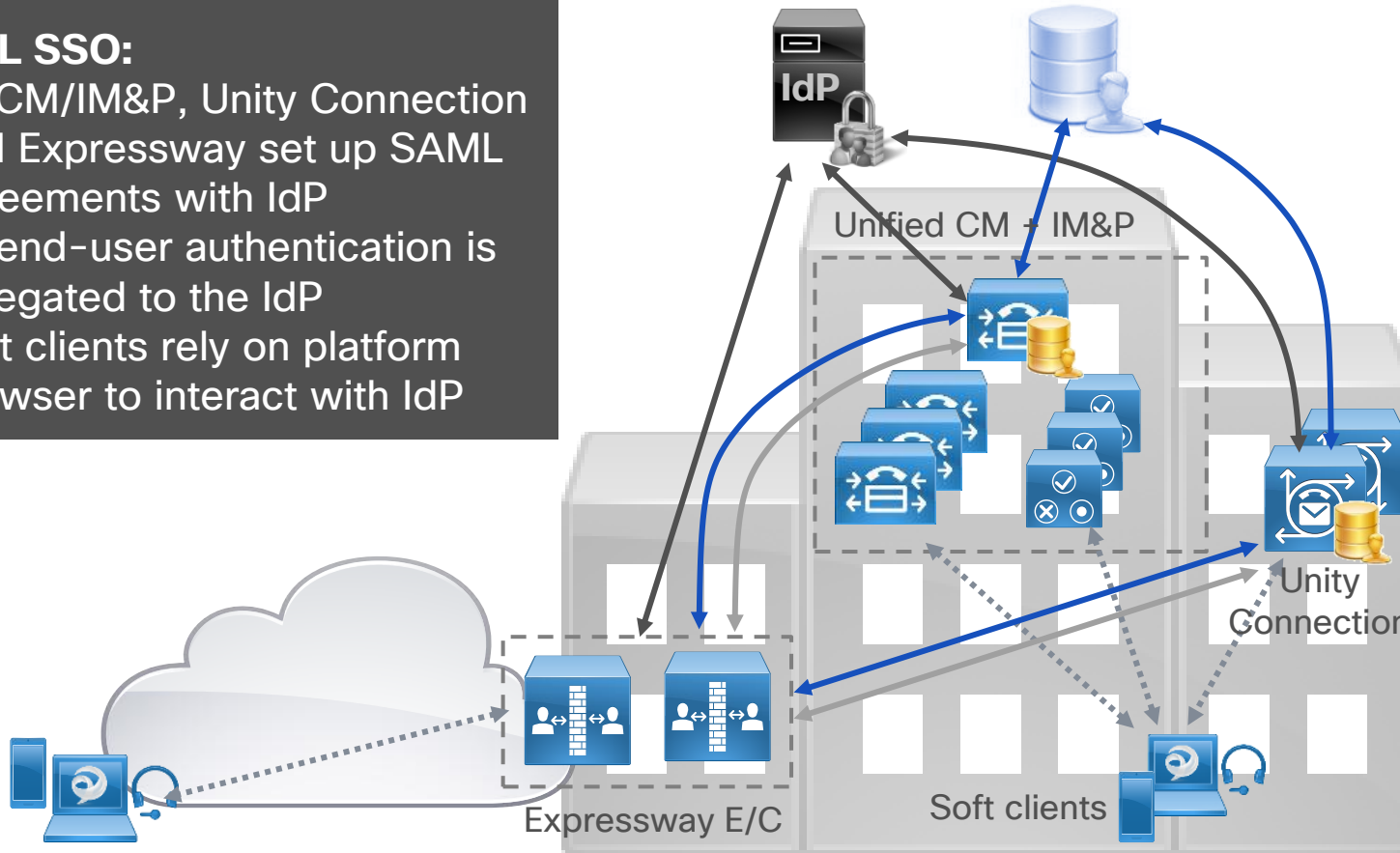
LDAP Authentication:

- CUCM/IM&P and Unity Connection use LDAP bind to authenticate end-users against external directory
- Equivalent to local authN for Expressway/MRA

1

Local Authentication :

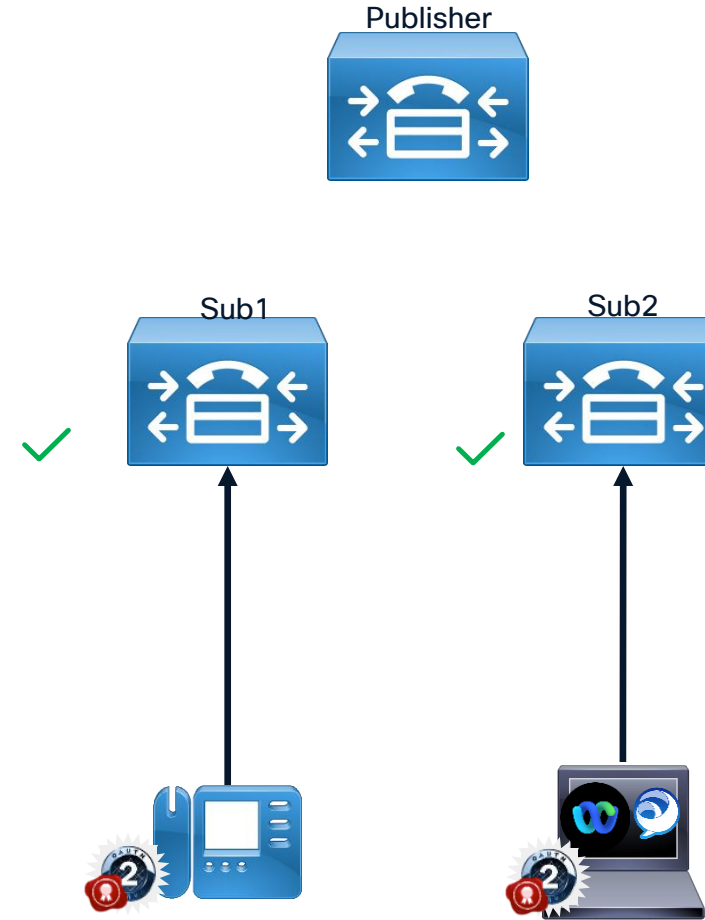
- Built-in user databases in CUCM/IM&P and Unity Connection
- Expressway forwards authN requests to CUCM/Unity for MRA



OAuth with Refresh Tokens – Pre CSR 15

- Signing and encryption keys are shared across all nodes
- Subs can validate access tokens based on this shared signing and encryption key.
- Login is **successful**

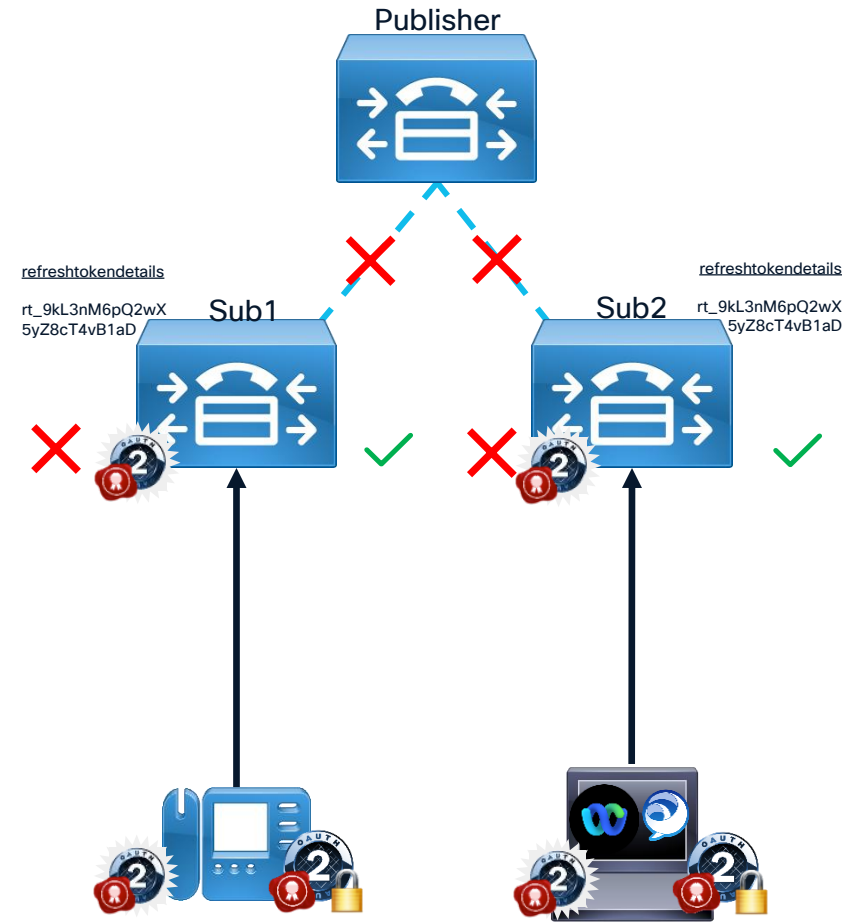
Token Type	Token Status
Access Token	Valid
Refresh Token	Valid



OAuth with Refresh Tokens – Pre CSR 15

- Subscribers have access to the refreshtokendetails table.
- Refresh token is validated based on shared signing/encryption keys.
- Login is **successful** because subscribers can validate Refresh Tokens and issue Access Tokens

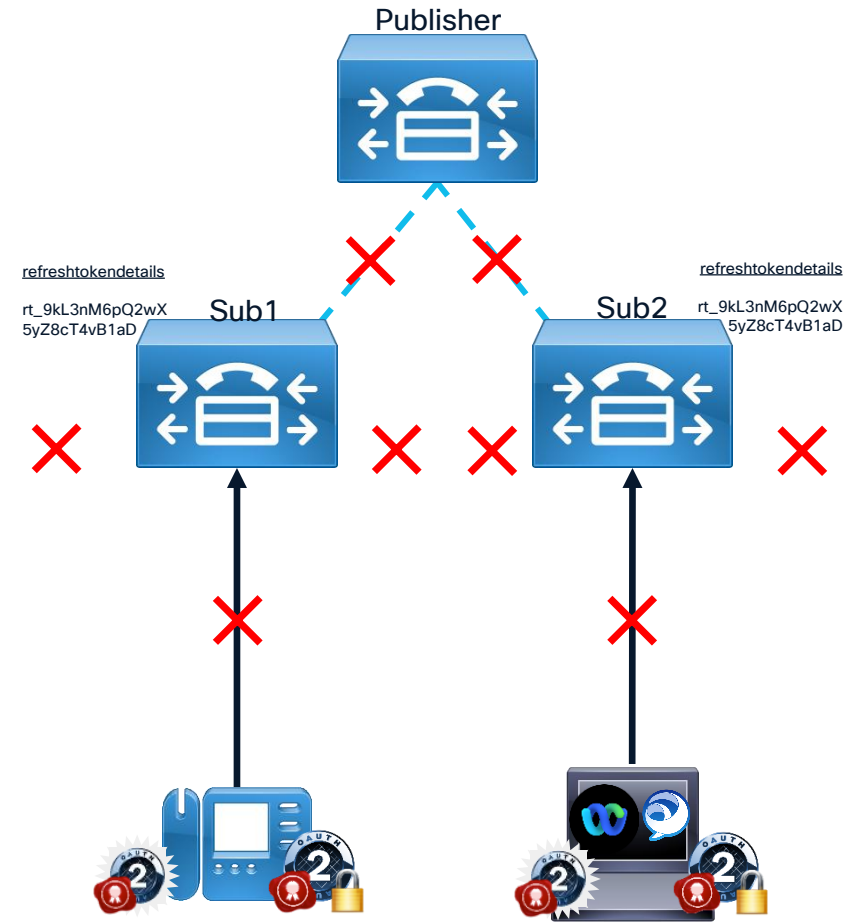
Token Type	Token Status
Access Token	Expired
Refresh Token	Valid



OAuth with Refresh Tokens – Pre CSR 15

- Publisher is either down or unreachable by the subscribers.
- Access token validation fails.
- Refresh token validation fails due to expiration or revocation.
- Login is **unsuccessful** because subscribers cannot issue refresh tokens.

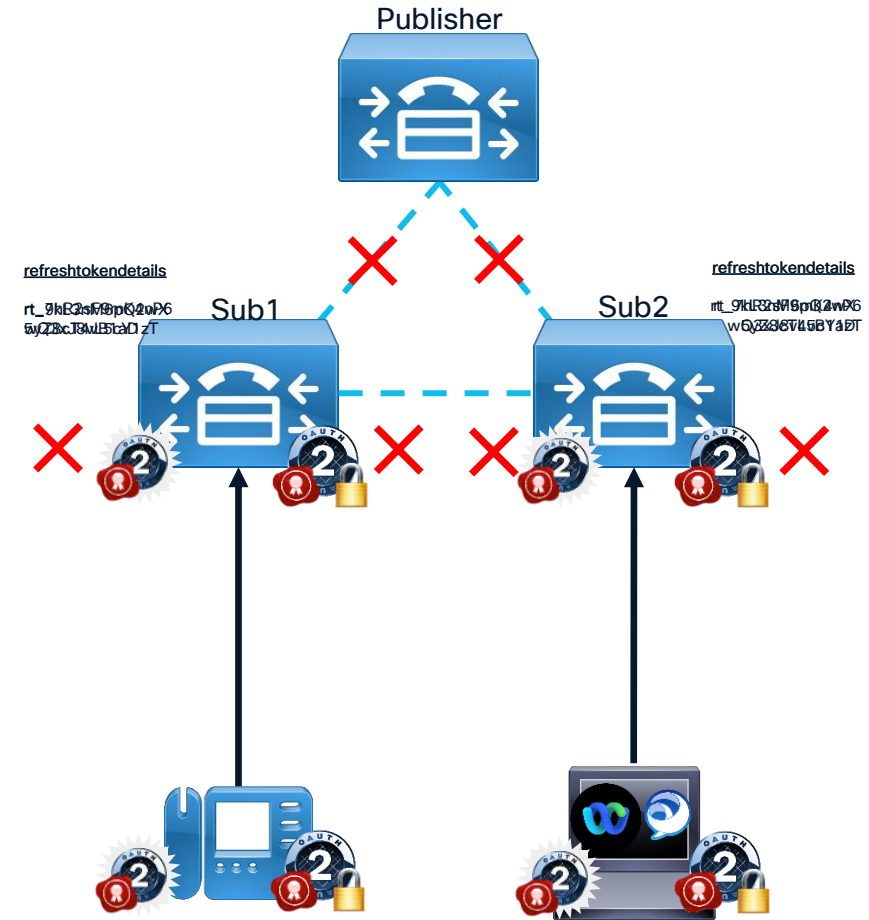
Token Type	Token Status
Access Token	Expired
Refresh Token	Expired/Revoked



CSR 15 OAuth Architecture Update

- Publisher is either down or unreachable by the subscribers.
- Access token validation fails.
- Refresh token validation fails due to expiration or revocation.
- Login is **successful** because subscribers can now issue refresh tokens and write that information to other nodes.

Token Type	Token Status
Access Token	Expired
Refresh Token	Expired/Revoked



OAuth Comparison

Aspect	Before Version 15 & 14SU3	After Version 15 & 14SU3
Access Token Issuance	Publisher + all subscribers	Publisher + all subscribers
Refresh Token Issuance	Publisher only	Publisher + all subscribers
Access Token Storage	None (stateless JWT)	None (stateless JWT)
Access Token Validation	Any node	Any node
Refresh Token Storage	Database (refreshtokendetails table)	Database (refreshtokendetails table)
Signing/Encryption Keys	Generated on publisher, distributed to all nodes	Generated on publisher, distributed to all nodes
Key Distribution Method	Automatic cluster distribution	Automatic cluster distribution
Load Distribution	All refresh token requests bottlenecked at publisher	Token requests can be distributed across the cluster
Cluster Distribution	Database replication (for refresh tokens)	Database replication (for refresh tokens)

Automatic Renewal of Refresh Token for Webex Clients

- Eliminates manual re-login every 60 days - refresh tokens automatically renew before expiration.
- Prevents unexpected Webex App disconnections and authentication interruptions.
- Controlled by "Auto Renew Refresh Token" enterprise parameter (enabled by default).
- Improves user experience, especially for remote/MRA deployments.

System ▾ Call Routing ▾ Media Resources ▾ Advanced Features ▾ Device ▾ Application ▾ User Management ▾ Bulk Administration ▾ Help ▾

Enterprise Parameters Configuration

Save Set to Default Reset Apply Config

Mgcp Trace Log Configuration

[Enable Mgcp Trace Log](#) * Disabled ▾ Disabled

Call Trace Log Configuration for Session Trace

[Enable Call Trace Log](#) * Enabled ▾ Enabled

[Max Number of Call Trace Log Files](#) * 2000 2000

[Call Trace Log File Size \(MB\)](#) * 2 2

Cisco Jabber

[Never Start Call with Video](#) * False ▾ False

SSO

[OAuth Access Token for Devices](#) * This parameter allows Administrator to move to OAuth-based security model for devices already registered. When set to "Implicit: Already registered devices", devices will get a token pair from Unified CM by authenticating with no end user intervention. This token pair can then be used for authentication across various services such as SIP registration within the Unified CM environment. If parameter is set to "Explicit: Activation Code device onboarding required", devices must be onboarded via Activation Code to move to the OAuth-based security model. This is a required field. Default: Implicit: Already registered devices

[Auto Renew Refresh Token](#) * This parameter allows an administrator to enable or disable auto renewal of refresh token. By default it is enabled. If it is disabled, CUCM keeps old behavior. i.e. refresh token will not auto-extend. This is a required field. Default: Enabled

[Directory Search Scope](#) * This parameter determines whether UDS User searches will be limited to Users mapped to the same "Customer" or to all users in the System. Note: This parameter should only be used by Hosted Collaboration Solution Shared Administrators. Enabled ▾ Enabled

[Use SSO for RTMT](#) * True ▾ True

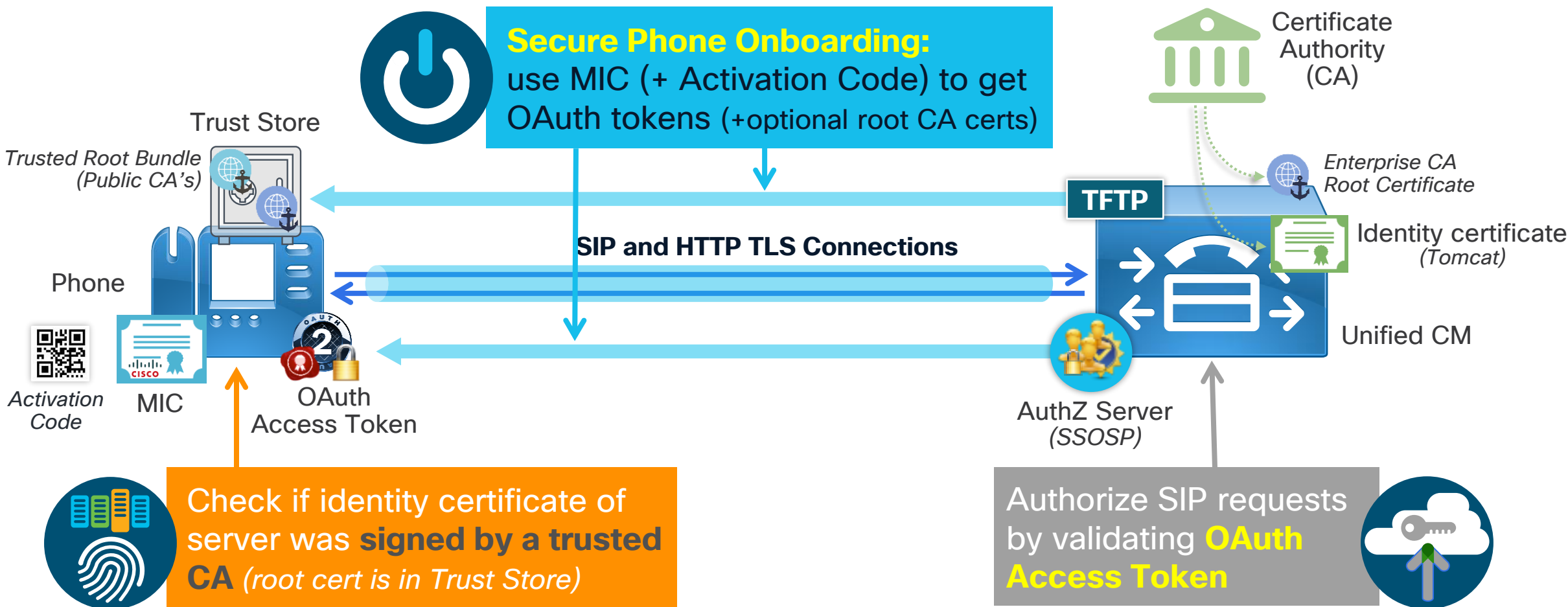
[OAuth Access Token for Devices](#) * Implicit: Already registered devices ▾ Implicit: Already registered devices

[Auto Renew Refresh Token](#) * Enabled ▾ Enabled

Simplified Device Onboarding & Provisioning

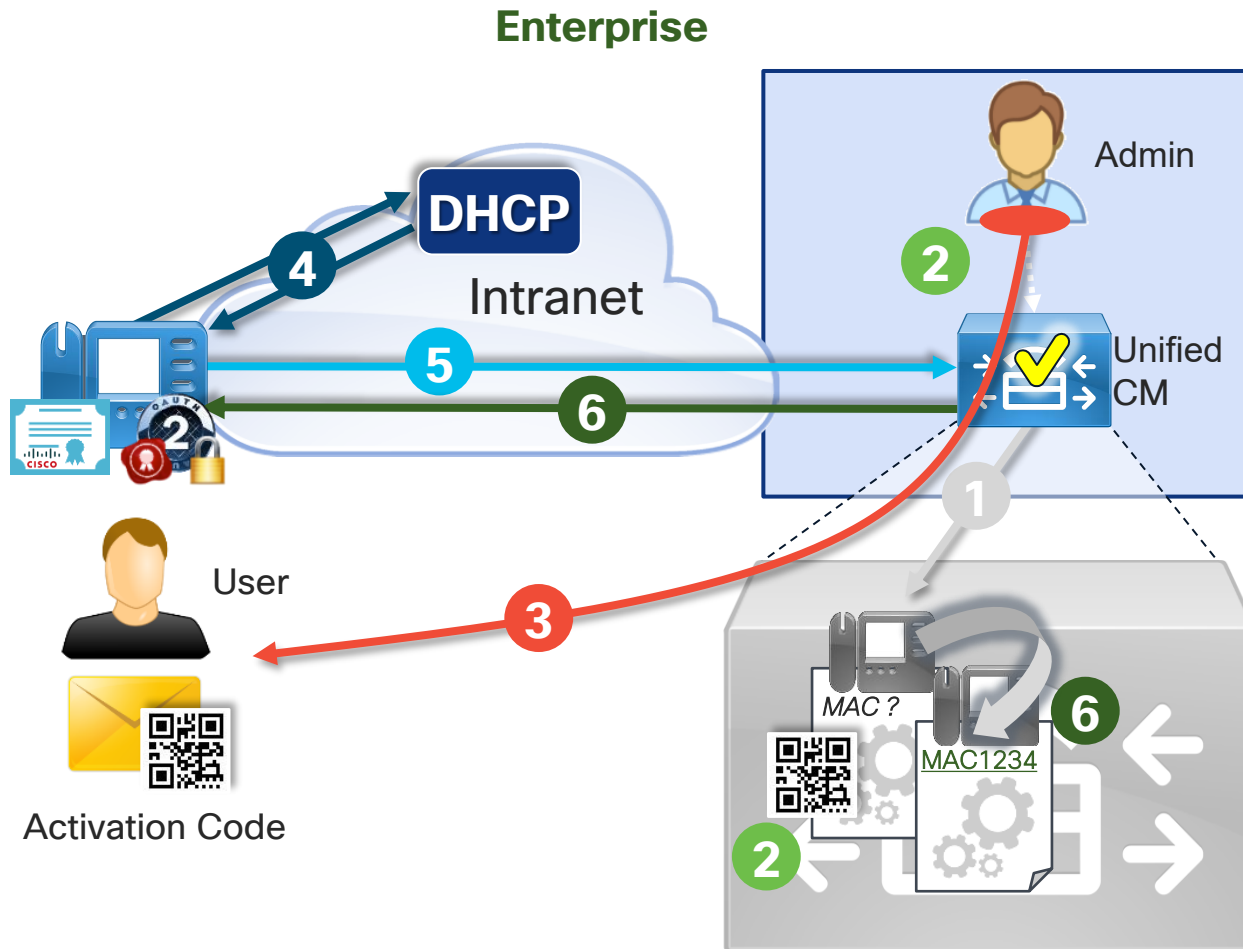
Always-secure Phones with OAuth

Enrollment: Secure Phone Onboarding



Activation Code Onboarding

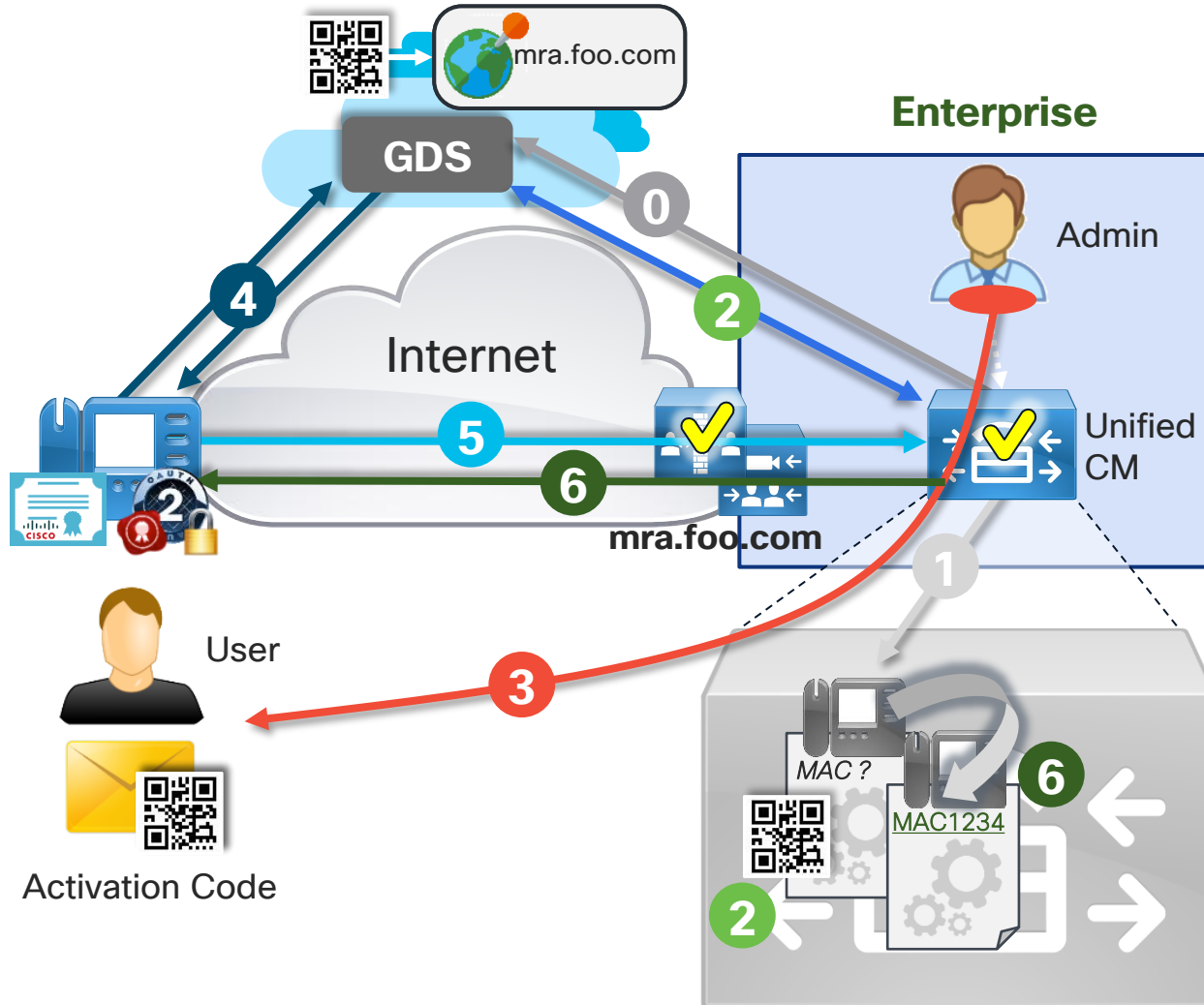
On-Premises Flow



- 1 Admin creates full device config, may leave MAC address blank
- 2 Admin requests activation code for this device (Unified CM-generated)
- 3 Activation code sent to/retrieved by user
- 4 Phone gets Unified CM target from DHCP opt 150/TFTP, user enters act. code
- 5 Phone authenticates to Unified CM using MIC + activation code
- 6 Unified CM updates device config with phone MAC. Phone can now get its config from TFTP and register

Activation Code Onboarding

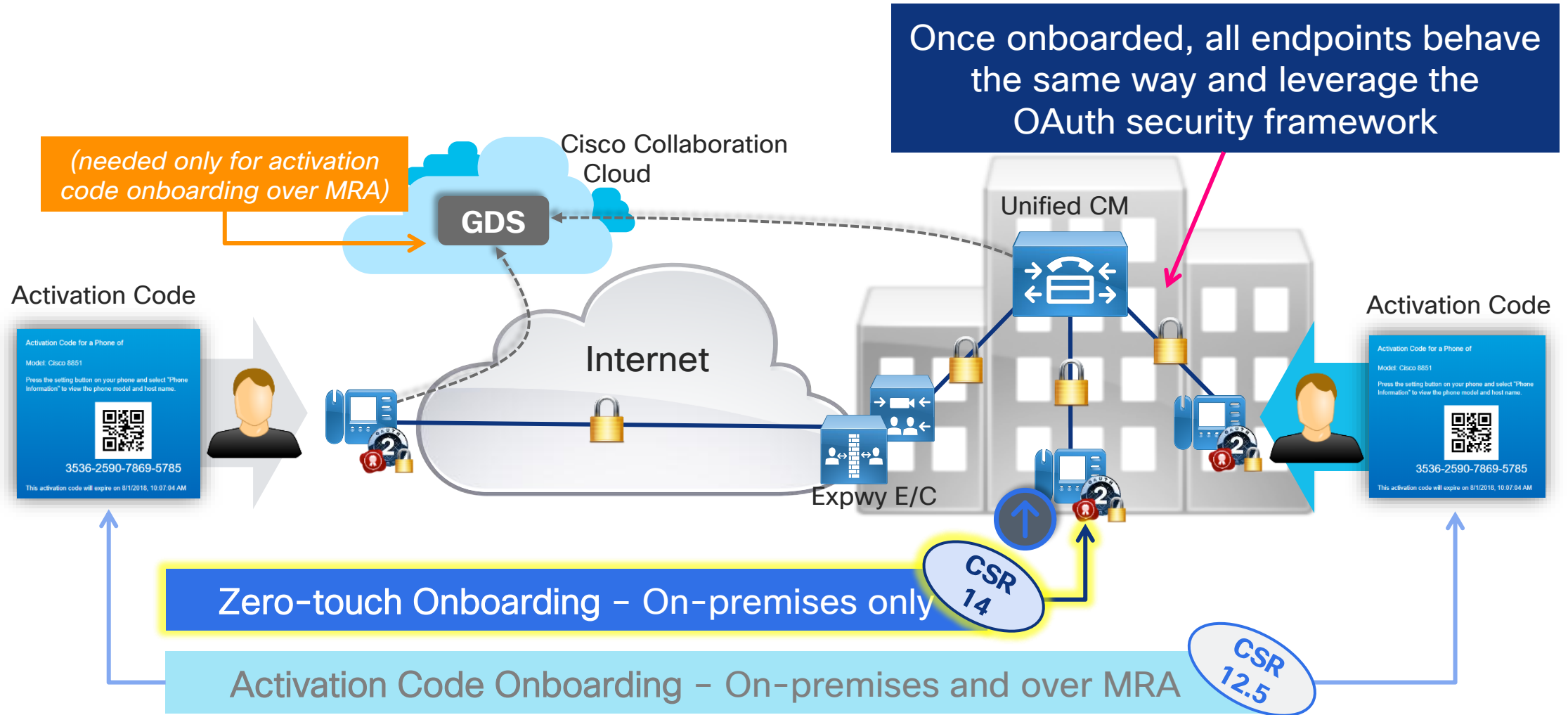
MRA Flow



- 0 Unified CM onboards with cloud/GDS, creates MRA target (+optional CA)
- 1 Admin creates full device config, may leave MAC address blank
- 2 Admin requests activation code for this device (Act. ID from GDS, OTP from Unified CM)
- 3 Activation code sent to a user/admin
- 4 User enters activation code, phone gets MRA target (+ opt. CA) from GDS
- 5 Phone authenticates to Expwy/Unified CM using MIC + activation code
- 6 Unified CM updates device config with phone MAC, sends tokens (+CA) to phone. Phone can now download config and register

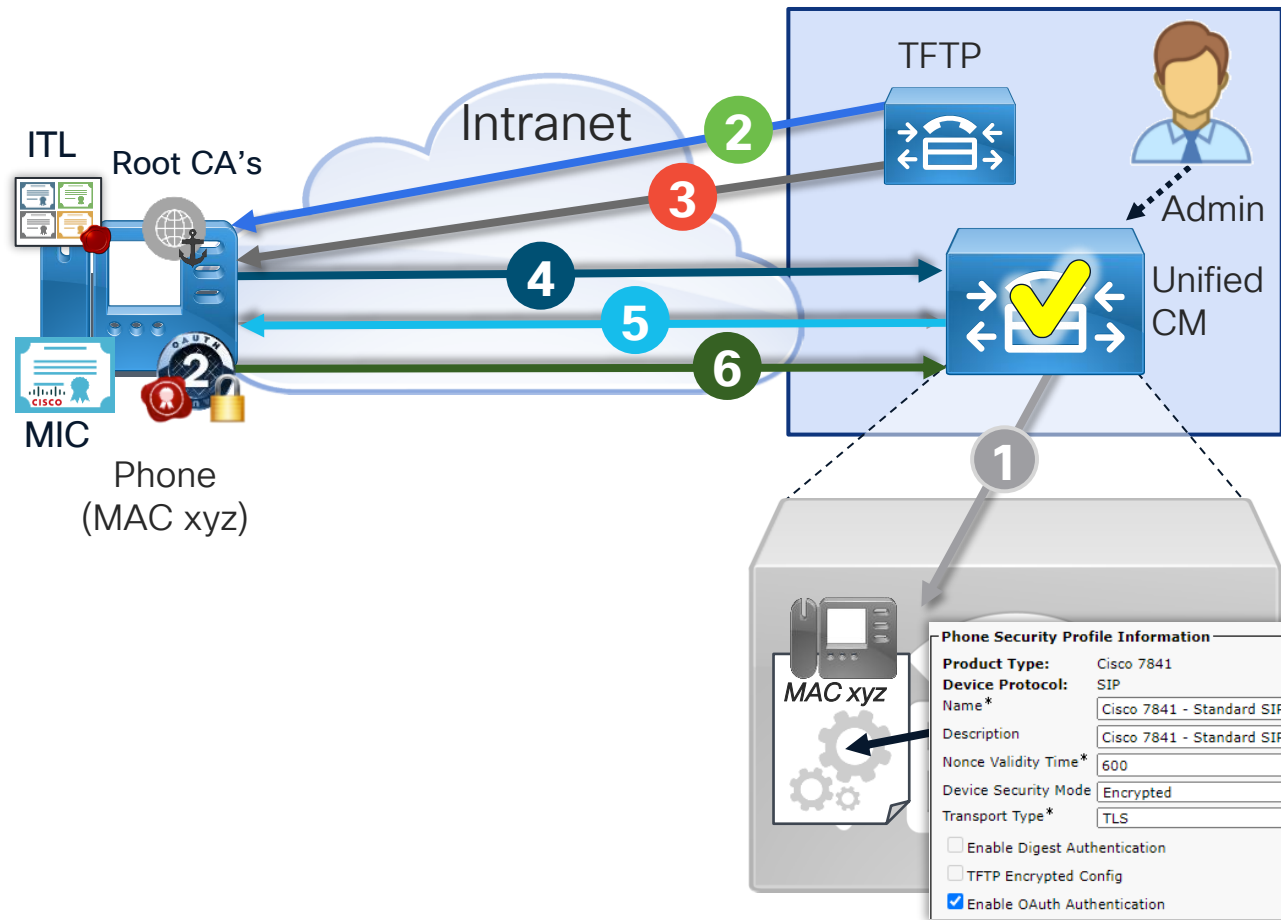
Secure Phone Onboarding

New Option with CSR 14: Zero-Touch Onboarding



Zero-Touch Onboarding

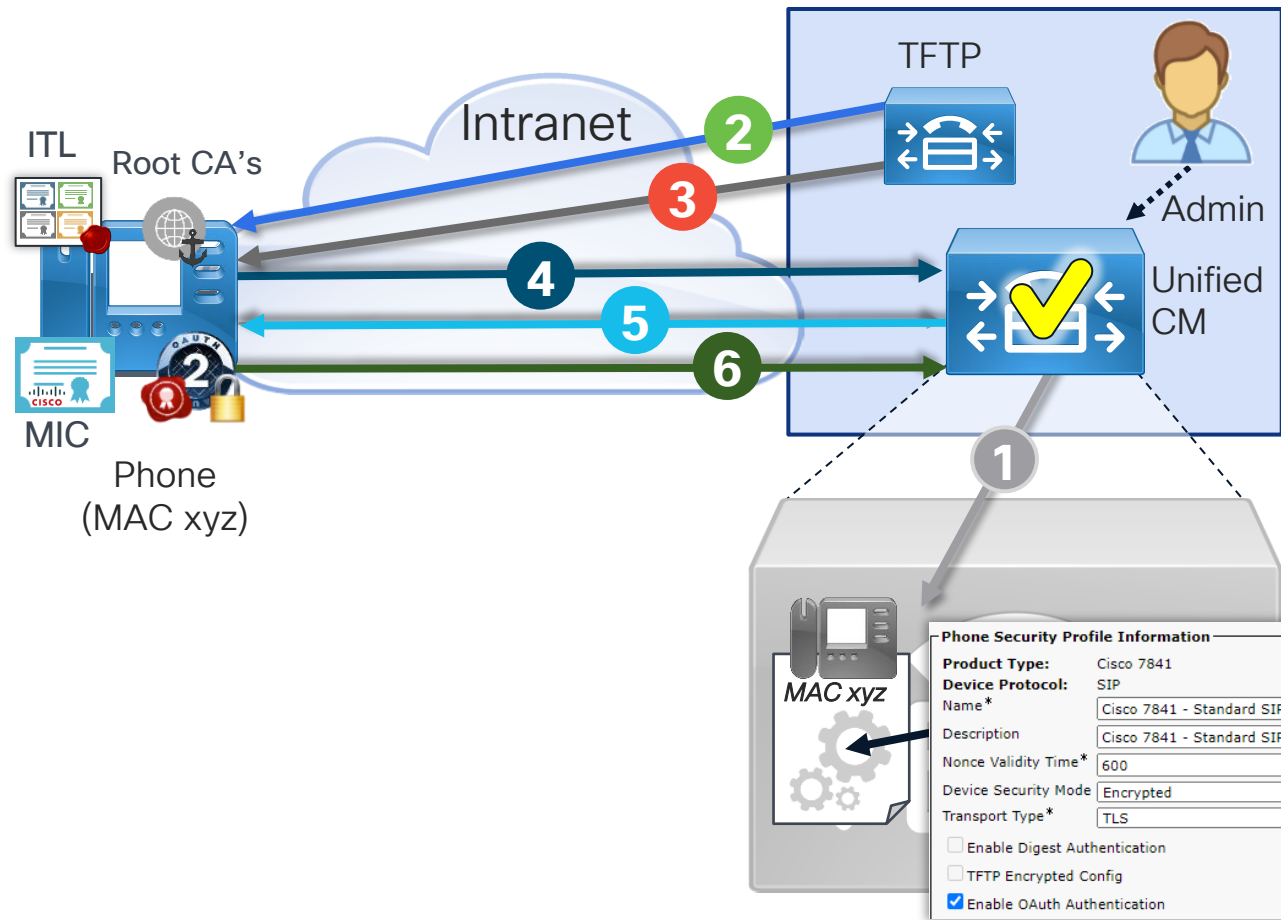
On-premises Only – CSR 14



- 0 Phone is registered in non-secure mode
- 1 Admin configures Phone Security Profile with Encrypted mode and OAuth Authentication, then resets phone
- 2 Phone gets new "mini-config" from TFTP that indicates SIP OAuth mode
- 3 Phone downloads signed CA trust anchor file over from TFTP (uses ITL to validate)
- 4 Phone requests OAuth tokens from UCM over HTTPS, validates cert with trust store and is challenged for MIC/LSC
- 5 UCM checks MAC address in MIC is present in DB and issues OAuth tokens
- 6 Phone can now register with SIP OAuth

Zero-Touch Onboarding

On-premises Only – CSR 14



0 Phone is registered in non-secure mode

1 Admin configures Phone Security Profile with Encrypted mode and OAuth Authentication, then resets phone

2 Phone gets new "mini-config" from TFTP that indicates SIP OAuth mode

3 Phone downloads signed CA trust anchor file over from TFTP (uses ITL to validate)

4 Phone requests OAuth token from UCM over HTTPS, validates cert with trust store and is challenged for MIC/LSC

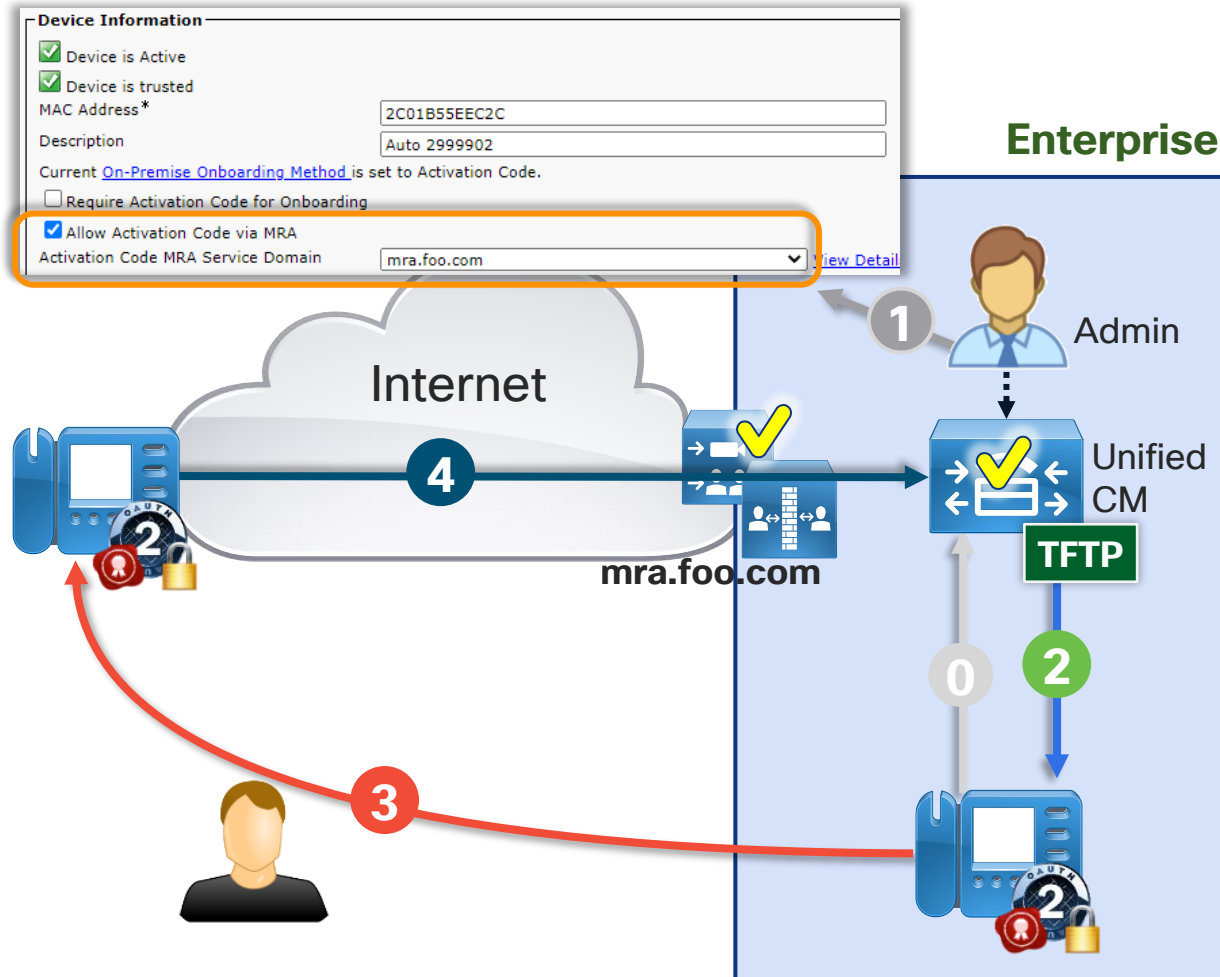
5 UCM checks MAC address in MIC is present in DB and issues OAuth tokens

6 Phone can now register with SIP OAuth

Moving Onboarded Phones Off-premises

From On-premises to MRA – CSR 12.5+

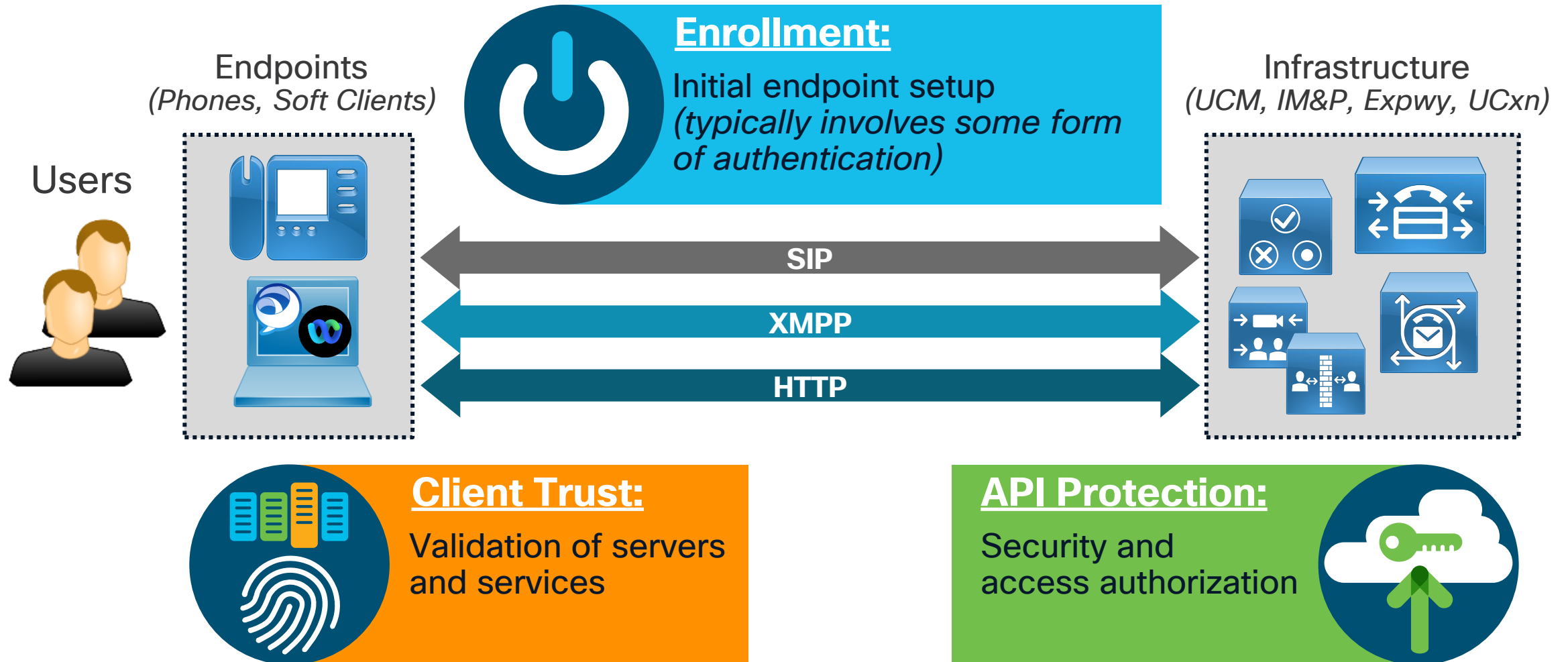
Unified CM Admin > Device > Phone :



Conclusions & References

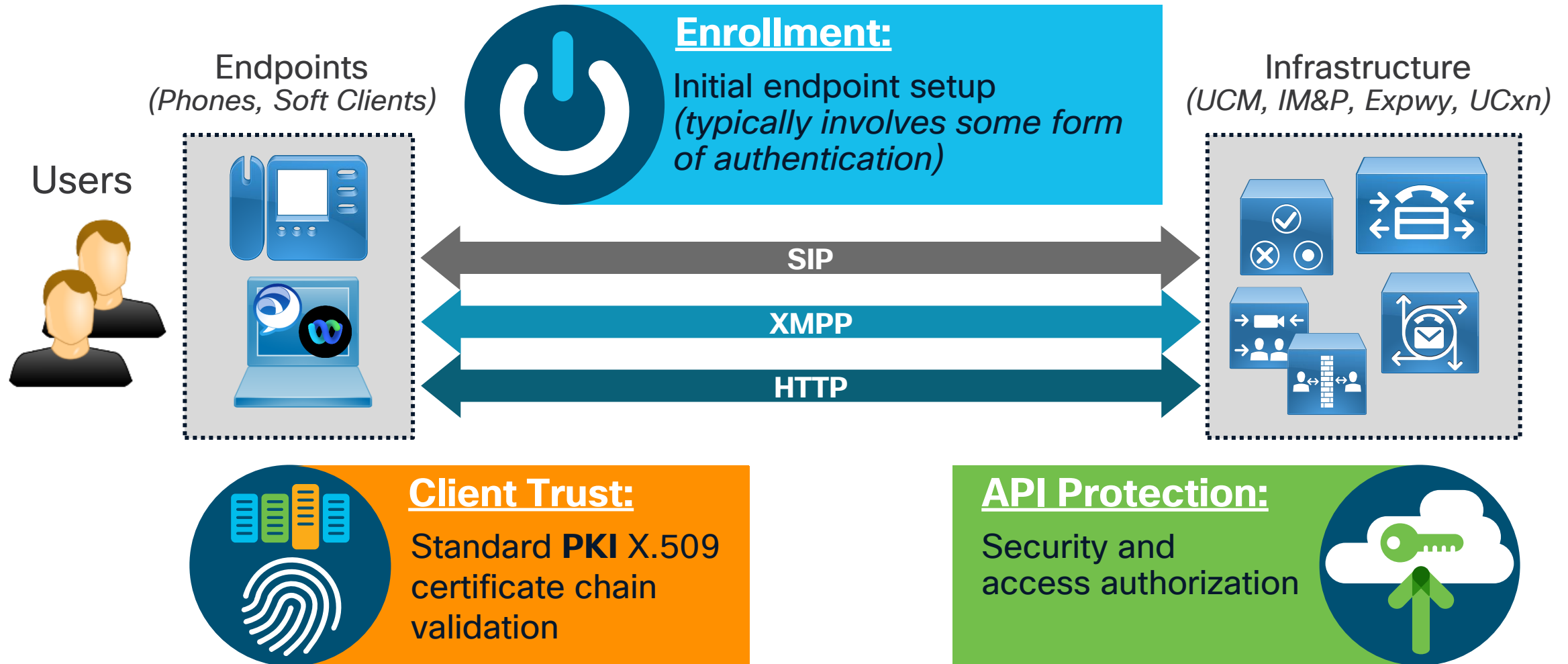
Unified CM Security Architecture

Key Areas for UC Security



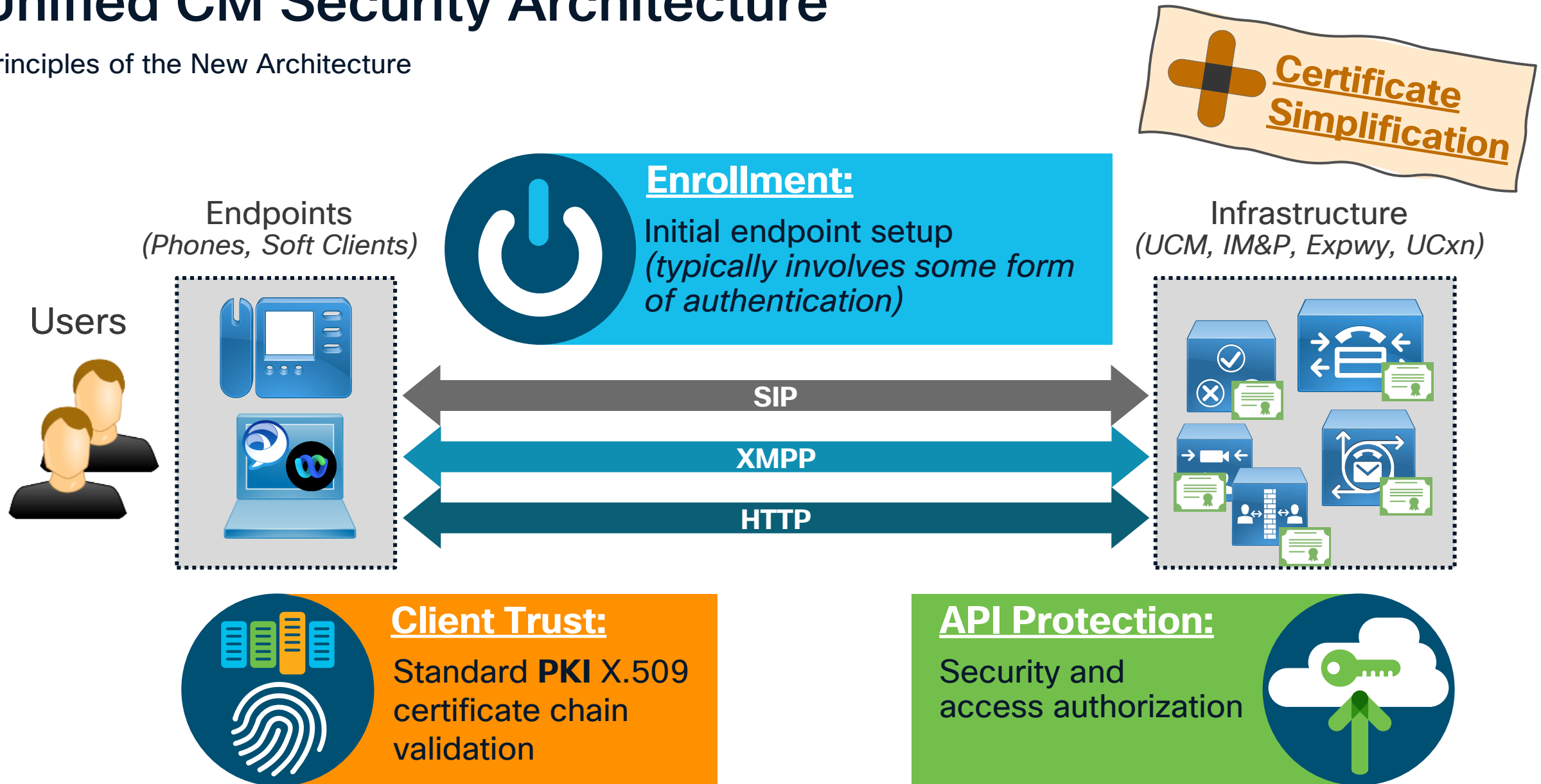
Unified CM Security Architecture

Principles of the New Architecture



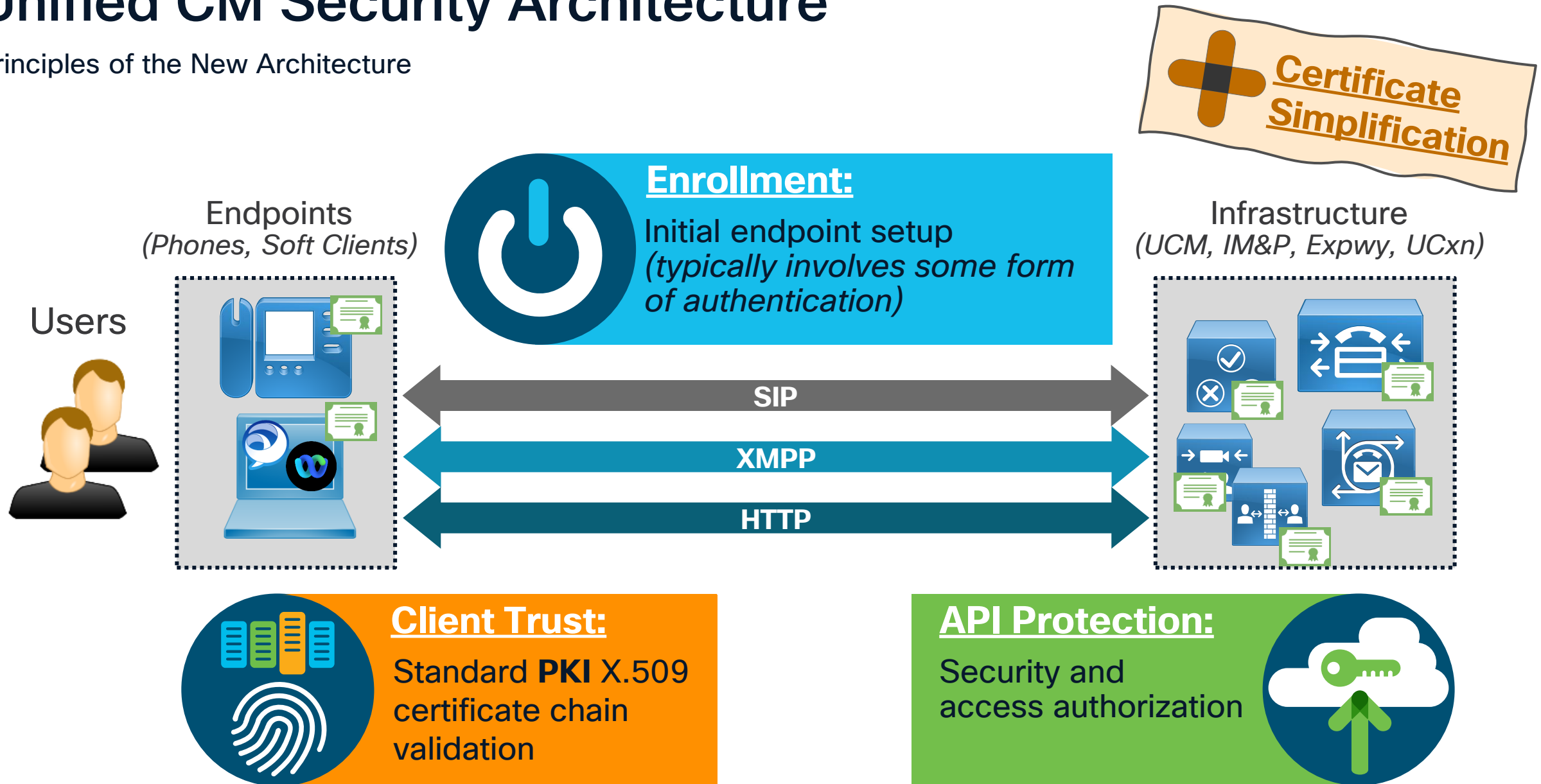
Unified CM Security Architecture

Principles of the New Architecture



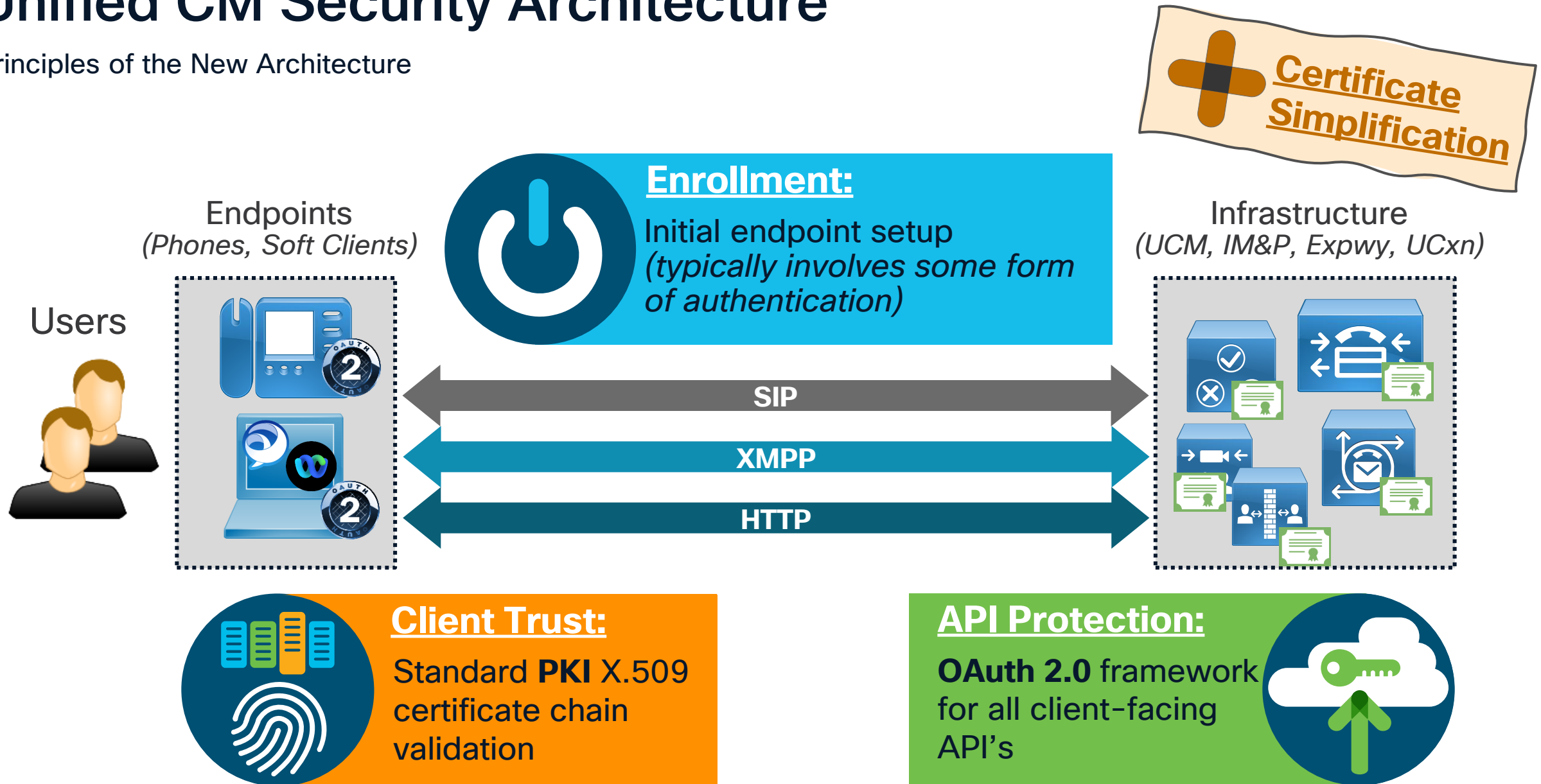
Unified CM Security Architecture

Principles of the New Architecture



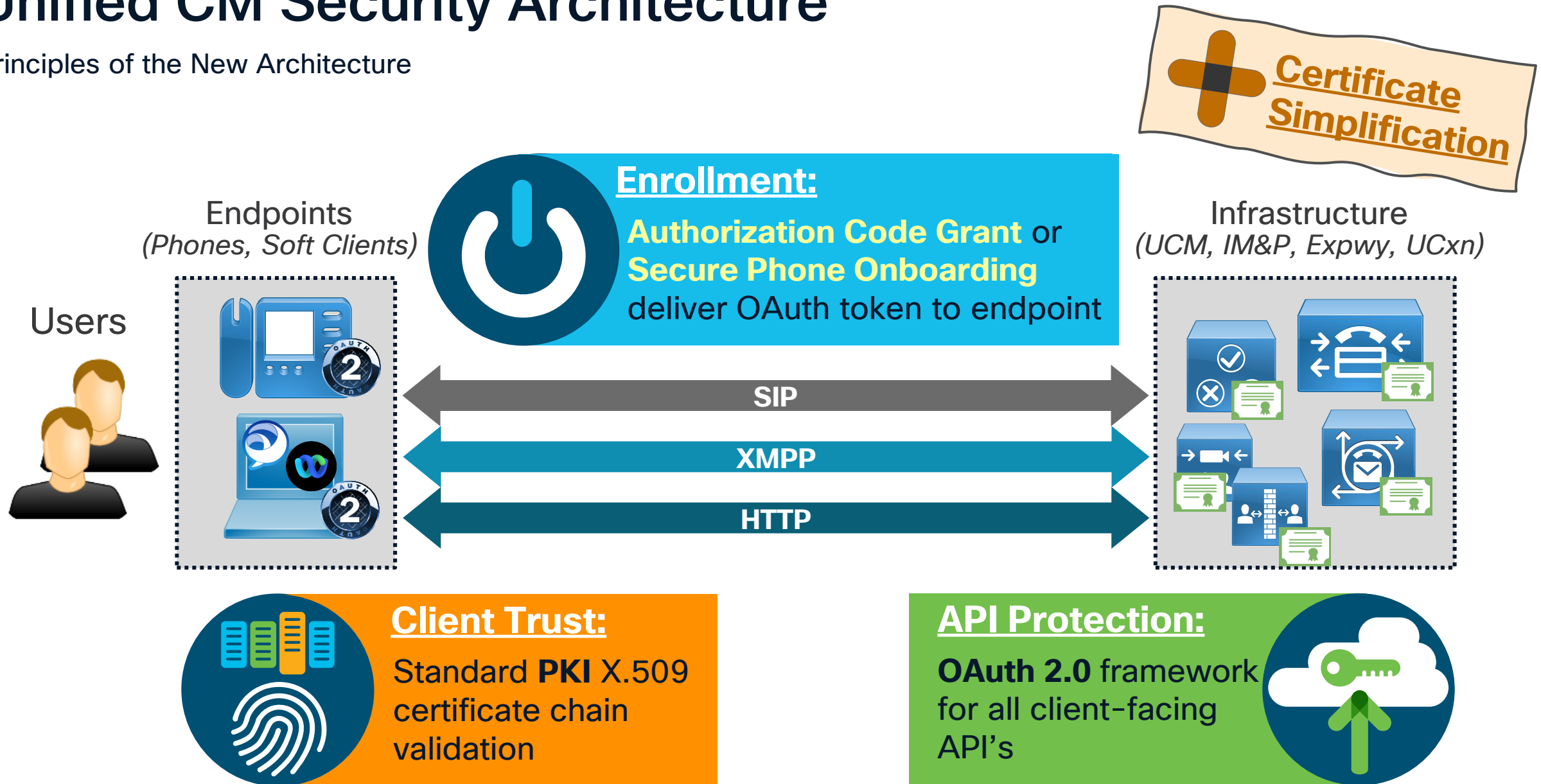
Unified CM Security Architecture

Principles of the New Architecture



Unified CM Security Architecture

Principles of the New Architecture



References – PKI

- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Certificate Authority Proxy Function**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_certificate-authority-proxy-function_su2_reorg.html
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **ITL/CTL/TVS/Encryption**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_default-security-setup_su2_reorg.html
- Cisco PKI: **Policies, Certificates, and Documents**
<https://www.cisco.com/security/pki/>

References – Cert Management & Encryption

- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Certificates**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_certificates.html
- Administration Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Manage Certificates**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/admin/15/adminGd/cucm_b_administration-guide-15/cucm_b_test-adminguide_chapter_01111.html
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Cipher Management**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_cipher-management_r_15.html
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **TLS 1.3 Setup**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_tls-setup_2.html
- On-Premises Calling Products Field Notice: FN74345 – **Impact on Secure Communication Due to Upcoming Changes to TLS certificates Issued by Public Certificate Authorities with Client Authentication ECU**
<https://www.cisco.com/c/en/us/support/docs/field-notices/743/fn74345.html>

References – OAuth 2.0 and API Protection

- The OAuth 2.0 Authorization Framework – **RFC6749**
<https://www.rfc-editor.org/rfc/rfc6749>
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Phone Security Overview**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_phone-security_reorg.html
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **SIP OAuth Mode**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_sip-oauth-mode-on-unified.html
- Security Guide for Cisco Unified Communications Manager, Release 15 and SUs – **OAuth Framework**
https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/security/15_0/cucm_b_security-guide-release-15/cucm_m_identity-management.html#reference_C8208B54F36A0A4813A69E859A14F6B2

References – Simplified Onboarding / Provisioning

- System Configuration Guide for Cisco Unified Communications Manager, Release 15 and SUs – **Device Onboarding via Activation Codes**

https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/cucm/admin/15/systemConfig/cucm_b_system-configuration-guide-15/cucm_b_system-configuration-guide-14_chapter_0100000.html

- Mobile and Remote Access Through Cisco Expressway Deployment Guide (X15.0) – **Onboarding MRA Devices**

https://www.cisco.com/c/en/us/td/docs/voice_ip_comm/expressway/config_guide/X15-0/mra/exwy_b_mra-deployment-guide-x150/exwy_m_provisioning-mra-devices.html

Complete your session surveys



Complete your surveys in the Cisco Events App.



Complete a minimum of 4 session surveys and the overall event survey to receive a unique Cisco Live t-shirt.
(from 11:30 on Thursday, while supplies last)

Continue your education



Visit the Cisco Showcase for related demos



Book your one-on-one Meet the Engineer meeting

Visit the Technical Solutions Clinics to discuss your technical questions



Attend the interactive education with DevNet, Capture the Flag, and Walk-in Labs



Visit the On-Demand Library for more sessions at CiscoLive.com/On-Demand

Contact me at: Contact me via Webex

Thank you

CISCO Live !

